

# **An AI-Driven Risk Quantification Model for Industrial Internet of Things Devices**

By Matthew Choiniere

B.S. in Computer Networks & Cybersecurity, University of Maryland, May 2017

M.P.S. in Information Assurance, Pennsylvania State University, August 2019

A Praxis submitted to

The Faculty of  
The School of Engineering and Applied Science of  
The George Washington University  
in partial fulfilment of the requirements for  
the Degree of Doctor of Engineering

January 9, 2026

Praxis directed by

Artem Stepanov  
Professorial Lecturer of Engineering Management and Systems Engineering

The School of Engineering and Applied Sciences of The George Washington University certifies that Matthew Choiniere has passed the Final Examination for the degree of Doctor of Engineering as of November 20, 2025. This is the final and approved form of the Praxis.

**An AI-Driven Risk Quantification Model for Industrial Internet of Things Devices**

Matthew Choiniere

Praxis Research Committee:

Artem Stepanov, Professional Lecturer in Engineering and Applied Science,  
Praxis Director

John Fossaceca, Adjunct Professor of Engineering and Applied Science,  
Committee Chair

John Dargan, Adjunct Professor of Engineering and Applied Science,  
Committee Member

© Copyright 2025 by Matthew Choiniere  
All rights reserved.

## **Dedication**

This praxis is dedicated to my wife Lauren, because without her, I would never have had any of the success I have enjoyed in life thus far. Her love and support throughout this degree and my career was what pushed me to succeed. She has been the source of my strength and biggest cheerleader, and I will forever be grateful for her unwavering support and dedication. I love you so much and am thankful I have you in my life.

## **Acknowledgments**

I want to extend my gratitude and appreciation to Dr. Stepanov and the members of the SEAS faculty for their support and guidance throughout the learning phase and the research of this praxis. Your collective wisdom has been pivotal to my professional growth, and I am grateful for the support I received.

I would not have been able to make it this far without that support and invaluable insight. Your mentorship has helped shape this project to what it has become and your patience with my indecisiveness at times was deeply appreciated and showed me true commitment to my success.

To my fellow classmates in our cohort. These last two years have been challenging and sometimes frustrating, but without the constant communication and ability to laugh when times were tough, it would have been difficult to make it through the program without you all. I am grateful to have met you all and I appreciate everyone's willingness to stick through this until the end.

## **Abstract of Praxis**

### **An AI-Driven Risk Quantification Model for Industrial Internet of Things Devices**

In recent years there has been a significant increase in the integration of Information Technology (IT) with Operational Technology (OT). As a result, there are now more vulnerabilities available to attackers than ever before within the Industrial Internet of Things (IIoT), and many of these vulnerabilities can be found at the critical infrastructure level. Unfortunately, most of the current methods of detecting cyberattacks such as rule-based Intrusion Detection Systems (IDS) and the use of manually monitored systems, are unable to quickly identify new types of attacks or provide immediate information on the scope of damage done during those attacks. This is why this research is developing and evaluating an Artificial Intelligence (AI) driven Risk Quantification Model for Modbus-based IIoT systems using supervised machine learning. In order to evaluate the performance of the Risk Quantification Model, a dataset called ToN\_IoT Modbus was used, which is a dataset of network behaviors and device telemetry provided by the University of New South Wales. Raw data from both Network Behavior Data and Device Telemetry Data was analyzed to determine when abnormal behavior had occurred in the IIoT System.

Once the data was transformed into a high-fidelity format for analysis, the data was normalized and timestamped for subsequent analysis. Stratified random sampling was then performed on the data to train and validate a Random Forest classifier that could categorize data as either normal or abnormal. The classifier achieved a detection accuracy of 94.5%, an F1 Score of 0.94 and an AUC ROC of 0.975, indicating that the Random Forest classifier achieved significantly higher accuracy for detecting abnormal behavior

in the IIoT System compared to previous traditional rule-based Intrusion Detection Systems (IDS). Statistical testing of the results using t-tests and bootstrapping confirmed the validity and reliability of the results of this study.

The results from this study support all three Research Hypotheses and show that the use of machine learning based risk quantification improves detection accuracy, reduces MTTR greater than 50% and improves classification performance of the IIoT system through the use of both network data and telemetry data. These empirical results suggest there is potential for future integration of AI-based models into industrial cybersecurity monitoring systems to provide an additional layer of defense against the growing number of IIoT cyber threats.

## Table of Contents

|                                                |             |
|------------------------------------------------|-------------|
| <b>Acknowledgments.....</b>                    | <b>v</b>    |
| <b>Abstract of Praxis.....</b>                 | <b>vi</b>   |
| <b>List of Figures.....</b>                    | <b>xiv</b>  |
| <b>List of Tables .....</b>                    | <b>xv</b>   |
| <b>List of Equations.....</b>                  | <b>xvi</b>  |
| <b>List of Acronyms.....</b>                   | <b>xvii</b> |
| <b>Chapter 1: Introduction .....</b>           | <b>1</b>    |
| 1.1    Background.....                         | 1           |
| 1.2    Research Motivation.....                | 4           |
| 1.3    Problem Statement .....                 | 7           |
| 1.4    Thesis Statement .....                  | 7           |
| 1.5    Research Objectives .....               | 8           |
| 1.6    Research Questions and Hypotheses ..... | 9           |
| 1.7    Scope of Research .....                 | 10          |
| 1.8    Research Limitations .....              | 11          |
| 1.9    Organization of Praxis .....            | 12          |
| <b>Chapter 2: Literature Review.....</b>       | <b>14</b>   |
| 2.1    Introduction.....                       | 14          |
| 2.2    IT/OT Overview and Relationship .....   | 17          |
| 2.3    Modbus Protocol.....                    | 20          |
| 2.3.1    How Modbus Works .....                | 21          |



|        |                                                                           |    |
|--------|---------------------------------------------------------------------------|----|
| 2.3.2  | Security Limitations of Legacy Modbus.....                                | 22 |
| 2.3.3  | Secure Modbus Variants and Migration Challenges.....                      | 24 |
| 2.3.4  | Modbus and Machine Learning-Based Risk Quantification.....                | 25 |
| 2.4    | IIoT System Architecture.....                                             | 26 |
| 2.4.1  | Core Layers of IIoT Architecture .....                                    | 26 |
| 2.4.2  | IT/OT Convergence in IIoT Architectures.....                              | 28 |
| 2.4.3  | Security Implications of IIoT Architectures.....                          | 28 |
| 2.5    | Traditional Security Approaches in IIoT.....                              | 29 |
| 2.6    | IIoT Vulnerabilities .....                                                | 33 |
| 2.7    | Major Cyber Attacks Targeting IIoT Systems.....                           | 38 |
| 2.8    | The Need for Adaptive Security in IIoT Environments .....                 | 42 |
| 2.9    | Risk Frameworks for Industrial Control Systems.....                       | 45 |
| 2.9.1  | NIST SP 800-82.....                                                       | 46 |
| 2.9.2  | ISA/IEC 62443 .....                                                       | 47 |
| 2.9.3  | Limitations of Static Risk Frameworks .....                               | 47 |
| 2.9.4  | Toward Dynamic and Adaptive Risk Quantification.....                      | 48 |
| 2.9.5  | Hybrid Frameworks: Combining Qualitative and Quantitative<br>Models ..... | 49 |
| 2.10   | Machine Learning in IIoT Cybersecurity .....                              | 51 |
| 2.10.1 | Supervised Learning in IIoT Security.....                                 | 51 |
| 2.10.2 | Unsupervised Learning for Novel Threats.....                              | 53 |
| 2.10.3 | Federated Learning for Privacy-Preserving Detection.....                  | 55 |
| 2.10.4 | Graph Neural Networks for Interconnected Systems.....                     | 56 |

|        |                                                                                  |    |
|--------|----------------------------------------------------------------------------------|----|
| 2.10.5 | Reinforcement Learning for Adaptive Defense.....                                 | 57 |
| 2.10.6 | Critical Evaluation of ML Limitations .....                                      | 58 |
| 2.10.7 | Failed ML Deployments in IIoT .....                                              | 60 |
| 2.10.8 | Comparative Insights and Hybrid Approaches.....                                  | 61 |
| 2.11   | Related Work: Machine Learning and Anomaly Detection for Modbus<br>Security..... | 62 |
| 2.12   | Comparative Studies: Rule-Based vs AI-Driven Detection.....                      | 64 |
| 2.12.1 | Large-Scale Dataset Evaluations.....                                             | 65 |
| 2.12.2 | Reduction of False Positives and Analyst Burden.....                             | 66 |
| 2.12.3 | Deployment Feasibility on Edge Devices .....                                     | 67 |
| 2.12.4 | Comparative Analysis of Rule-Based vs. AI Approaches.....                        | 67 |
| 2.12.5 | Emerging Trends in AI-Enhanced IIoT Security.....                                | 69 |
| 2.13   | Datasets Available for Research.....                                             | 70 |
| 2.13.1 | SWaT (Secure Water Treatment) Dataset.....                                       | 71 |
| 2.13.2 | WADI (Water Distribution) Dataset.....                                           | 71 |
| 2.13.3 | TON_IoT Dataset.....                                                             | 72 |
| 2.13.4 | BoT-IoT Dataset .....                                                            | 72 |
| 2.13.5 | N-BaIoT Dataset .....                                                            | 73 |
| 2.13.6 | Summary .....                                                                    | 74 |
| 2.14   | Research Gaps and Opportunities.....                                             | 75 |
| 2.14.1 | Model Robustness.....                                                            | 75 |
| 2.14.2 | Dataset Limitations .....                                                        | 75 |
| 2.14.3 | Dataset Bias and Generalizability .....                                          | 76 |

|                   |                                                          |           |
|-------------------|----------------------------------------------------------|-----------|
| 2.14.4            | Standards Integration.....                               | 77        |
| 2.15              | Conclusion .....                                         | 78        |
| <b>Chapter 3:</b> | <b>Methodology.....</b>                                  | <b>79</b> |
| 3.1               | Overview of Methodology .....                            | 79        |
| 3.2               | Data Sources and Preprocessing.....                      | 80        |
| 3.2.1             | Dataset Description .....                                | 80        |
| 3.2.2             | Data Cleaning .....                                      | 81        |
| 3.3               | Machine Learning Model Development .....                 | 82        |
| 3.3.1             | Model Choice and Justification.....                      | 82        |
| 3.3.2             | Data Splitting.....                                      | 83        |
| 3.3.3             | Model Training .....                                     | 83        |
| 3.3.4             | Hyperparameter Optimization and Performance Tuning ..... | 84        |
| 3.3.5             | Cross-Validation Methodology .....                       | 84        |
| 3.3.6             | Model Evaluation Criteria .....                          | 85        |
| 3.3.7             | Accuracy .....                                           | 85        |
| 3.3.8             | Precision.....                                           | 86        |
| 3.3.9             | Recall (Sensitivity or True Positive Rate).....          | 87        |
| 3.3.10            | F1-Score .....                                           | 87        |
| 3.3.11            | Receiver Operating Characteristic and AUC (ROC-AUC)..... | 87        |
| 3.3.12            | Summary of Evaluation Metrics .....                      | 88        |
| 3.4               | Risk Score Computation .....                             | 89        |
| 3.5               | Baseline Rule-Based Detection Framework.....             | 89        |
| 3.6               | Anomaly Detection.....                                   | 90        |

|                                 |                                                                                     |           |
|---------------------------------|-------------------------------------------------------------------------------------|-----------|
| 3.6.1                           | Dynamic Thresholding .....                                                          | 90        |
| 3.6.2                           | Anomaly Aggregation .....                                                           | 90        |
| 3.7                             | Limitations .....                                                                   | 91        |
| 3.8                             | Summary .....                                                                       | 91        |
| <b>Chapter 4: Results .....</b> |                                                                                     | <b>92</b> |
| 4.1                             | Introduction.....                                                                   | 92        |
| 4.2                             | Data Preprocessing and Exploratory Data Analysis (EDA) .....                        | 92        |
| 4.2.1                           | Overview .....                                                                      | 92        |
| 4.2.2                           | Data Integration .....                                                              | 92        |
| 4.2.3                           | Column Renaming and Standardization .....                                           | 94        |
| 4.2.4                           | Timestamp Cleaning and Recovery.....                                                | 96        |
| 4.2.5                           | Ground Truth Alignment and Labeling .....                                           | 98        |
| 4.2.6                           | Feature Selection and Preprocessing .....                                           | 100       |
| 4.2.7                           | Exploratory Statistics .....                                                        | 101       |
| 4.2.8                           | Visualization and Class Separation .....                                            | 101       |
| 4.2.9                           | EDA Summary .....                                                                   | 103       |
| 4.3                             | Results of Model Performance .....                                                  | 105       |
| 4.3.1                           | H1: Accuracy of Machine Learning Models vs Rule-Based Detection..                   | 106       |
| 4.3.2                           | H2: Reduction in Mean Time to Resolve (MTTR) Using AI-Based<br>Risk Scoring .....   | 107       |
| 4.3.3                           | H3: Performance Gain from Integrating Network Behavior and<br>Device Telemetry..... | 108       |
| 4.4                             | Statistical Confidence and Performance Stability.....                               | 109       |

|                                    |                                                       |            |
|------------------------------------|-------------------------------------------------------|------------|
| 4.5                                | Effect Size and Practical Significance .....          | 109        |
| 4.6                                | Feature Importance and Operational Implications ..... | 110        |
| 4.7                                | Conclusion .....                                      | 110        |
| <b>Chapter 5: Conclusion .....</b> |                                                       | <b>111</b> |
| 5.1                                | Discussion .....                                      | 111        |
| 5.1.1                              | Research Questions and Hypotheses .....               | 111        |
| 5.1.2                              | Failure Mode Analysis .....                           | 116        |
| 5.1.3                              | Deployment Pathway .....                              | 116        |
| 5.1.4                              | Limitations Acknowledgment .....                      | 117        |
| 5.1.5                              | Adversarial Robustness .....                          | 117        |
| 5.1.6                              | Regulatory and Compliance Considerations .....        | 118        |
| 5.1.7                              | Cost–Benefit Analysis .....                           | 118        |
| 5.2                                | Conclusions .....                                     | 119        |
| 5.3                                | Contributions to the Body of Knowledge .....          | 119        |
| 5.4                                | Future Work and Improvements .....                    | 120        |
| <b>References .....</b>            |                                                       | <b>121</b> |

## List of Figures

|                                                 |     |
|-------------------------------------------------|-----|
| Figure 1: IoT Market 2019-2030.....             | 16  |
| Figure 2: Modbus Communication Protocol .....   | 21  |
| Figure 3: IIoT Architecture .....               | 27  |
| Figure 4: Stuxnet Attack.....                   | 39  |
| Figure 5: BlackEnergy Attack.....               | 40  |
| Figure 6: NotPetya Attack .....                 | 41  |
| Figure 7: Colonial Pipeline Attack .....        | 42  |
| Figure 8: Random Forest Trees .....             | 52  |
| Figure 9: Isolated Forest Model .....           | 54  |
| Figure 10: Federated Learning Model .....       | 55  |
| Figure 11: Graph Neural Network.....            | 57  |
| Figure 12: Reinforcement Learning Model.....    | 58  |
| Figure 13: Methodology Pipeline .....           | 80  |
| Figure 14: Ground Truth Alignment Process. .... | 99  |
| Figure 15: Risk Score Spread.....               | 101 |
| Figure 16: Confusion Matrix.....                | 102 |
| Figure 17: Risk Score Distribution.....         | 102 |
| Figure 18: Feature Correlation Heatmap.....     | 103 |

## List of Tables

|           |                                                 |     |
|-----------|-------------------------------------------------|-----|
| Table 1:  | Rule-Based vs AI-Driven Detection Systems ..... | 68  |
| Table 2:  | Comparisons of Major IIoT Datasets .....        | 73  |
| Table 3:  | Evaluation Metrics .....                        | 88  |
| Table 4:  | Normal Samples .....                            | 93  |
| Table 5:  | Injection Attack Samples .....                  | 93  |
| Table 6:  | Backdoor Attack Samples .....                   | 93  |
| Table 7:  | Password Attack Samples .....                   | 93  |
| Table 8:  | Scanning Attack Samples.....                    | 94  |
| Table 9:  | Cross Site Scripting Attack Samples.....        | 94  |
| Table 10: | Ground Truth Labeling Example .....             | 94  |
| Table 11: | Classification Report.....                      | 108 |

## List of Equations

|             |                                 |    |
|-------------|---------------------------------|----|
| Equation 1: | Accuracy .....                  | 85 |
| Equation 2: | Precision.....                  | 86 |
| Equation 3: | Recall .....                    | 87 |
| Equation 4: | F1-Score.....                   | 87 |
| Equation 5: | Area Under the Curve (AUC)..... | 88 |



## **List of Acronyms**

|         |                                                        |
|---------|--------------------------------------------------------|
| AI      | Artificial Intelligence                                |
| AUC     | The area under the ROC curve                           |
| AUC-ROC | Area Under the Receiver Operating Characteristic Curve |
| CI      | Critical Infrastructure                                |
| CISA    | Cybersecurity and Infrastructure Security Agency       |
| DDoS    | Distributed Denial-of-Service                          |
| DoS     | Denial-of-Service                                      |
| EDA     | Exploratory Data Analysis                              |
| FPR     | False Positive Rate                                    |
| GNN     | Graph Neural Networks                                  |
| ICS     | Industrial Control System                              |
| IEC     | International Electrotechnical Commission              |
| IIoT    | Industrial Internet of Things                          |
| IDS     | Intrusion Detection Systems                            |
| ISA     | International Society of Automation                    |
| IT      | Information Technology                                 |
| MITM    | Man-in-the-Middle                                      |
| ML      | Machine Learning                                       |
| MTTR    | Mean Time to Resolve                                   |
| OT      | Operational Technology                                 |
| PLC     | Programmable Logic Controllers                         |
| RF      | Random Forest                                          |
| RL      | Reinforcement Learning                                 |

|       |                                          |
|-------|------------------------------------------|
| ROC   | Receiver Operating Characteristic        |
| SCADA | Supervisory Control and Data Acquisition |
| SVM   | Support Vector Machines                  |
| SWaT  | Secure Water Treatment                   |
| TLS   | Transport Layer Security                 |
| UNSW  | University of New South Wales            |
| WADI  | Water Distribution                       |
| XSS   | Cross-Site Scripting                     |

## **Chapter 1: Introduction**

### **1.1 Background**

The Internet of Things has existed for many years and has become more popular in recent years. These devices are found in a wide range of industries, such as personal fitness devices, smart homes, healthcare, industrial automation, and critical infrastructure (CI). The increased use of IoT devices has introduced many new security vulnerabilities that attackers can leverage to gain access to systems where they are not permitted to be and rob their victims of information, while also infecting their devices with malware and potentially drawing them into taking part in a Distributed Denial-of-Service (DDoS) attack as a member of a botnet.

Within the IoT industry, several sub-categories have the potential to cause grave damage should an attacker gain access to those systems. The Industrial Internet of Things (IIoT) category is the field that meets that threshold. The devices that fall into the IIoT category include Industrial Control Systems (ICS) used in sectors such as manufacturing, energy, transportation, logistics, and utilities. In addition to being part of the industrial category, many of these sectors are considered CI. In case of a breach occurring at any of the systems identified as CI, it has the potential to create significant damage, both nationally and internationally. Due to the long lifespan of some of the industrial equipment used today, much of this equipment lacks current-day security, primarily because this type of equipment is now decades old and was produced without the security features currently available to industry.

Both the cost and frequency of security breaches within the industrial sector are increasing rapidly. Verizon (2020) states that one in three breaches involves an IoT

device. The cost for these breaches can be in the millions of dollars; IBM estimates that the average cost of a breach in 2024 was \$5.56 million (IBM, 2025) and adds to the already substantial costs associated with the lost availability of an industrial facility experiencing unplanned downtime, which averaged \$800 thousand per hour across multiple industrial sectors (Siemens, 2024). Specific incidents that will be discussed further, the Colonial Pipeline incident and the Maersk / NotPetya attack cost these organizations between \$4.4 – \$5 million and \$250-\$300 million respectively (Greenberg, 2018).

Due to their various architectures and differing features, it may be impossible to develop a single set of cybersecurity controls that would be effective in protecting all IoT devices. Most IoT devices typically have little-to-no processing capabilities, which makes it difficult for the manufacturer to decide whether to bake-in security features or to exclude them altogether. Much like IT systems that exist on a network (workstations, printers, servers), IoT systems are also vulnerable to network threats and therefore can negatively affect the operation of the network upon the occurrence of malicious activities. Similar to other types of attacks that can occur dynamically against IT systems, IoT devices can also experience dynamic attacks that require continued monitoring and an incident response plan to minimize additional damages.

There are also scalability problems that impact large-scale IoT deployments, which can involve thousands to hundreds of thousands, or even millions of connected devices. The sheer volume of devices makes manual security monitoring impractical, necessitating an automated, Artificial Intelligence (AI)-driven security solution.

IIoT devices may be more vulnerable to cyberattacks than other sectors of the IoT field due to a number of items, such as proprietary communication protocols, the lack of security controls in most devices, and, most commonly, extremely outdated software. If a device is considered part of a country's CI sector, any downtime due to a security incident could lead to power outages, water shortages, or other issues, causing major problems for the government or companies responsible for securing and operating them.

One of the most common communication protocols that IIoT devices rely on is the Modbus protocol. Introduced in the late 1970s, Modbus was developed as a way for CI Operational Technology (OT) to communicate quickly. When it was first created, there were no safeguards implemented to protect it from malicious activity or prevent it from being vulnerable to cyberattacks. This was not a result of businesses not being concerned about security, more to the point that nobody was aware of cyberattacks. There is no encryption built into the protocol itself, which is used by a wide variety of CI systems in one way or another.

As CI systems and IoT devices have advanced, security has advanced with them in some manner. New security controls have been developed for these systems; however, the Modbus protocol has failed to advance with these new controls. In a typical system using Modbus, the entire system is air-gapped, meaning it is not connected to any outside systems, so traditional monitoring was not implemented. The Modbus protocol itself is difficult to monitor. Due to the air-gapped nature of most ICSs, security systems do not track this protocol. They cannot monitor the communications of these devices and are typically focused on other communication protocols inherent to regular IT and cyber systems.

## 1.2 Research Motivation

When attempting to choose a topic to write about, it was clear that IoT and IIoT devices were clearly an issue that had led to multiple incidents over the last few years across both enterprise and CI systems. IoT devices have been commercially available for almost two decades, and security was frequently disregarded or underestimated when they were originally introduced. In the past, many manufacturers of early IoT devices were mainly interested in ensuring that their devices were functional and inexpensive, and they would only incorporate security before there was a major public event that showed that the devices needed it. The technology has improved greatly since its inception, and, since then, the security of devices has not kept pace with their technological improvements, with many devices being vulnerable to the use of bad authentication, unsecured communications protocols and minimal accommodation for being patched.

Surveys have consistently reported that IoT security is regarded as poor compared to other types of devices, and in one case, fewer than 10% of participants in a large-scale industry study rated IoT devices as “very secure” (IoT Inspector, 2021, p. 2). The lack of security implementation on these devices is partly due to the way the devices were manufactured from the beginning with a lack of security controls, and this has continued in modern devices. This problem is highlighted in IIoT environments, which includes devices such as Programmable Logic Controllers (PLCs), sensors and gateways, which are usually resource-constrained and lack the processing power to support advanced security controls (Alwaisi, et al., 2024). It was surprising to see this still being an issue all these years later because recent trends have shown that as technology advances, security

controls often grow in the same manner or catch up to make up for the lack of security in the beginning. Not having security controls in place for these devices creates a problem as the security for the device itself falls on the organization that utilizes the device in operations rather than the device's manufacturer.

This lack of security is particularly important when it involves critical infrastructure. A successful cyberattack of critical infrastructure could lead to economic, environmental and health/safety concerns. Use of legacy protocols such as Modbus, increases the risk because of lack of security in encryption, authentication and integrity checks, making them very vulnerable to replay, injection and MITM attacks (Wang et al., 2023). Recent studies emphasize the need for network defense mechanisms that could supplement or replace the limited protections at the device level. Devices such as Machine Learning (ML) based intrusion detection systems and risk assessment models have been able to detect abnormal conditions in IIoT traffic and provide real-time understandable reports of cybersecurity risk (Ayodele, 2024). The purpose of this praxis is to explore ways to enhance device security while integrating future cybersecurity devices in order to address the vulnerabilities of legacy protocols by illustrating through use of an example of how the application of ML to Modbus telemetry data can enhance resilience against cyber threats as it applies to mixed IT and OT environments.

The proposed AI-driven IIoT risk quantification model distinguishes itself from existing commercial and research-based Intrusion Detection Systems (IDS) through its integration of real-time probabilistic risk scoring and behavior-based anomaly detection tailored specifically for Modbus telemetry. Current industrial cybersecurity solutions such as Claroty, Nozomi Networks, and Dragos primarily focus on network-based

intrusion detection using signature matching, rule-based thresholds, or pre-trained behavior baselines (Claroty, 2024; Nozomi Networks, 2024). Although these tools have been effective in detecting threats, they generally do not include adaptive learning capabilities to continually learn about new attack methods and/or specific behaviors of devices within changing contexts. As opposed to those tools, the model described in this paper includes a supervised machine learning technique, namely, a Random Forest (RF) Classifier to produce a dynamic, continuous Risk Score between 0 and 100 indicating the degree of probable threat for each device and thus allow security personnel to make informed decisions relative to how to best utilize limited resources and to alleviate alert fatigue.

Furthermore, most IDS based on ML in literature only use static datasets or small, targeted lists of attack types limiting their applicability to IIoT systems operating in a real-world environment (Alwaisi et al., 2024; Peng et al., 2024). This study builds upon prior studies and advances in the field by using a combination of device telemetry and network behavior data to capture a broader and more accurate views of all industrial activities being conducted on the system. Also, unlike prior studies that focus on achieving high detection accuracy, this paper introduces an additional layer of explanation, e.g., explainable risk quantification, where anomaly intensity is linked to operational risk exposure, consistent with established standards and guidelines for IIoT security (NIST SP 800-82; ISA/IEC 62443), and represents a significant contribution to bridge the gap between predictive analytics and operational risk management in IIoT security through its ability to provide real-time and interpretable results.



### 1.3 Problem Statement

*Existing IIoT security solutions lack the capability to dynamically assess, quantify, and respond to evolving cyber threats in real time. Traditional security approaches rely on static rules, signature-based detection, or periodic vulnerability scanning, which are ineffective against zero-day attacks and novel threats. Furthermore, the high volume and variety of IIoT devices make manual threat assessment resource-intensive and inefficient.*

IIoT device security is a problem for security professionals and will continue to be an issue if traditional security methods are used to protect these devices, which require near-constant uptime due to their critical nature. Having a framework that can dynamically assess and identify malicious activity will allow personnel to act quickly before the problem spreads across the network. Frameworks similar to this exist for traditional IT systems, however, there is not one available for IoT or IIoT systems.

This praxis seeks to create a basic framework that can be used to proactively detect cyberattacks in critical IIoT systems. The methodology will include training the model in aspects of the TON\_IoT dataset, specifically the Modbus telemetry dataset and validate its performance through Precision, Accuracy, F1 and Recall. The attacks in the dataset include Backdoor attacks, DDoS attacks, Denial-of-Service (DoS) attacks, Injection attacks, Man-in-the-Middle (MITM), Password attacks, Scanning (Reconnaissance) attacks, Ransomware, and Cross Site Scripting (XSS) attacks.

### 1.4 Thesis Statement

*As Industrial IoT (IIoT) systems become more interconnected and critical to operational infrastructure, traditional cybersecurity approaches that rely on static rules*

*and delayed threat detection are no longer sufficient. This research proposes an AI-driven risk quantification framework that uses machine learning to dynamically assess security posture, identify anomalous device behavior, and assign continuous risk scores to IIoT assets. The goal is to enable proactive threat mitigation and strengthen operational resilience across industrial environments.*

The framework will provide training on a supervised model to continually monitor systems for security breaches as well as reduce false positives; enhance the accuracy of detecting threats; and provide automated response to identified threats. The proposed study will define the model architecture; determine the risk factors; and implement the model on a real-world simulation with the TON\_IoT dataset to develop a practical, scalable, and efficient solution to improve cybersecurity in increasingly complex IoT systems.

## **1.5 Research Objectives**

The goal of this research project is to illustrate how AI and ML can be used to quantitatively assess risk; detect more threats; and improve cyber defense in industrial networks that utilize insecure communication protocols such as Modbus. To achieve this end, this research will be centered around three research objectives:

**RO1:** Develop and evaluate the effectiveness of AI-based risk quantification models for IIoT security.

**RO2:** Design and implement a real-time IIoT risk quantification framework for threat detection

**RO3:** Investigate the impact of automated risk-based security responses on IIoT cyber defense.

## **1.6 Research Questions and Hypotheses**

In this praxis study, investigations were performed on the application of ML models to detect and classify the various types of cyberattacks aimed at IIoT devices and systems. It focuses on the Modbus protocol which is used in a large amount of IIoT systems, including those critical in nature. This praxis showcases the following research questions and hypotheses to assess whether the ML model that was created and specific dataset used in training will be appropriate for the basis of the risk assessment framework. In the hypotheses, the term traditional rule-based security means static IDS and firewall rules (Sommer & Paxson, 2010; Knowles et al., 2015; Boyes et al., 2018). Manual security monitoring is manually configured settings and the requirement of a human analyst to observe alerts and act against threats (Siddiqui et al., 2023; Stouffer et al., 2023).

### **Research Questions (RQ):**

- RQ1:** How effective are supervised machine learning models in detecting IIoT security threats based on network behavior and device telemetry?
- RQ2:** Can a real-time IIoT risk quantification model effectively classify and mitigate cyber threats before they escalate?
- RQ3:** What are the most predictive risk factors for IIoT security, and how do they influence dynamic risk scoring?

### **Hypotheses (H):**

- H1:** Machine learning-based IIoT risk quantification models achieve at least 10% higher threat detection accuracy than traditional rule-based security approaches. In an industry where downtime costs hundreds of thousands to

millions of dollars, a 10% improvement would decrease downtime during an attack, save the affected organization money, and lower the burden on the analyst.

**H2:** An AI-driven real-time risk scoring model reduces incident response time by at least 50%, measured as Mean Time to Resolve (MTTR), compared to manual security monitoring. MTTR varies by organization; industrial standards suggest 1-2 hours would be an acceptable timeframe (Baecker, 2025), which this research uses as the MTTR for manual security monitoring).

**H3:** Incorporating network behavior and device telemetry into risk assessment will improve risk classification performance compared to network-only approaches by at least 3%. With the number of devices that are deployed across some of these organizations, a 3% increase would reduce the number of false alarms in a production environment by thousands of corrected outcomes per month, resulting in more efficient usage of time by the analysts.

## **1.7 Scope of Research**

Since IoT is such a broad topic covering many different devices, it is necessary to narrow down the framework, focusing specifically on IIoT and, more precisely, the Modbus protocol. The reason for choosing the Modbus protocol is that it is the most widely used industrial control communication protocol (Iyalunaidu, 2024). Building the model on Modbus will facilitate adaptation to other protocols in the future. The research uses the TON\_IoT dataset to train an RF ML model. The dataset was selected because it

includes various attack types that simulate real-world attacks on OT networks. This praxis aims to define the basis of a real-time IIoT Risk Quantification model for security practitioners. The research assesses the efficacy of the ML model using traditional ML performance metrics, such as Precision, F1, Accuracy, Score, and Recall, on the TON\_IoT Modbus datasets.

## **1.8 Research Limitations**

This praxis intends to develop and assess an ML model that can serve as a good basis for a Real-Time risk quantification framework for threat detection in IIoT environments. However, some limitations must be addressed. The research is based on the TON\_IoT Modbus dataset, which is representative of IIoT traffic but is a generated test-bed dataset, rather than data from a live industrial environment. The attack scenarios are different from one another, and involve several attack types, but are pre-defined. Hence, they may not capture all behaviors of attackers which occur in the real-world environment of networks. The data labelling relies on time-stamping alignment with ground truth annotations and so an inoperative time-stamp correction and alignment could have affected the accuracy of attack labels. The research study concentrates on Modbus only, which is the prominent legacy protocol. The research does not study other IIoT and ICS protocols such as DNP3, OPC-UA, and IEC 61850. This might limit the generalizability of the results across different industrial control environments.

RF was chosen as the supervised learning method because of its robustness and interpretability. Although the evaluation was successful, there were no evaluations made against other learning methods that might be able to capture more complex problems.

Unsupervised anomaly detection techniques were also not fully explored, which could have provided additional insights for attack detection.

The Real-Time Risk Quantification framework was simulated in a research environment on Google Colab rather than being deployed into a live IIoT network with active devices. Because of this, practical considerations such as scalability, deployment costs, and integration with industrial hardware were not validated. The study of automated, risk-based responses is conceptual and simulation-based, instead of being implemented in an operational IIoT environment, which means it did not measure the potential side effects of that response, such as interrupting legitimate processes or creating operational downtime.

## **1.9 Organization of Praxis**

Organization of the praxis is set up in five different chapters exploring the usage of the ML model in an OT network.

Chapter 1 provided an introduction and background to the IoT field, aiming to clarify the research topic, motivation, problem and thesis statements, research objectives, questions and hypotheses.

Chapter 2 provides a literature review discussing the background of the greater IT/OT infrastructure in ICS, to include an overview of the Modbus protocol, an introduction to the IIoT industry, and current security controls for IIoT devices. It also discusses common vulnerabilities, the risk assessment frameworks that aim to address these issues and ML in IIoT cybersecurity. There is also a look into the comparative studies of Rule-Based vs AI-Driven Detection and other ML and anomaly detection studies and current research gaps.

Chapter 3 covers the methodology of the praxis, which will discuss dataset selection, the processes undertaken to prepare, design, and implement it for the ML Risk Quantification Framework, and evaluate its performance in detecting and mitigating IIoT security threats.

Chapter 4 will examine the findings by presenting the outcomes of the ML experiments, including model performance and metrics, risk score analysis and statistical evaluations that demonstrate the effectiveness of the proposed framework.

Chapter 5 will summarize the research performed in this praxis to summarize the significant findings and highlight the contributions of this research to the field, and conclude with the significance of these findings, and potential future work that will further develop the efforts of this praxis in future research projects.

## Chapter 2: Literature Review

### 2.1 Introduction

The IIoT is an area of IoT that oftentimes does not receive as much attention as the other subcategories of IoT. Despite this, it has existed for many years and includes numerous types of interconnected systems across a variety of industrial sectors such as manufacturing, energy, transportation, logistics, and utilities. These devices consist of connected sensors, machines, and control systems that are built on traditional ICS by adding network connectivity. This makes it possible for the systems to execute predictive maintenance that uses real-time process monitoring to efficiently allocate resources. With the interconnectivity of these devices becoming more prevalent, it has increased their attack surface, making IIoT systems a prime target for cyber attackers. (Bhaiyat & Sithungu, 2022).

When ICSs were first introduced, internet connectivity was less developed than it is now, and so it was not capable of providing interconnectivity in the same way these systems operate currently. These systems were monitored in person by the operator, and the systems communicated via proprietary communication protocols, which were often isolated from other systems, very different from the way IT systems are currently configured (Cheminod, et al., 2012). As technology advanced, IT systems and these OT systems started to become more commonly connected, which led to less system isolation. Because of the new interconnectivity, systems that were once protected solely because of their lack of outward connection are now being exposed to the same attack vectors that traditional IT networks see regularly. In 2010, the ICS community experienced its first major disruption through the well-documented Stuxnet attack (Karnouskos, 2011). The



Stuxnet attack demonstrated the impact of maliciously designed targeted malware on industrial operations when a third party gained access to control systems. To this day, the Stuxnet attack remains the IIoT D-Day for many global cybersecurity professionals, as it brought home the reality of IIoT system vulnerabilities to many for the first time. Since 2010, the sophistication of IIoT system attacks has increased as these systems have been identified by criminals as prime targets for ransomware, insider sabotage, botnets and supply chain compromises.

According to Calderón et al. (2024), the architecture of IIoT systems combined with legacy equipment interoperability creates a very complicated issue regarding the management of IIoT system cybersecurity and represents one of the greatest challenges in providing adequate IIoT system protection from cyber threats. As stated by Pal & Jadidi (2021), IIoT systems rarely include any type of embedded security feature, making these systems attractive to cyber attackers once they determine the identity of the systems. A recent study by KnowBe4 reported in 2024, indicated that cyberattacks on CI directly targeting OT environments have increased 30% since 2022, further emphasizing the need for improved defensive capabilities (KnowBe4, 2024).

Like all aspects of the IoT market, IIoT is anticipated to grow rapidly in every sector by 2030, based upon the estimates of Pereira and Romero (2017). With the increasing numbers of devices, the potential attack surface will continue to increase, and thus with the rapid growth of IIoT devices, there will be an equal expectation for reliable, resilient and secure deployments.

## The Internet of Things (IoT) Market 2019-2030

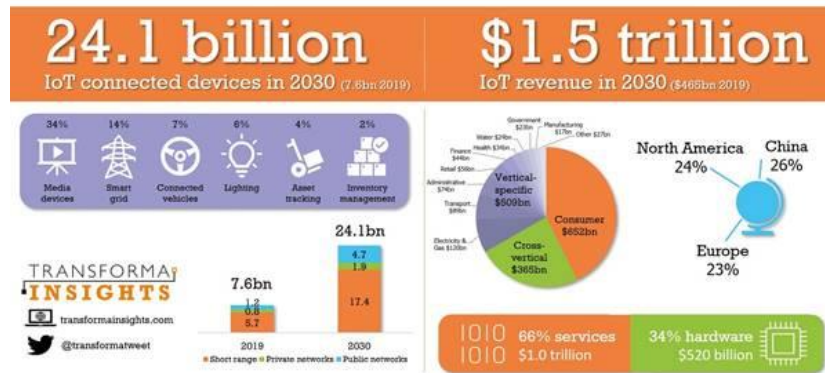


Figure 1: IoT Market 2019-2030  
(Source: Transforma Insights, 2020)

Government regulatory agencies in both the U.S. and Europe have also acknowledged the need for standardized security measures for these systems. In the U.S., NIST has established two documents under its Cybersecurity Framework: NIST SP 800-82 (Guide to OT Security) and NIST IR 8228 (Considerations for Managing Internet of Things (IoT) Cybersecurity and Privacy Risk); and the European Union has produced the ENISA Guidelines for Securing the Internet of Things. Both of these documents provide guidance for protecting industrial environments but typically represent baseline/reactive approaches to security and therefore are generally ineffective as a proactive defense mechanism. Moreover, the EU's NIS2 Directive and the U.S. CISA are actively working to raise awareness of IIoT system threat visibility and the reporting requirements, especially within the CI sectors (CISA, 2021). Even though regulations are developed to address security risks, ensuring compliance can be difficult to achieve, and even for those that comply, compliance does not necessarily translate into real-time risk mitigation due to the fact that cybercrime actors typically adjust their tactics more rapidly than regulations permit.

## **2.2 IT/OT Overview and Relationship**

IT and OT have traditionally been two separate disciplines with increasing overlap in today's manufacturing environments. Typically, IT refers to the use of computing devices, networks, and storage systems to gather and manage information to support business operations including enterprise resource planning, customer relationship management, and threat/vulnerability management (Humayed et al., 2017). On the other hand, OT is the hardware and software, both physical and logical, that enables the monitoring and control of physical processes, equipment, and industrial facilities using programmable logic controllers (PLC's), supervisory control and data acquisition (SCADA) systems, and distributed control systems (DCS) (Stouffer, et al. 2023).

Traditionally the purpose and design of IT and OT systems have been different. The applications generally used within IT systems particularly deal with the processing of information and the profitability of the business, where the main area of concern for OT systems has been the reliability, availability, and safety of industrial processes. Historically, the OT network was isolated and independent of the IT network in order to mitigate threats from outside of the organization. However, with the growing awareness of the Industrial Internet of Things (IIoT) and Industry 4.0, this area has become much more interdependent. As a result of IIoT and Industry 4.0, many of the industrial organizations are seeking to utilize OT data within IT to understand the predictive maintenance of the equipment, to enhance performance metrics of the process, and to provide business intelligence (Macaulay & Singer, 2013). While this has promoted advancement, it has also broadened the attack vector which is allowed, since an exploit in an IT system could now also be used as an entrance into OT critical infrastructure.

As a result, IT/OT convergence is now one of the largest topics being studied in the area of industrial control cybersecurity literature. The IT and OT systems have been distinguished not only by their functionality, but even their individual security priorities. Scholars (Ashibani & Mahmoud, 2017; Humayed et al., 2017) have observed that the focus of IT security is on confidentiality, integrity, and availability (CIA), while in contrast OT security emphasizes safety, availability, and reliability more (Stouffer et al., 2023). The difficulty in reconciling these two sets of objectives will be that the organization will have to make deliberate changes and commit certain quantities of resources to such changes. Security control methodologies acceptable to IT, such as patch management and uptime methods, might not be acceptable business in OT systems, which, by definition, cannot afford such downtime. Recent research has sought to arrive at methodologies that identify methods of aligning IT security practices and techniques to those of OT security. Effectively the focus has shifted to the area of implementing risk-based online monitoring and IDS for the most common industrial assets found in OT systems. Thus, the purpose of the research is to be able to demonstrate that the requirements of OT systems and their operational objectives are being met while satisfying the requirements for behavior and method of operation as found in IT systems.

These reconciliations offer several advantages. Some such as a real time visibility of industrial production levels which may ultimately lead to knowledge-based decision-making. However, this area also raises considerable security problems. The separation between IT and OT was an air-gapped architecture by design which meant security was overlooked because of the lack of external connectivity. Merely connecting previously air-gapped OT environments to IT networks and cloud infrastructures greatly enlarges the

area of attack. (Humayed et al., 2017) Compromised IT systems can serve as a pivot point for adversarial forces when they attack OT systems where the potential exists for physical damage to equipment, a process disruption or a safety issue.

In addition, there are several high profile cyberattacks that demonstrate some of the risks presented by IT/OT convergence. One of the best known of these incidences was the Stuxnet attack in 2010 which compromised Siemens PLC OT devices in order to damage centrifuges in Iran's nuclear program (Karnouskos, 2011). More recently, there has been a multitude of ransomware attacks including WannaCry and NotPetya, which compromised IT systems, and subsequently infected water and industrial systems resulting in massive damage (Ashibani & Mahmoud, 2017). These incidences demonstrate that OT systems, originally designed with reliability as the principal consideration and not security in mind, are becoming increasingly vulnerable to more sophisticated IT exploits.

Researchers have noted several obstacles to achieving IT/OT convergence. In the first place many OT devices utilize legacy communication protocols such as Modbus not having built in security and safety features that account for identification or encryption (Cheminod et al., 2012). Secondly, OT systems are usually deployed in environments where downtime is highly unacceptable, thus limiting the feasibility of many IT security related activities, such as periodic application of patches or scheduled downtimes, because of the time involved in completion of repairs. Finally, OT devices are deployed in a large quantity of differing environments which limit standardization of security controls. Many of the industrial protocols utilized in OT systems were not originally developed with interoperability or intended security considerations in mind.

As a result of those obstacles, researchers and practitioners have pointed out the need for the development of security methodologies designed considering the unique quality of the OT systems. In particular OT specific IDS and risk assessment systems may provide increased visibility into Modbus communications and anomalies, thus closing the gap between IT security methodologies and OT systems. There is evidence that risk assessment systems utilize machine-learning techniques to analyze Modbus communications, thus providing the capability for better detection of breaches of security in the IT/OT convergence application without delaying proper preparation for conducting activities related to OT matters.

### **2.3 Modbus Protocol**

The Modbus protocol, developed by Modicon in 1979, represents one of the oldest but most widespread communication standards used in both OT and ICS environments. Modbus was created to facilitate the simple, reliable and vendor-independent exchange of data between SCADA systems and PLCs; it is the reason why Modbus has endured for so long. It is open to use by anyone, easy to deploy and works with a vast array of industrial devices and sensors; therefore, Modbus provides the backbone for industrial automation and remote monitoring across the various sectors of energy, water treatment, manufacturing and building management (Iyalunaidu, 2024).

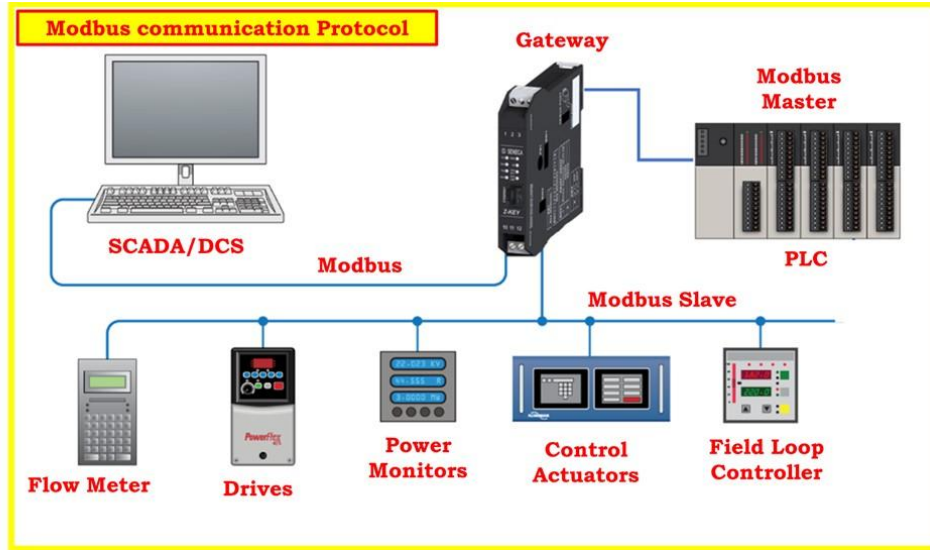


Figure 2: *Modbus Communication Protocol*  
(Source : Iyalunaidu, 2024)

Although Modbus has proven to be a reliable and interoperable method of exchanging data between industrial applications, it was designed with little regard for modern cyber security concerns. It was designed to ensure compatibility and determinism, rather than ensuring the confidentiality of the data exchanged or controlling access to the data. As a result of the increasing convergence of IT and OT networks, the Modbus method of exchanging data, lacking as it does authentication, encryption and the ability to verify the integrity of the data, has now become a significant threat to organizations utilizing this protocol (Cheminod et al., 2012; Karnouskos, 2011).

### 2.3.1 How Modbus Works

Modbus uses a master/slave (client/server) communication architecture. The master, usually a SCADA host, will send queries to one or more slaves (PLCs, sensors or actuators) requesting data or confirmation of an action taken. All transactions follow a defined format based upon the following components: device address, function code, data

payload and a Cyclic Redundancy Check (CRC). Function Codes (FC) describe the action(s) to be taken (e.g., read inputs, write to coils, modify holding registers.)

Modbus defines four basic data models, and each corresponds to a unique address space within a device:

1. Coils – discrete outputs that can be read or written (1-bit each).
2. Discrete Inputs – read-only digital inputs.
3. Input Registers – read-only analog values (16-bit).
4. Holding Registers – read/write analog values (16-bit).

Each of the address spaces are accessed via these standardized function codes:

- FC 1 – Read Coils
- FC 2 – Read Discrete Inputs
- FC 3 – Read Holding Registers
- FC 4 – Read Input Registers

The four core functions outlined above are identical to the ones used in this research (FC1 - FC4), and these represent the fundamental elements of Modbus telemetry in all industrial processes.

### **2.3.2 Security Limitations of Legacy Modbus**

As a result of its simplicity, Modbus is well-suited for deterministic process control. However, Modbus' simplicity is also the root of its vulnerability; since Modbus transmits in plaintext and includes no encryption, any entity located on the same network segment as the Modbus master can send Modbus commands. Modbus also does not include user authentication, thereby enabling any device capable of sending properly formatted frames to be trusted as valid.



This environment enables multiple types of attacks:

- **Command Injection:** Unauthenticated entities can send malicious function calls to alter process parameters or actuator states.
- **Replay Attacks:** Legitimate Modbus packets captured by an adversary can be resent to execute unauthorized actions.
- **Man-in-the-Middle (MITM):** Adversaries can intercept Modbus packets being sent from the SCADA server to the field devices, modify the contents and then send the modified packet to the field device.
- **Denial-of-Service (DoS):** An adversary can flood PLCs or gateways with a large number of fake Modbus requests causing the resources to be exhausted and preventing production.

Modbus also does not provide fine-grained access control. Once an adversary gains access to the network, they generally face no restriction on issuing write commands to coils or registers. Additionally, the absence of built-in integrity verification makes undetectable the potential for data corruption during transmission (Iyalunaidu, 2024; Cheminod et al., 2012).

These weaknesses can be especially hazardous in IT/OT converged environments, where an adversary can move from a compromised IT asset to an OT network. There are documented examples (Stuxnet and BlackEnergy) of how the compromise of industrial protocols, such as Modbus, resulted in physical damage to equipment, degraded performance, and posed a safety hazard to personnel (Karnouskos, 2011).

### **2.3.3 Secure Modbus Variants and Migration Challenges**

Identifying the deficiencies mentioned above, the Modbus Organization introduced two enhanced versions of the Modbus Protocol - Modbus/TLS and Modbus Security. The Modbus/TLS encapsulates the Modbus Application Data inside a Transport Layer Security (TLS) Tunnel, providing confidentiality, integrity and authentication between the endpoints. Modbus Security defines role-based access control and cryptography to authenticate messages (Modbus Organization, 2021).

However, the adoption of these new secure versions of Modbus has been slow and fragmented. Several practical reasons exist for this slow pace of adoption:

1. **Legacy Infrastructure:** Many industrial installations continue to utilize decades-old PLCs and gateways that cannot accommodate the overhead of encrypting the TLS (Sadeghi et al., 2015).
2. **Downtime Aversion:** Changing the firmware or retrofitting devices usually requires stopping production and this carries a high cost for operations.
3. **Interoperability Concerns:** Environments that contain both secure and insecure Modbus nodes create hybrid systems that dilute the overall level of security.
4. **Vendor Lock-In:** Closed proprietary ecosystems associated with devices make migrating to open, secure alternatives difficult from a technical and contractual perspective (Knowles et al., 2015).

Therefore, legacy Modbus is the default choice for many critical industries. Although the secure versions of Modbus could potentially reduce the risk of exploitation, the effectiveness of secure versions of Modbus in reducing risks in real world environments is limited by the inconsistent deployment and incomplete end-to-end

protection. Researchers are increasingly advocating for non-intrusive, protocol-agnostic security layers that do not require changes to the underlying protocol.

#### **2.3.4 Modbus and Machine Learning-Based Risk Quantification**

Since the limitations of traditional static defense mechanisms, there are several recent studies that suggest the use of ML to improve Modbus security. Methods such as supervised classification, clustering and probabilistic modeling can learn from the patterns of telemetry data to detect anomalies indicating command manipulation or network intrusion (Alsaedi et al., 2020). Unlike signature-based methods, anomaly detection does not require knowledge of known attack vectors; instead, the ML algorithms learn the normal operational profile of Modbus traffic and flag abnormalities in real time.

The AI-driven risk quantification model developed in this study extends the concept of simply identifying anomalous events by assigning a continuous risk score (0-100) to each Modbus telemetry event. As a result, operational decisions can be made in near real-time, and analysts can prioritize their incident response based on the risk level of the event. The proposed risk-aware model overcomes the practical limitations of traditional rule-based IDS and presents an evolving, adaptive security model that develops and changes as the dynamics of industrial process evolve.

This proposed solution incorporates domain specific knowledge about Modbus along with statistical learning techniques to present a complementary solution to enhancing secure protocols like Modbus/TLS. In addition, it can run in conjunction with existing Modbus infrastructure. This dual-pronged approach to enhancing detection intelligence without requiring disruptive changes to legacy infrastructures, is

representative of a realistic path forward to protect critical IIoT systems operating in mixed IT/OT.

## **2.4 IIoT System Architecture**

IIoT systems represent the integration of IT and OT to form systems that integrate industrial sensors, PLCs, communication equipment, and cloud-based computing resources to collect data, monitor operations and analyze performance. Although the creation of IIoT systems creates new opportunities for optimizing manufacturing operations through greater efficiencies and productivity, it also introduces new risks and challenges related to the increased complexity and connectivity of cyber-physical systems. Thus, the development of effective security solutions for IIoT systems requires understanding of the various IIoT system architectures currently employed.

### **2.4.1 Core Layers of IIoT Architecture**

There are several different architectures used to develop IIoT systems. Most commonly, IIoT architecture is based upon a hierarchical structure consisting of five levels:

1. Perception (Device) Layer – This is the lowest layer in the hierarchy and contains industrial devices such as sensors, actuators, PLCs, and other industrial automation devices that collect data directly from the physical world (Xu et al., 2014). These devices usually have limited processing power and memory and employ older, less secure communication protocols such as Modbus, making them vulnerable to attack.
2. Network Layer – The primary function of this layer is to manage the flow of data from field devices to higher-level systems using industrial Ethernet, wireless systems

(Wi-Fi, LPWAN, 5G), and industrial communication protocols (Modbus, DNP3, OPC-UA). Since the network layer acts as the interface between OT and IT, the diversity of systems and the use of insecure protocols increase the potential for attacks, including interceptions, injections, and service disruptions (Wang et al., 2023).

3. Edge/Processing Layer – Edge gateways and local process units handle data aggregation, filtering and preprocessing of data before they move on to cloud or enterprise systems. More and more, edge computing is used for real-time examination analysis and intrusion detection strikes near the data source reducing the latency rate and minimizing exposure of sensitive data (Shi et al., 2016).
4. Application Layer – This layer is positioned above the four layers and is used for providing industrial applications such as SCADA systems, predictive maintenance platforms, digital twins, and enterprise support tools. This layer is typically deployed in the cloud environment and incorporates ML and AI-driven analytics to improve industrial processes (Lee et al., 2015).



*Figure 3: IIoT Architecture*  
(Source: Simmons, 2022)

### **2.4.2 IT/OT Convergence in IIoT Architectures**

A key feature of IIoT architectures is the integration of IT and OT environments. Historically, OT networks have focused on reliability, availability and safety and have been isolated or air-gapped from external networks. Conversely, IT networks focus on the analysis of data and security. With the introduction of IIoT, IT and OT environments are being integrated to facilitate the sharing of industrial data with enterprise-wide systems to improve the quality of data analysis and support decision-making (Macaulay & Singer, 2013). Although the integration of the two environments creates new opportunities for collaborative innovation, it also creates new risks for the security of the system since vulnerabilities in IT systems may now be exploited as entry points into OT systems and result in physical disruption.

As a result of the increased risks associated with IIoT architecture, many manufacturers are developing their IIoT systems using a security-by-design approach, which includes techniques such as network segmentation, edge-based intrusion detection and secure gateways. Additionally, given that many IIoT systems still utilize legacy protocols such as Modbus, the need to develop additional monitoring and measurement environments that can provide real time risk indicators to aid in mitigating risk (Cindrić et al., 2025) further supports the use of the security-by-design approach.

### **2.4.3 Security Implications of IIoT Architectures**

Although the IIoT architecture improves operational efficiencies by enabling real-time monitoring and predictive maintenance, it also introduces several vulnerabilities due to its layered design. Specifically:

- Within the perception level, devices have limited resources and therefore do not include built-in security features. Consequently, these devices must be monitored and protected by external systems.
- At the network layer, the transmission of unencrypted industrial data exposes systems to eavesdropping and MITM attacks.
- Misconfigured gateways and poorly secured middleware at the edge layer can serve as entry points for attackers.
- Finally, the application level, especially when located in the cloud, introduces dependency on third-party services and the possibility of disclosing sensitive operational data for potential breaches.

These identified risks indicate the need for AI-driven assessment models to quantify operational and strategic risk within IIoT system architecture to provide real-time visibility and adaptive protective measures. If these types of solutions are integrated into the network and edge layers of communication, they will decrease latency for detection and enhance the resilience of IIoT systems against emerging threat patterns of cyberattacks (Yazdi et al., 2024).

## **2.5 Traditional Security Approaches in IIoT**

Historically, the protection of IIoT environments has depended on rule-based systems such as firewalls, IDS's, anti-virus programs, and static access rules. This is similar to the protection offered in enterprise IT networks. While these security approaches offer protection against known threats, they cannot detect new or behaviorally based anomalies found in the current range of cyberattacks. As Knowles et al. (2015)

indicate, reliance on detection implementations based on signature means that IIoT environments are particularly susceptible to zero-day attacks and lateral movement within previously compromised networks, where attackers use legitimate pathways to avoid detection.

Classic rule-based defenses have their own problems due to their reactive nature. They rely on databases of signatures or patterns from past events, and these defensive mechanisms are reactive to those threats (Sommer & Paxson, 2010). To illustrate, an anti-virus can only indicate that malware is on the host machine when a previous definition exists in the catalog, while an IDS can only detect traffic with a previously cataloged signature. This will create lag time between when the new vulnerabilities are discovered and when they are registered in the system. In IIoT environments, where service to the customer in an orderly manner is critical and non-availability may result in serious threats to safety or financial loss, these delays can be very serious.

Furthermore, the management of the classic methods of defense systems becomes increasingly difficult to accomplish in large-scale IIoT decisions. One industrial site or campus area can have hundreds or thousands of IIoT devices, which can vary from sensors, actuators, PLCs, and gateways. These devices produce varying networks of traffic across multiple protocols and paths of correspondence (Affia et al., 2023). It becomes impossible to manually create, tune, and update security controls to a manageable level. Boyes et al. (2018) demonstrated that organizations employing standards such as ISA/IEC 62443 or the NIST Cybersecurity Framework experienced significant detection delays and lengthened response times due to the rule-based



organization of their security controls. Thus, compliance in itself does not show resilience.

The inflexibility of the threshold detection systems is a separate problem. These detection systems depend to an extent on manual thresholds, such as the number of failed logins, or some threshold traffic volumes which produce alert feedback. Siddiqui et al. (2023) and Sommer and Paxson (2010) reported that these thresholds are hard to tune in dynamic environments. As indicated earlier, over-restrictive thresholds can generate numerous false positives, thereby producing excessive alerts and consequently risking critical oversight. Conversely, overly-lenient criteria can ignore actual dangers. In light of the persistent pressure to make adjustments to the threshold to increase alert sensitivity while also maintain its practicality, it becomes extremely difficult to distinguish between normal/expected fluctuations in traffic volume and unwanted/abnormal changes in industrial networks.

As a result of the above, the ability to minimize the number of false positives produced will become crucial in preventing alert fatigue; analysts may become desensitized to alerts, thereby increasing the probability of missing a genuine attack. Consequently, the negative impacts of excessive false positives are exacerbated by the limited resources available to most industrial security teams, including staff, expertise, and personnel needed to investigate each suspicious event. As reported by Siddiqui et al. (2023) static tools are unable to keep up with the fast pace and volume of current IIoT traffic. Since there are a wide variety of attack methods (e.g. ransomware targeting IT systems, attacks via protocol exploits e.g. Modbus or DNP3), very few individuals or groups have the necessary expertise in many different areas to effectively address them.

Hence, depending solely on manual interpretation introduces a systematic vulnerability (Parsons et al., 2023).

Another major drawback of traditional rule-based systems is their rigidity. As the cyber threat landscape continues to evolve and attackers continue to develop new exploits or change tactics to evade existing defenses, rule-based defenses do not have the capability to autonomously learn or model behavior. For instance, if a rule-based defense mechanism could not recognize a small deviation in communication pattern of a Modbus controller, the same would apply to all other deviations until they had been coded into rules. This leads to a cycle of reactions where defenders are always one step behind the attackers (Sommer & Paxson, 2010).

Due to the limitations of traditional IIoT security methodologies (specifically, the impact of cyberattacks on OT systems) the necessity to expand rule-based methodologies is increasingly apparent. IIoT security systems that use adaptive, intelligent mechanisms (especially those that utilize ML and/or AI), can model normal device and network behavior, recognize anomalies in real-time, and adapt to emerging attack techniques without requiring the administrator to update the rules manually. The goal of these methodologies is to decrease the false positive rate through learning from historical trends, and to improve the detection of zero-day and behavior-based threats that static systems cannot find (Yazdi et al., 2024).

Although traditional rule-based systems such as firewalls, IDS's and anti-virus programs continue to be important elements in the IIoT security arsenal, their limitations demonstrate the inadequacy of using them individually. Their passive, administrative costs, high false-positive rates, reliance on humans and inability to adapt independently

demonstrate their ineffectiveness in the complex and large scale modern IIoT ecosystems. Literature suggests that effective IIoT security methodologies include both traditional and varied methodologies, in combination with adaptive and intelligent methodologies that can handle new threats. This understanding is the premise for research on ML-driven risk models, intended to provide scalable, proactive, contextualized protection in industrial settings.

## **2.6 IIoT Vulnerabilities**

Though IIoT systems rely on the same common security measures such as firewalls, intrusion detection systems, and anti-virus software as most other IT networks, there is no guarantee that an attacker will not find a way to breach or harm an industrial enterprise. Unlike typical IT networks, IIoT systems contain various types of devices, legacy OT systems, and interconnected platforms extending far beyond standard security boundaries. Consequently, IIoT systems are at risk for a variety of vulnerabilities related to legacy infrastructure and the fast-paced integration of new technology. Authorized security professionals identify these security gaps as do attackers seeking to exploit them for financial gain, to carry out acts of sabotage, or to further political agendas (Makrakis et al., 2021).

One of the largest causes of the insecurity of IIoT systems relates to the limited capabilities of legacy OT systems. Most industrial systems have been operational for several decades with a focus on providing reliable and available operations rather than providing adequate cyber-secure protection. Since legacy systems were not originally designed to interface with the internet, they therefore lacked some key security features such as encryption, authentication, and secure boot (Sadeghi et al., 2015; Humayed et al.,

2017). Legacy systems are very susceptible to poor authentication practices, including the use of default, hard-coded, or nonexistent usernames and passwords, which further complicate the problem (Affia et al., 2023). Once an attacker successfully breaches one poorly secured device, they can easily move through the network, and subsequently, target additional devices to expand their level of access to the system. Also, the lack of proper network segmentation allows an attacker, once they have penetrated the perimeter, to attack and destroy each successive layer of system operations.

Another factor contributing to the insecurity of IIoT systems is that in many IIoT deployments, device behavior cannot be observed. While industrial organizations are unable to continually monitor all the communications occurring between devices or monitor changes in device behaviors, it delays the identification of any potential anomalies in the behavior of the devices. Due to misconfigurations (open ports, hard coded passwords, factory default settings) an attacker can take advantage of this condition. This has been illustrated with the Mirai Botnet Attack of 2016 where thousands of IoT devices were attacked and turned into a large-scale DDoS network attacking internet services worldwide (Antonakakis, et al., 2017). Although the Mirai botnet attack was focused primarily on consumer/home IoT devices, similar attacks carried out by an attacker against industrial IoT devices could lead to catastrophic consequences, such as shutting down entire production lines, triggering physical damage to critical equipment via alarm conditions, and/or negatively impacting human safety (Sadeghi et al., 2015). The size and automation of these types of attacks demonstrate how attackers can obtain a massive number of vulnerable IIoT devices in order to launch an attack against an industrial organization.

Software vulnerabilities represent another major threat vector. Manufacturers' firmware or embedded systems operating IIoT devices may provide exploitable vulnerabilities to an attacker. There are numerous Common Vulnerabilities and Exposures listed in the National Vulnerability Database for devices such as PLCs, RTUs, and SCADA systems used in industrial settings (Stouffer et al., 2023). Examples of vulnerabilities include buffer overflow attacks, remote code execution flaws and the use of insecure default services. The problem is made worse because many IIoT systems have long patching cycles and do not support remote patching, which creates delays for operators to install important patches since they are concerned about downtime. Patching typically follows system availability and is therefore frequently delayed for months, if not years, in mission-critical environments like manufacturing, energy, and healthcare, leaving affected systems open to exploitation. Therefore, attackers can exploit known exploits against these unpatched systems (Beerman, et al., 2023).

In addition to the lack of timely patching, the growing complexity of IIoT supply chains increases the number of third-party components, software libraries and firmware being used in products. Manufacturers tend to rely upon third-party code when trying to minimize the time and cost associated with developing their own solutions; however, the dependencies created can mask weaknesses in the code. A well-known example of this is the SolarWinds supply chain attack, in which adversaries were able to compromise tens of thousands of downstream organizations at once through a vendor who was trusted by those organizations (Makrakis et al., 2021). While this was an IT attack, the same type of hazard exists in industrial firmware supply chains. Here, a single compromise in a similarly popular component may affect entire industries (Knowles et al., 2015). As IIoT

devices from various vendors cooperate in the IIoT systems, it is exceedingly difficult to secure third-party dependencies. This need for security indicates a need for software bill of materials, transparency, and continuous verification in IIoT environments (Affia et al., 2023).

In addition to cyber vulnerabilities, physical security concerns remain a major issue for IIoT systems. Unlike data centers and corporate IT systems where IIoT devices are rarely located, IIoT devices are often placed in locations on the factory floor, electric power sub-stations, oil refineries, and remote locations where the lack of physical security means that the devices can be tampered with, stolen, or sabotaged (Ashibani & Mahmoud, 2017). As an example, having physical access to the device may enable reprogramming of a PLC, introduction of destructive firmware, or even recovery of proprietary information that is resident in the device. Further, stresses such as heat, dust, shock, vibration and electromagnetic radiation may lead to failure of the hardware and further create vulnerabilities for the attacker (Chen et al., 2024). Therefore, it is clear from a physical standpoint that the cybersecurity of IIoT implementations must also be tied into the risks of operation and resilience.

These various vulnerabilities, e.g., legacy systems, insecure configurations, software bugs, supply chain defects and physical threats, underline the technical problems associated with the technology for IIoT security. For example, traditional firewalls or signature-based intrusion detection systems are inadequate on their own due to their dependence on passively applicable rules, and do not possess the ability to learn about new or subtle anomalies since they cannot help but passively recall existing rules in the technology. More than that, the attackers are actively re-enforcing their tactics and

taking advantage of technical vulnerabilities, or the weaknesses of individuals and organizations. The weaknesses of traditional security techniques are becoming increasingly clear with the growing complexity of these systems, and continued growth in the future.

This underscored the crucial need for dynamic threat intelligence and monitoring in IIoT situations. For this reason, it is important to the industries concerned to use software that utilizes ML and AI techniques to appropriately analyze the large streams of telemetry data in such a way that the so-called normal activity profiles are established, and then irregularities in such profiles can be detected and responded to immediately, instead of relying on stiff, rule-based systems. This will result in not only less false positives and detection of zero-day attacks but also provide actionable intelligence that can be scored with a risk assessment in real-time, as opposed to receiving a simple alert. The security that addresses both detection and response enables industrial organizations to identify threats much faster and respond to them based on the level of threat severity.

As indicated above, these vulnerabilities in IIoT technology demonstrate that there are technical risks, organizational and physical risks, that need to be recognized and addressed together. Risks of this nature can be mitigated through efforts that incorporate security into the design of IIoT devices and systems, continued monitoring of potential threats, regular patch programs, and flexible facility designs. The way of the future with regard to IIoT security must abandon the traditional voluntary risk management techniques in favor of a more integrative, intelligence process that can deal with the specific needs of the industrial situation, where the effect of a cyber threat may be imminent and serious.

## **2.7 Major Cyber Attacks Targeting IIoT Systems**

As IIoT has grown, it has also attracted increasing numbers of cyberattacks intended to capitalize on industrial system weaknesses. Unlike typical IT based cyberattacks that may compromise business or personal data and/or create financial loss, IIoT cyberattacks have the potential to create physical injury, damage to infrastructure, and to pose safety risks to people. Many well-known attacks demonstrate the severity of this threat and the inability of static rule-based security measures to provide adequate protection.

The first major and impactful cyberattack was Stuxnet in 2010. Stuxnet was a highly sophisticated computer worm created to specifically target the PLCs, made by Siemens, in the Natanz uranium enrichment plant located in Iran. Stuxnet caused the centrifuges being controlled by the Siemens PLCs to malfunction and to spin out-of-control by issuing false operational instructions through the PLCs to the centrifuges while providing false operational data to the plant's operators (Karnouskos, 2011). This was the first example of an adversary causing harm to ICS through malware and is considered the first example of cyber-physical warfare, demonstrating the ability of adversaries to use cyberspace to impact the physical world. Furthermore, this attack marked a milestone in cyber warfare and clearly showed that both IIoT/OT systems could be compromised for geopolitical purposes.



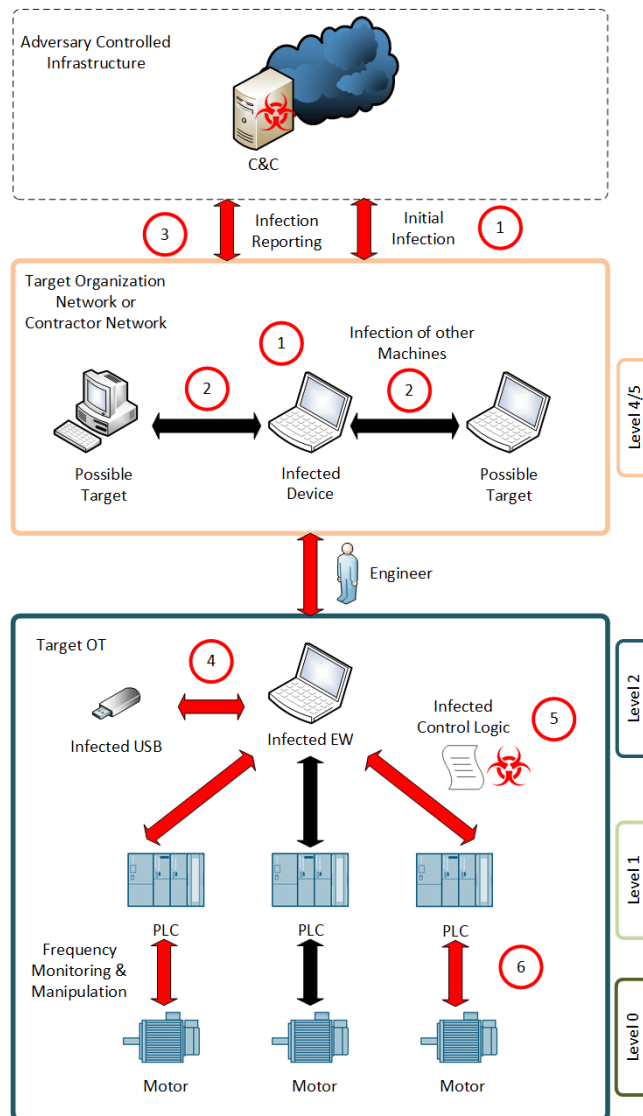


Figure 4: Stuxnet Attack  
(Source: Makrakis et al., 2021)

The second major attack was the 2015-2016 cyberattack on the Ukrainian electrical grid. In this attack, the attackers used malware called BlackEnergy and later Industroyer/CrashOverride to disrupt the electrical grid of Ukraine, resulting in over 200,000 consumers losing power (E-ISAC et al., 2016). This was one of the first documented examples of a large-scale power outage caused by a cyberattack and further highlighted the potential for adversaries to use ICS vulnerabilities to disrupt large portions of society.

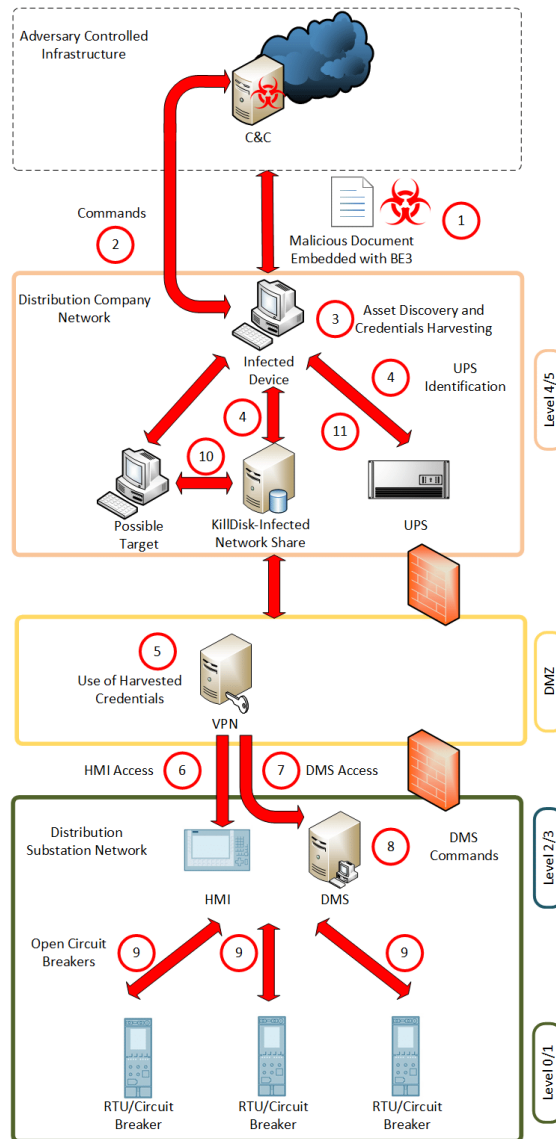


Figure 5: *BlackEnergy Attack*  
(Source: Makrakis et al., 2021)

NotPetya was initially developed as a ransomware attack in 2017; however, it was soon rewritten to be a destructive piece of malware that could easily infect industrial organizations around the world. When shipping company Maersk was infected, it caused a total shutdown of every port in the world for several weeks, resulting from the infection of all of their industrial control systems and the logistical systems associated with them, and ultimately led to losses of over \$300 million (Greenberg, 2018). Although NotPetya

was not specifically designed to target IIoT systems, it is clear from the widespread and non-discriminatory impact of the malware that industrial operations are highly vulnerable to collateral damage from IT-borne threats.

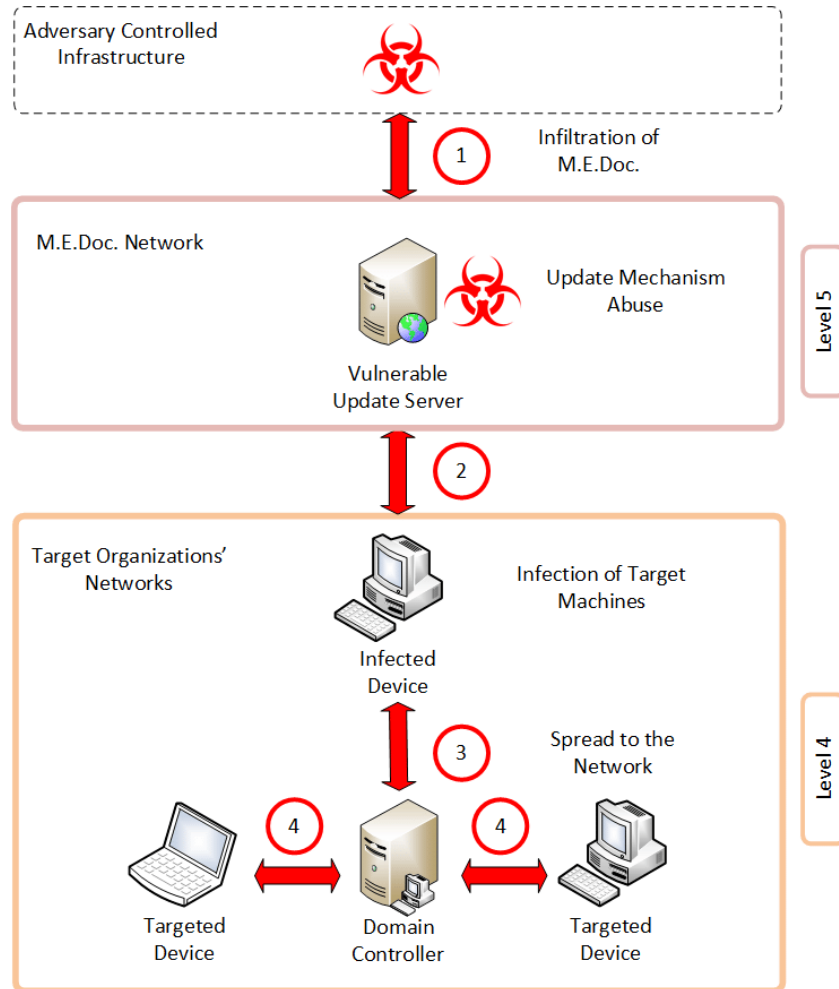
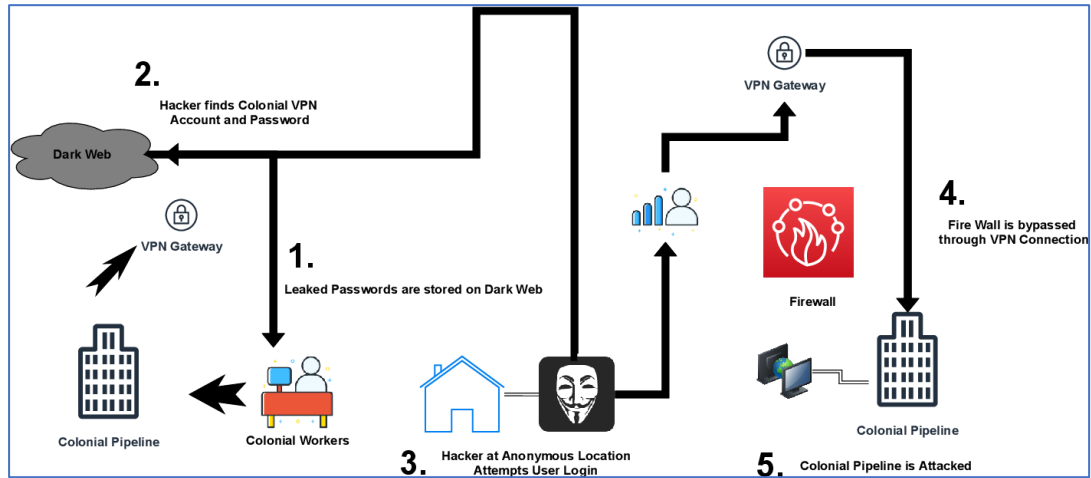


Figure 6: *NotPetya Attack*  
(Source: Makrakis et al., 2021)

Although the recent Colonial Pipeline ransomware attack did not directly affect IIoT systems, it demonstrated how disruptions to operational processes caused by ransomware could lead to significant fuel shortages and cascade-like economic impacts (CISA, 2021). This further emphasizes the interconnectedness between IT and OT

systems, where disrupting one domain may cause unpredictable consequences to the other.



*Figure 7: Colonial Pipeline Attack*  
(Source: Beerman, et al., 2023)

The above mentioned events show a common theme among the IIoT/OT community; these communities are being targeted by an ever-increasing number of potential cyber adversaries including nation-state sponsored hackers as well as cyber criminals. Cyberattacks on IIoT/OT have significant risk associated with them which include but may not be limited to: National Security risks; Public Safety Risks; Decreased Resilience in CI; As well as the fact that adversaries are adaptable, flexible, and will continue to find ways to attack systems faster than the ability of the current traditional rule based security mechanisms to adapt to those threats.

## 2.8 The Need for Adaptive Security in IIoT Environments

As indicated by the increasing number of historical cyberattacks on industrial systems that implement IIoT and the increasing complexity of industrial systems, both illustrate the limited effectiveness of currently used static based traditional defenses. All rule-based defensive mechanisms such as firewalls, IDS's, and signature-based malware

detection techniques will be ineffective until they can be provided with pre-defined attack signatures or manual entry of threshold values, thus limiting them to defend against only previously identified attacks. Adversaries are shown to have utilized zero-day exploits in addition to utilizing legitimate protocols to circumvent static defenses as demonstrated by Sommers & Paxson (2010) in the cases of Stuxnet and the Ukraine grid attack.

Additionally, the dynamic nature of IIoT ecosystems creates an extremely challenging environment for defense as well. Industrial environments are often comprised of thousands of interconnecting devices from numerous vendors that operate using different protocols, firmware revisions and patch levels. As such, the differences between devices create large hurdles to defend each individual device using static configuration. Affia et al. (2023) indicates that most IIoT devices are shipped with weak or default password settings; cannot be easily patched; and use insecure communication protocols that can be exploited by attackers. Moreover, the analysts responsible for securing these systems experience alert fatigue from the overwhelming number of false-positive alarms generated by excessively strict threshold values that make it nearly impossible for analysts to rapidly identify real threats.

Therefore, IIoT security requires adaptive and intelligent-based defense mechanisms that can continually evolve to provide defensive capabilities as the threat landscape evolves. ML and AI enable the system to determine what normal operational behaviors of its devices and network appear to be, to recognize deviations of those behaviors that may suggest unauthorized access, and to update its detection models as new threats emerge. Unlike rule-based systems that only provide simple alerts, adaptive solutions can classify the risk level associated with each activity based on how likely it is

that the activity represents malicious behavior (Yazdi et al., 2024). Therefore, the security team is able to prioritize their efforts by only focusing on the most serious emerging threats and not squandering resources on less severe problems that may detract from actual risks.

Reducing response times is also critical for adaptive security. According to Siddiqui et al. (2023), static defenses cause delayed detection, and subsequently, increased mean time to detect and MTTR. In IIoT environments, where attacks can result in immediate physical harm, the delayed responses may have negative consequences. Continuous, adaptive learning by AI-based models allows them to continually develop a definition of what normal behavior looks like as they provide actionable insight to operators to stop the progression of threats.

In addition to the continuous development of definitions of normalcy and actionable insights for operators, adaptive security frameworks enable organizations to create scalable and automated versions of their security programs. Since IIoT can involve thousands of different types of equipment across numerous sites, it will not be possible to monitor all of this equipment using manual methods. To make effective, high-scale security decisions, automation of security decision-making, including automatic isolation of compromised devices, limiting suspicious traffic, and escalated processing of high-risk anomalies will be required to process the data generated by IIoT devices (Chen et al., 2024). Embedding adaptable components in defense mechanisms will enable organizations to move towards proactive resolution and sustainable operation of their security programs.

There has been a shift from static, rule-based methods of protecting industrial systems to intelligence-based, adaptive methods of protecting industrial systems due to the continued increase in the number of IIoT cyberattacks and the continued vulnerability of industrial systems. Although ML & AI can enhance adaptive security solutions, utilizing either technology for enhanced adaptive security is not an alternative, because the damage caused by IIoT cyberattacks has the potential to be both physical and widespread.

## **2.9 Risk Frameworks for Industrial Control Systems**

The vulnerabilities and high-profile cyber incidents discussed above demonstrate that IIoT systems cannot be defended with only static defenses or by resorting to reactive security measures. Although traditional means of organizations, such as firewalls, intrusion detection systems, and other forms of signature-based control, should never be neglected as part of the industrial security arsenal, they are inadequate for the rapidly changing and dynamic nature of the modern threats. To address this situation, many international organizations have sought to formulate risk-management frameworks for securing control systems. Examples of such frameworks are those derived from NIST SP 800-82 and ISA/IEC 62443 standards, which provide systematic, structured, standards-based approaches to establishing baseline protections, analyzing risk, and layering defenses. Although important, the frameworks previously discussed are static and qualitative in nature. Therefore, they are insufficient to address the rapidly evolving threats to IIoT that require dynamic, data-driven and machine learning-based methods for ICS Cyber Risk Quantification.

The shortcomings of conventional frameworks, like NIST SP 800-82 and ISA/IEC 62443, are demonstrated through their reliance on qualitative risk assessment and the identification of vulnerabilities and application of mitigation strategies. Conventional frameworks provide guidance on fundamental controls and best practices for protecting ICSs (Hoang, 2024) and thus form the basis of modern cybersecurity governance for ICSs, with the inclusion of defense-in-depth, asset classification and prioritized risk management strategies based on the results of threat evaluation.

### **2.9.1 NIST SP 800-82**

NIST SP 800-82 was developed by the U.S. National Institute of Standards and Technology and is widely recognized as one of the most influential guidelines for protecting ICS from cyber threats. A key component of this guideline is that ICS-specific identification of potential threats to, and the associated vulnerabilities and impacts on critical process operations must be completed for each individual system. Stouffer et al. (2023), indicate that NIST provides a framework with recommendations for a risk assessment methodology, which assesses risks across layers. Those layers include the likelihood of occurrence, the impact of the risk and the resulting operational effects.

A fundamental principle of NIST SP 800-82 is defense-in-depth. Defense-in-depth is based on providing layered, redundant security protection in multiple categories of security controls, such as perimeter systems, industrial control systems and the services they provide. The framework requires ongoing monitoring of the configuration of all systems, so that the status of all ICS assets can be understood and appropriate updates to existing security configurations can be made. Response to incidents is



emphasized in the context of planning, with prompt recovery and actions in response to cyber-related incidents.

### **2.9.2 ISA/IEC 62443**

The ISA/IEC 62443 series of publications, established by the International Electrotechnical Commission (IEC), as well as the International Society of Automation (ISA), offers a very comprehensive and specialized framework for the protection of industrial automation and control system components. ISA/IEC 62443 is different from the broader guidelines developed by NIST in that the security levels are based on detailed studies on risk assessment. These levels embody technical and organizational controls of increasing severity which allow the applicability of the organizations security concepts to the risks expected (Cindrić et al., 2025).

It is also important to stress a feature found in all parts of ISA/IEC 62443 that there is a strong emphasis on security by design. In other words, the framework encourages the inclusion of security requirements very early in the life cycle of the product, whether development or design of the system, rather than to be introduced after the system is deployed. This is in line with the latest secure software development life cycles, and DevSecOps, which ensures that all industrial devices and networks are constructed robustly from the outset.

### **2.9.3 Limitations of Static Risk Frameworks**

Both NIST SP 800-82 and ISA/IEC 62443 define several effective security controls, however both documents are static and qualitative in nature. As such, risk assessment typically occurs at the time systems are deployed, and risk is only assessed on

a periodic schedule (Adaros-Boye et al., 2019). In addition to being static, this process also doesn't account for the rapid evolution of threats, including new exploits, new vulnerabilities, and new ways to attack emerging almost daily.

These types of risk assessments rely heavily on manual evaluation by experts using checklists. Expert-based evaluations provide a level of interpretability and compliance but are likely impractical in environments with thousands of IIoT devices and millions of telemetry data points. At some point, humans will simply not be able to examine the telemetry data flowing from these devices. According to Stouffer et al. (2023), far too many organizations have only a snapshot of the risks present and therefore do not understand how their security posture is constantly changing.

A final limitation is in the qualitative nature of the scoring methodology. While grouping risk into categories of low, medium, and high is useful for determining priorities, there is little detail provided for making ongoing operational decisions regarding those risks. For example, operators would benefit greatly if they had quantitative, device-specific risk scores that included information about the version of firmware currently running on each device, the most recent patch applied to the device, the amount of abnormal network activity occurring on the device, etc. Traditional risk frameworks do not support the development of dynamic, real-time assessments of risk. (Baker, 2021).

#### **2.9.4 Toward Dynamic and Adaptive Risk Quantification**

There have been significant calls to include operational telemetry into risk assessment frameworks due to these challenges. Parsons et al. (2023) contend that utilizing performance metrics from devices, firmware versions, patch status, and alert

information related to detected anomalies could enable organizations to continuously assess and adjust their level of risk, moving from a model where risk assessments were conducted periodically and using a checklist type format toward an automated, continually assessed risk model.

Such systems would enable organizations to:

- Detect changes in risk posture as soon as vulnerabilities are discovered.
- Prioritize patching and remediation efforts based on real-time device status.
- Adjust security responses dynamically as threat conditions evolve.

In practice, this would mean that a device running outdated firmware with known vulnerabilities would be assigned a higher dynamic risk score than a fully patched device, regardless of its role in the system. In addition, anomaly-detection systems may contribute to an elevated risk score for a particular device if traffic patterns are determined to be outside of what would normally be expected, thus enabling additional time for security personnel to react (Alsaedi et al., 2020).

#### **2.9.5 Hybrid Frameworks: Combining Qualitative and Quantitative Models**

Several researchers believe that it is possible to develop hybrid frameworks that can merge the interpretability associated with qualitative assessments commonly utilized in conjunction with the scalability and adaptability associated with quantitative ML models. Affia et al. (2023) point out that expert-established rules may form the foundation upon which AI models are built; and thus provide the hybrid framework both the ability to continuously generate data-driven insights, as well as to allow for

adaptations to occur within the operating environment. Two important concerns are addressed via this hybrid approach:

1. Interpretability - the transparency and understandability of the risk decisions made by the operators and auditors will be facilitated via the use of expert-established rules.
2. Adaptability – The ML models will be able to identify and automatically categorize the subtle anomalies that exist and are not visible prior to the event occurring and therefore cannot be identified via traditional rule-based approaches.

The hybrid models also provide an opportunity for bridging the gap between compliance frameworks, which are generally administrative in nature (e.g., NIST SP 800-82, ISA/IEC 62443, etc.), and real-time operational risk assessments. By providing human expertise combined with machine capabilities, industrial organizations can create security postures that meet the global standards of best practice and that are responsive to evolving threats (Cindrić et al., 2025).

Compliance frameworks, including NIST SP 800-82 and ISA/IEC 62443, provide a strong basis for industrial cybersecurity through the establishment of standard practices, promotion of defense-in-depth and requirement of security in all system design considerations. However, the static, checklist type approach used in most compliance frameworks to assess risk is poorly suited to dynamic environments where conditions change, and new risks continually arise that involve various forms of devices. As such, the future direction of compliance frameworks is to incorporate flexible, data-centric risk assessment models that use real-time telemetry and AI. The focus of this new direction will be to transition the emphasis from merely complying with regulations to creating

operationally resilient organizations that can quickly adapt their security practices based on emerging threats.

## **2.10 Machine Learning in IIoT Cybersecurity**

Over the last decade, the amount of reliance on AI-based techniques for anomaly detection and risk assessment within IIoT environments has dramatically increased (Bin Hulayyil et al., 2023). Instead of relying on traditional methods of threat detection using signatures and thresholds, AI techniques are reliant on data and are adaptive. They learn patterns from large volumes of telemetry data and become effective at identifying both known and unknown attack types. ML is especially relevant in the modern industrial environment, displayed by both the ability to cope with high-dimensional data and diverse and dynamic data, since the physical interaction between systems and digital networks presents special problems relevant to both industries.

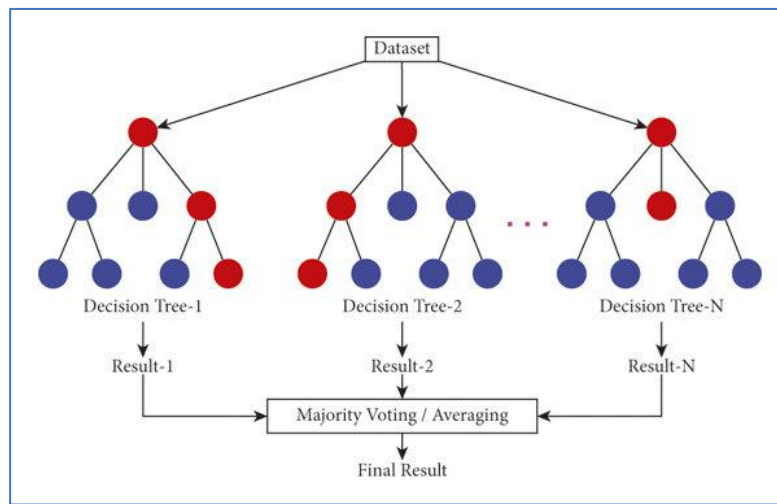
Numerous ML methodologies, each with its distinguishing advantages, restrictions, and applications, are available. In general, methods may be classified as supervised, unsupervised, federated, advanced neural network-based methods, and reinforcement learning. Each contributes differently to the goal of strengthening IIoT cybersecurity and creating robust, adaptable risk assessment systems.

### **2.10.1 Supervised Learning in IIoT Security**

In the realm of IIoT and ML, supervised learning is often used for cybersecurity applications. Using supervised models, classes are produced by training classifiers on datasets that contain labels. The input values (which can include packet size, register values, communication frequency, and so on) are paired with labels that correspond to the

*truth*, namely, normal or attack. While a model is being trained, it achieves success when it can implicitly classify instances of new data and properly categorize them.

Algorithms, such as RFs and Support Vector Machines (SVMs) have been shown to be successful tools for the academic problem of industrial intrusion detection. RFs (ensembles of decision trees) are models that, due to their structure, can handle noise and high-dimensional datasets while minimizing overfitting to identify the truth accurately. For example, Koroniotis et al. (2019), through the use of a RF classifier, trained on the BoT-IoT dataset, were able to identify instances of DDoS attacks, with a classification success of greater than 91%. This illustrates the abilities of supervised models to have the ability to classify patterns of attacks that are repetitive, and well-defined.



*Figure 8: Random Forest Trees*  
(Source: Khan et al., 2021)

On the other hand, SVMs are particularly effective in the binary classification domain and are powerful classifiers when there is no apparent linear way to separate two classes. By affecting hyperplanes in a high-dimensional space, SVMs can clearly distinguish between normal behavior and malicious activity. Paul et al. (2024) made use of the properties of SVMs in a smart grid environment in order to distinguish normal

oscillations in voltage from malicious attacks, such as tampering in substations. This is an excellent illustration of the expository powers of supervised methods in CIs.

The strength of supervised learning is its accuracy in predicting probabilities of known threats and its interpretability concerning various features when they are well understood. However, the dependency on labeled datasets creates a serious drawback because labeled datasets can be either extremely expensive to create, very lengthy to prepare, or often impractical due to operational risks. In addition, supervised models are inferior at identifying zero-day exploits, since the normal scenario under which they are trained will differ greatly from their training data.

### **2.10.2 Unsupervised Learning for Novel Threats**

Unsupervised learning algorithms are especially effective when it comes to IIoT cybersecurity because they do not need labeled datasets. These algorithms learn the current conditions, and deviations can be labeled as possible anomalies. This makes them perfect for situations where little or no information about attack data is available, but behavioral changes can still indicate a malicious attack has occurred.

One of the more recognized unsupervised algorithms is Isolation Forests. The algorithms used here rely on a recursive partitioning in the data set to produce anomalous points, because for anomalous points fewer partitions are required than are needed for the purpose of establishing the normal points. Elnour et al. (2020) in their use of Isolation Forests to monitor PLC traffic in a water purification unit showed that the model is particularly successful in the detection of suspicious anomalies showing its importance in uncoerced detection of malicious activity.

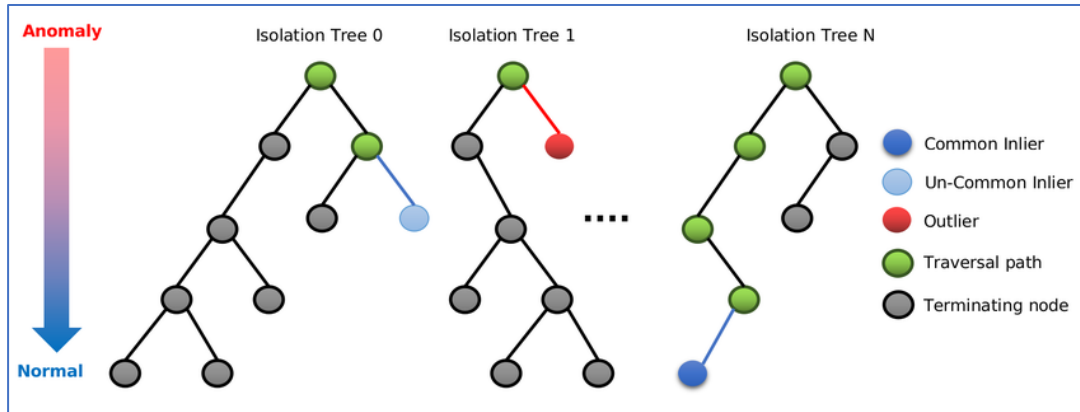


Figure 9: *Isolated Forest Model*  
(Source: Dairi et al., 2022)

Another well-known model is the Autoencoder model. The Autoencoder is a type of neural network that will compress input data down to some lower dimensional representation, that then must be fully reconstructed. In general, if the compression and reconstruction of the data yield a high error rate, it would likely suggest that the input data does not follow the learned normative behavior and therefore may contain an anomaly. Aslam et al. (2024) used Autoencoders on the Secure Water Treatment (SWaT) dataset, which is a real-world dataset that represents the normal operation of a water treatment plant. They reported successful results with the detection of anomalies generated by cyberattacks as well as those generated by unauthorized changes to the system's normal operating parameters.

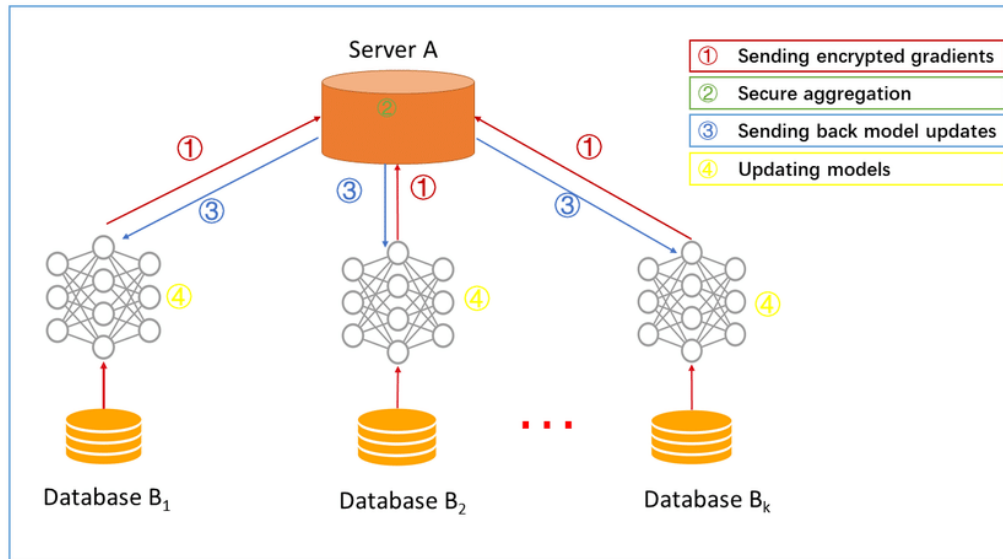
One advantage of unsupervised learning is that it allows you to identify zero-day attacks or unknown types of attacks without having labeled training data. However, these types of models can also produce false positives due to a legitimate operational change can be misinterpreted as an anomaly. For the most part, when the trade-off between accuracy and sensitivity is considered, the use of a supervised or hybrid approach is typically the optimal choice.



### 2.10.3 Federated Learning for Privacy-Preserving Detection

Federated learning, a new area of IIoT security research, allows models to be built and updated across different decentralized systems, devices, or organizations without exchanging raw data over the networks; they exchange only updates to their models. This will prevent leaks of data from one device to another and therefore protect the private nature of the data sets on each device.

Lim et al. (2019) demonstrated the possibility of using federated learning for detecting anomalies in IIoT applications. The results of Lim's study showed that federated models could achieve levels of accuracy in anomaly detection equivalent to those achieved by models developed through centralization of data, with no loss of data sovereignty in these various environments locations. This is particularly useful in many industrial applications where data sensitivity, concern regarding proprietary information, or regulatory requirements are major factors, as they are in industries such as healthcare, energy, or defense.



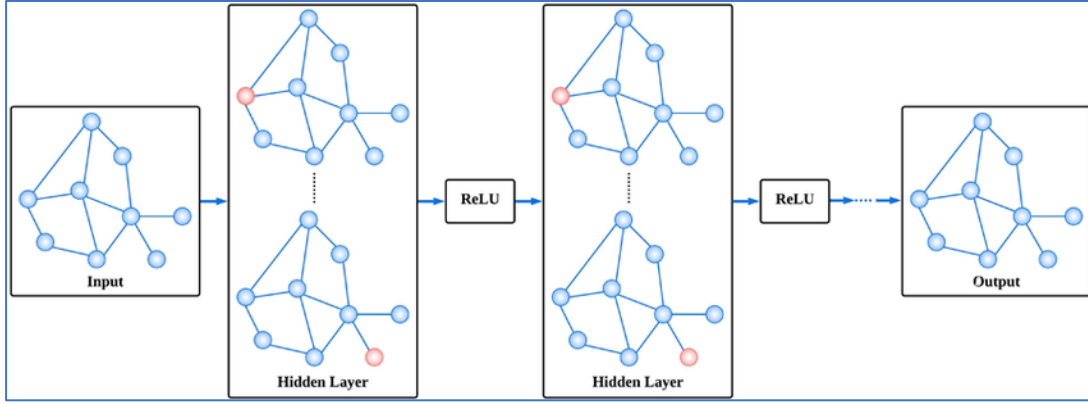
*Figure 10: Federated Learning Model*  
(Source: Yang et al., 2019)

Federated learning also addresses the issue of data divergency present across different sites, in which various facilities may work under different conditions. By training locally, each site becomes a contributor to a global model that adjusts to different environments and thus benefits the robustness of the detection. There are problems, however, like the possibility of model poisoning attacks, which occur when adversaries are willing to corrupt the local training updates intentionally, and the communication overhead due to the frequent model synchronizations.

#### **2.10.4 Graph Neural Networks for Interconnected Systems**

Industrial networks are highly interconnected and related networks of devices, processes and communications that form complex graphs. Traditional ML models that consider the data as independent records usually fail to describe these dependencies. Graph Neural Networks (GNNs) can overcome this flaw through the explicit modelling of nodes (devices) and edges (communication links) and are thereby well suited for the problem of IIoT cybersecurity.

Wu et al. (2020) applied GNNs to industrial contexts, such as modern factories and transport systems, in which they were relevant for modeling the relationships between devices and network levels. The GNNs' knowledge of topological connectivity permits the detection of coordinated attacks that involve many compromised devices. For example, the GNNs could detect irregularities in the flow of data through a substation network or recognize botnets by the strange clustering of traffic patterns.



*Figure 11: Graph Neural Network*  
(Source: Sharma et al., 2024)

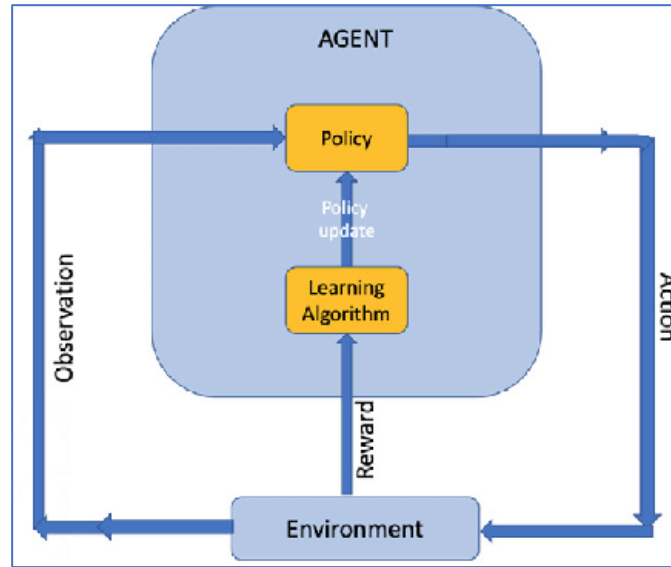
Although GNNs show great promise, they are inherently complex and computationally intensive and will not therefore find immediate use in time-critical non-robotic industrial devices. However, the interesting property of GNNs, namely their ability to capture structural dependences, means that their use is one of the major potential areas of IIoT anomaly detection research.

#### **2.10.5 Reinforcement Learning for Adaptive Defense**

While supervised and unsupervised learning focus on detection, Reinforcement Learning (RL) is concerned with responding to these detections. RL agents learn about the world through selecting actions that yield the maximum cumulative reward. This implies that when discussing cybersecurity, automating defensive responses that learn from previous successes and failures.

In this regard, Srinivasan & Senthilkumar (2025) proposed a blockchain-based hybrid framework integrating RL and rule-based detection for the IIoT. Their model, which utilizes RL agents, adjusts security controls in response to shifts in the threat landscape. In addition to being able to isolate a compromised device or change firewall

settings again, they can utilize blockchain to maintain the integrity and transparency of the agent's decision-making process.



*Figure 12: Reinforcement Learning Model*  
(Source: Kumar & Raubal, 2021)

RL's value lies primarily in its ability to perform well within continually changing competitive environments where attackers' strategies are continually evolving. This adaptation capability is necessary for protecting IIoT from ongoing attacks as well as from zero-day vulnerabilities. Although RL does offer a lot of flexibility for adapting to new threats, there is a large amount of data needed for training with regard to a well-designed reward function that encourages good behavior rather than bad, thus the application of RL safely in an industrial environment (in which down-time/ errors may be extremely costly) continues to be an active area of research.

#### **2.10.6 Critical Evaluation of ML Limitations**

While ML techniques have exhibited strong performance in IIoT based intrusion detection, there are still several drawbacks to the technique. The main weakness of ML based IDS's is the susceptibility to adversarial attacks, where attackers will purposefully

modify input data to trick the model. With respect to ICS, slight variation in telemetry data can easily confuse an ML based IDS into incorrectly classifying malicious behavior as non-malicious (Biggio & Roli, 2018). Traditional signature-based methods inherently validate data integrity through the use of predetermined signatures for attack detection whereas ML models do not validate data integrity as part of the classification process, thus, they are open to being tricked by manipulated inputs or spoofed sensor data that appears statistically valid.

Another developing concern is the potential for data poisoning particularly with continuously learning or adaptive systems. An attacker can intentionally add malicious sample data to the training set during the retraining of the system and the longer it takes to retrain the system the greater the likelihood that the attacker has successfully biased the model toward accepting anomalous behavior as normal. If an attacker can successfully poison the training set, this can have lasting effects on the operation of industrial networks that utilize automated retraining (Jagielski et al., 2018). The potential for these types of attacks highlights the importance of utilizing robust data provenance validation and retraining governance.

The third drawback to ML based IDS's is the phenomenon known as concept drift. Concept drift refers to the gradual changes in the distribution of data over time. Due to the changing nature of industrial environments, workloads, maintenance schedules, and firmware updates that can affect how devices operate, ML models developed to classify abnormal behavior based upon historical data typically degrade over time when presented with new operational states (Lu et al., 2022). To maintain the accuracy and reliability of the anomaly detection capabilities of an ML model, it is necessary to

continually recertify the model. This makes the development of hybrid learning models and/or adaptive learning models that can recertify themselves important for long term effectiveness.

#### **2.10.7 Failed ML Deployments in IIoT**

Even though multiple studies have shown promising results in using ML for IIoT threat detection, the actual deployment of these systems have not always met expectations. Early pilot programs in both power distribution networks and manufacturing environments reported alarmingly high false positive rates, causing alert fatigue and operator distrust of the system (Raman et al., 2021). Some models that were trained in a controlled environment did not perform well in the field when first deployed because the variability of industrial operations was not accurately reflected in the training data (Sommer & Paxson, 2010).

Important lessons from these poor implementations of ML-based IIoT threat detection include the need for feature extraction that is specific to the industrial domain, the need for continual retraining, and the need for human-in-the-loop validation. Some deployments have also indicated that black box neural networks were able to provide higher levels of accuracy in a laboratory setting, however, the same models were rejected by operators due to low levels of interpretability; a major concern for any safety-critical IIoT environment (Fischer et al., 2020). Therefore, Explainable AI and hybrid systems that combine heuristic threshold values with the output of ML algorithms are becoming increasingly popular.

These findings clearly show the trade-off between accuracy and explainability that is inherent in many ML security systems. Deep learning models such as long short-

term memory and convolutional neural networks are capable of capturing complex temporal patterns; however, their lack of transparency creates barriers to trust and regulatory compliance. On the other hand, transparent models such as RF or decision trees sacrifice some of the raw accuracy but are much more compatible with industrial accountability requirements.

#### **2.10.8 Comparative Insights and Hybrid Approaches**

Each ML approach offers unique benefits for IIoT cybersecurity:

- Supervised learning: High accuracy for known threats; limited against novel attacks
- Unsupervised learning: Effective at detecting zero-days; higher false positive risk
- Federated learning: Preserves privacy; vulnerable to model poisoning
- Graph Neural Networks: Capture structural dependencies; computationally intensive
- Reinforcement Learning: Adaptive responses; challenging to train safely

Because of these trade-offs, many researchers advocate for hybrid frameworks that incorporate multiple techniques. For example, use could be made of a supervised RF model to identify previously known attacks, while an Autoencoder would simultaneously identify the emergence of new anomaly patterns. Federated learning can extend these capabilities across distributed locations, while preventing the sharing of raw data; and RL agents provide real-time adaptive responses. These multi-layered ML techniques follow

the principle of defense-in-depth and provide resilience at different levels of detection and response (Ayodele, 2024).

ML has evolved into a significant component of modern IIoT cybersecurity, enabling capabilities far exceeding those of traditional rule-based systems. ML techniques have enabled supervised classification of previously known attacks, unsupervised detection of unknown anomalies, federated learning to enable privacy preservation, and reinforcement learning to enable adaptive responses to evolving threats. As such, ML techniques provide the flexibility, scalability, and intelligence necessary to defend industrial systems in a rapidly evolving threat environment. While there are still many remaining challenges with respect to interpretability, computational costs, and safe deployment; however, hybrid approaches that combine multiple ML methods offer the most promise in creating effective, real-time, proactive defensive capabilities in IIoT ecosystems.

### **2.11 Related Work: Machine Learning and Anomaly Detection for Modbus Security**

An increasing amount of research has been examined using ML and anomaly detection techniques to tackle security issues with Modbus and other industrial protocols. Because Modbus lacks built-in security features, researchers have aimed to create external monitoring systems and IDS capable of recognizing abnormal traffic patterns that signal attacks.

Early methods relied on signature-based detection, which adapted existing IT intrusion detection systems for industrial environments. These methods were effective against known attacks because they used signatures and patterns specific to attack types.



However, because they used deterministic rules, they could not identify zero-day attacks or new attack types (Cheminod et al., 2012). As industrial networks became more diverse and attackers more sophisticated, shifting toward behavioral anomaly detection was a logical next step.

To characterize normal Modbus network traffic and detect anomalies, unsupervised learning techniques such as clustering and statistical profiling have been used. Morris and Gao (2014), for example, used statistical properties of Modbus packet headers to identify replay and command injection attacks with good detection results and minimal computational load. More recently, deep learning methods, like autoencoders and long short-term memory networks, have been employed to address more challenging problems of Modbus network traffic. Various models have performed well in detecting stealthy or slow-developing attacks (Inoue et al., 2017).

Supervised learning methods have also undergone extensive analysis since labeled datasets like TON\_IoT and BoT-IoT have become widely accessible. classification algorithms RFs, SVMs and Gradient Boosting consistently perform well in terms of getting high accuracies in binary classification benchmarks through distinguishing normal from malicious Modbus activity (Sharma & Babbar, 2023). Supervised models are advantageous since they need labeled data of attacks, but require the availability of the ground truth dataset, which is resolved in this practical study by adjusting the timestamps to then map them to the intervals of confirmed attacks.

There have been proposed hybrid methods which combine supervised and unsupervised learning. For example, Kiss et al. (2014) proposed a layered method of attack where anomaly detection was used to detect suspicious traffic, which was then

filtered by supervised classifiers for final decision. This type of method provides a balance between generality of use and accuracy and reduces false positives whilst maintaining sensitivity to unknown attack types.

Despite these advances, challenges still exist in real-time deployment. Many models need extensive preprocessing, long training times, or heavy computational power, which limits their use in resource-limited industrial settings. Additionally, a gap remains between academic evaluation and operational risk assessment, where risk scores must not only identify anomalies but also help prioritize incidents and guide responses.

## **2.12 Comparative Studies: Rule-Based vs AI-Driven Detection**

There are a number of studies that compare AI based threat detection systems versus rule-based approaches to securing IIoT systems. There is general consensus that while rule-based systems are important to provide a baseline level of protection, their effectiveness is being diminished as attackers continue to evolve and use more sophisticated techniques to target industrial networked systems (Pal & Jadidi, 2021).

As early as 2015, Sadeghi et al. pointed out that static defenses are often ineffective at detecting stealthy, low-and-slow type attacks and multi-stage attack chains that are developed over a period of time. Static defenses are limited by their reliance on predefined signatures or fixed threshold values. Therefore, attackers may remain undetected through the distribution of malicious activity over time, blending into normal traffic, or utilizing legitimate commands to perform malicious tasks. These types of subtle anomalies are rarely detected by traditional systems as they are only designed to trigger an alarm when specific, well-known signatures are identified.

Conversely, AI-based solutions have proven to be highly effective at identifying abnormal behavior patterns regardless if the behavior pattern does not match any pre-defined rule. As an example, Peng et al. (2024) demonstrated that ML algorithms, specifically Ensemble Methods such as RF and XGBoost, exceeded signature-based systems in terms of performance when using certain evaluation metrics. Since these methods combine the returns from several models, they are less susceptible to noise and tend to be better at detecting nonlinear data. This typically leads to greater detection accuracy and consequently better detail in classifying detected threats, allowing for different types of attacks to be classified rather than being classified as merely malicious. Perhaps the most important aspect is that since they are adaptive in nature they can be retrained or tuned as new data relating to emerging threats, greatly reducing the window of opportunity for these types of threats.

### **2.12.1 Large-Scale Dataset Evaluations**

The preeminence of methods based on AI has been repeatedly corroborated in large-scale benchmark datasets. Research with benchmarks available in the public domain like UNSW-NB15, NSL-KDD, or more recent examples in a specific application like IIoT like NIMS and TON\_IoT, shows that models based on AI exhibit detection accuracy greater than 95% compared to 60 to 70% for traditional IDSs (Moustafa et al., 2018) regularly confirmed by larger scale learning experiments.

This can clearly be deduced also from field-testing results that remove the laboratory artificialities. Simulated IoT sensor datasets with real traffic traces aim to enhance ML models by making the situations more representative of the realities of IIoT. The importance of the findings is increased because ordinarily, these processes must

manage a variety of devices, old legacy protocols, special processes, etc. The combination of these factors results in a high level of noise and variability introduced into the data. The AI-based models are much better suited to deal with these complex issues than are the traditional and static-driven rule-based systems (Alsaedi et al., 2020).

### **2.12.2 Reduction of False Positives and Analyst Burden**

One well-known critique of traditional systems is their tendency to produce a large number of false positives. Static thresholds, especially in dynamic systems such as the IIoT, generate alerts for innocuous incidents, such as minor variations in the cycles of a machine, or short spikes in the network traffic. This results in a level of alerts that are of poor quality, which eventually leads to alert fatigue, whereby analysts become desensitized to their interpretation of alerts and miss real threats (Sommer & Paxson, 2010).

Systems for detecting anomalies that utilize AI in their analysis substantially alleviate this issue. Because the context of behavior is evaluated, the model is able to identify whether the deviations are within normal bounds or are truly deviations from the norm. The result is increased accuracy and fewer false positives providing better intelligence to the security teams. Improved mechanisms for responding, which are more appropriate to the circumstance, increase mean time to detect and MTTR, which are important in the realms of industrial security. In places where a short-term risk can cause production disruption, with associated safety issues, there are significant improvements that are capable of integration in the daily operations (Yazdi et al., 2024).

### **2.12.3 Deployment Feasibility on Edge Devices**

A typical concern with the deployment of AI-based threat detection in IIoT is that there is still significant computational overhead when it comes to ML. Traditionally, it was believed that in order to get efficient training and inference, the processor power of server or cloud infrastructures would have to be utilized, thus making real-time deployment impractical, in which many IIoT devices are placed at the network edge or borderline.

Recent work has, however, challenged this view. Alwaisi et al. (2024) have shown that even resource-limited edge devices can run lightweight ML models for real-time anomaly detection. Methods such as model compression, pruning, and quantization enable a reduction in both size and complexity of neural networks without significantly detracting from their accuracy. Furthermore, this lightweight model allows for security monitoring at the edge rather than through a centralized collection mechanism, thus reducing the overhead of time for detection through lower reliance on collection through centralized systems. This is of particular benefit in global smart factories, or distributed industrial networks, where local methods of detection will reduce bottlenecks, and support scalability across large deployments.

### **2.12.4 Comparative Analysis of Rule-Based vs. AI Approaches**

To illustrate the differences between Rule-Based and AI approaches:

- Traditional Rule-Based IDS
  - Relies on static signatures and thresholds
  - Effective only against known, well-documented attacks

- High false positive rates in dynamic environments
- Poor adaptability to evolving or stealthy attack methods
- Low computational requirements, but limited intelligence
- AI-Driven Detection Systems
  - Learn patterns from historical and live telemetry
  - Effective against both known and novel attacks
  - Reduced false positives due to contextual understanding
  - Adaptive: retraining allows rapid updates to threat models
  - Scalable across both cloud and edge environments

*Table 1: Rule-Based vs AI-Driven Detection Systems*

| Dimension             | Rule-Based Detection Systems                                              | AI-Driven Detection Systems                                                           |
|-----------------------|---------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| Detection Basis       | Relies on pre-defined signatures, rules, and static thresholds.           | Learns patterns from historical and live telemetry data.                              |
| Effectiveness Against | Known attacks only.                                                       | Known, unknown, and zero-day attacks.                                                 |
| Adaptability          | Static; requires manual updates by administrators or vendors.             | Dynamic; models can be retrained or fine-tuned as new threat data emerges.            |
| Accuracy              | Moderate (60–70% on large-scale datasets such as UNSW-NB15).              | High (90–95%+ on datasets such as UNSW-NB15, ToN_IoT, and SWaT).                      |
| False Positives       | High, due to rigid thresholds and lack of contextual awareness.           | Lower, as models account for contextual and behavioral patterns.                      |
| Scalability           | Limited in large, heterogeneous IIoT environments.                        | Scales across centralized, distributed, and edge deployments.                         |
| Deployment Complexity | Relatively simple to configure but requires frequent manual rule updates. | Requires training, validation, and maintenance of models, but increasingly automated. |

|                              |                                            |                                                                                       |
|------------------------------|--------------------------------------------|---------------------------------------------------------------------------------------|
| <b>Resource Requirements</b> | Low computational demand.                  | Higher, but lightweight models can run on edge devices (Alwaisi et al., 2024).        |
| <b>Response Speed</b>        | Reactive; depends on analyst intervention. | Proactive; supports real-time anomaly detection and automated responses.              |
| <b>Role in Modern IIoT</b>   | Baseline protection and compliance.        | Adaptive, intelligent defense; increasingly replacing or augmenting rule-based tools. |

The comparative framework suggests that while rule-based methods are a good starting point, their leading role should be guided by compliance and filtering. AI methods also serve as a flexible and evolving security layer for the attack surface.

### 2.12.5 Emerging Trends in AI-Enhanced IIoT Security

In addition to RFs and XGBoost, there is an increasing trend to use advanced AI technologies for IIoT defense. For example, deep learning tools such as Convolutional Neural Networks and Recurrent Neural Networks have been successfully used to analyze time series and spatial patterns of IIoT traffic. In addition, hybrid techniques based on the best practices of unsupervised anomaly detection and supervised classifiers yield a good trade-off between adaptability and accuracy (Goh et al., 2017).

Another interesting approach is for federated learning to be employed in industrial networks sufficiently because not only can the models be trained without transferring sensitive information to other sites, but it also addresses the issues of skill and privacy in IIoT data as well as performance (Lim et al., 2019).

Finally, the combination of an AI detection system and an adaptive response system based on reinforcement learning enables a closed-loop response system between detection and defense. This not only guarantees that the systems detect anomalous

behavior but that they automatically contain some attacks and update the relevant security policies in real time. The result of this is a reduction in the MTTR (Siddiqui et al., 2023).

There is a good indication from the reviewed literature that AI-driven frameworks show better detection, response, and risk quantification than traditional rule-driven systems do in IIoT. Benchmark results using datasets such as UNSW-NB15 and TON\_IoT have indicated that AI demonstrates higher detection accuracy, lower false positive rates, and better flexibility in handling newly discovered events in real-world implementations of these AI algorithms on edge devices. While rule-based defenses still offer a basic layer of protection, they are no longer enough on their own. The direction of research and practice points toward AI-enhanced hybrid systems, where traditional methods are augmented or often replaced by adaptive, data-driven models that capture the dynamic and high-stakes nature of industrial cybersecurity.

### **2.13 Datasets Available for Research**

The development of effective ML and risk quantification models for IIoT cybersecurity depends on the availability of high-quality datasets that capture both normal operational behavior and malicious activity in industrial contexts. Unlike traditional IT intrusion datasets, IIoT datasets must represent cyber-physical processes, industrial protocols, and heterogeneous device telemetry. This section reviews the most widely used IIoT datasets, comparing their structure, attack scenarios, and relevance to research in anomaly detection and adaptive security.



### **2.13.1 SWaT (Secure Water Treatment) Dataset**

The SWaT dataset was created from a scaled-down water treatment testbed at the Singapore University of Technology and Design (Goh et al., 2017). It convincingly simulates a fully operational water treatment plant concerning six electrical and physical processes (chemical dosing, water storage, water distribution, etc.). There are datasets containing normal operating data, as well as exhibiting different kinds of cyberattack scenarios (against PLCs and/or sensor inputs).

SWaT is used importantly by researchers because it contains attack-labeled ground truth for supervised learning methods. SWaT has been used extensively in research for anomaly detection itself (RF model, autoencoder model, LSTM type model, etc). The main limitation of SWaT is its excessive domain specificity, as it covers only water treatment processes, and it may not be well-suited for applications in the manufacturing, process, or energy sectors.

### **2.13.2 WADI (Water Distribution) Dataset**

In a complementary dataset to SWaT, the Water Distribution (WADI) dataset was developed from a large-scale water distribution testbed in Singapore (Ahmed et al., 2017). WADI models supply and distribution of water in a city-wide network with pumps, reservoirs and valves. In contrast to SWaT data collection is of much longer periods and there are more complicated attack scenarios than SWaT, some being stealthy attacks which attempt to hide their attack pattern in normal behavior.

WADI has been used to assess anomaly detection systems which detect low-and-slow attacks, where the malevolent actions blend in with normal variances of the network

traffic. Its main problem is the problem of class imbalance, benign traffic occupying most of the dataset, so a careful resampling /preprocessing is required.

### **2.13.3 TON\_IoT Dataset**

The dataset called TON\_IoT (Alsaedi et al., 2020) is among the most complete datasets available for IIoT cybersecurity. In contrast to single-domain datasets, TON\_IoT is multi-modal and consists of several subsets.

- Network Traffic: Captures benign and malicious IoT network flows
- Telemetry: System resource usage from IoT devices (CPU, RAM, I/O)
- System Logs: Linux operating system events. Modbus Subset: Industrial

Modbus/TCP traffic, including backdoor and DoS attacks

The multi-modal nature of TON\_IoT makes it particularly valuable for research into holistic anomaly detection, federated learning, and risk quantification, since it allows researchers to combine network-level data with device telemetry and system logs.

### **2.13.4 BoT-IoT Dataset**

The BoT-IoT dataset was created at UNSW, specifically to test how well IoT/IIoT devices could protect themselves from botnet attacks. The dataset contains a variety of attacks (DDoS, DoS, reconnaissance, info stealing) and simulates these types of attacks on a virtual IoT network.

It is so valuable for use in training AI and Deep Learning models because of the sheer size of the dataset, and because each example has been labeled extensively. The value of BoT-IoT in the IIoT space comes from the fact that it can mimic what would

happen if an IIoT device were compromised by a botnet attack, which is becoming more common in smart manufacturing and other automated industrial processes.

### 2.13.5 N-BaIoT Dataset

The N-BaIoT dataset (Meidan et al., 2018) was generated based on IoT devices that had been infected with Mirai or BASHLITE botnets. These devices produced both normal and malicious traffic, which was monitored and collected. The data collected included telemetry metrics from the individual device level, including traffic flow derived metrics, in order to remove anomalies due to malware.

N-BaIoT, although not directly industrial, is important for IIoT research because many industrial environments contain consumer-grade IoT devices (e.g., cameras, sensors, routers), which can become entry points for attackers to gain access to operational networks. Therefore, N-BaIoT is particularly useful when evaluating device-level anomaly detection AI models.

*Table 2: Comparisons of Major IIoT Datasets*

| <b>Dataset</b> | <b>Domain</b>           | <b>Size / Duration</b>   | <b>Features Captured</b>    | <b>Attack Types</b>                | <b>Notes</b>                         |
|----------------|-------------------------|--------------------------|-----------------------------|------------------------------------|--------------------------------------|
| <b>SWaT</b>    | Water treatment         | 11 days (51 hrs attacks) | Sensor & actuator telemetry | PLC manipulation, sensor spoofing  | Ground-truth labels; domain-specific |
| <b>WADI</b>    | Water distribution      | ~16 days                 | Pump, valve, reservoir data | DoS, stealthy false data injection | Imbalanced; large-scale system       |
| <b>ToN_IoT</b> | Multi-domain (IoT, ICS) | 22M+ records             | Net flows, telemetry, logs  | DoS, backdoors, scans, malware     | Multi-modal; includes Modbus traffic |

| <b>Dataset</b> | <b>Domain</b>           | <b>Size / Duration</b> | <b>Features Captured</b>    | <b>Attack Types</b>     | <b>Notes</b>                          |
|----------------|-------------------------|------------------------|-----------------------------|-------------------------|---------------------------------------|
| <b>BoT-IoT</b> | IoT / Smart Factory     | Billions of flows      | Net flow, packet features   | DDoS, DoS, Recon, Theft | Large-scale; suited for deep learning |
| <b>N-BaIoT</b> | Consumer/Industrial IoT | Device-level telemetry | Traffic-derived statistical | Mirai, BASHLITE botnets | Strong for device anomaly detection   |

### 2.13.6 Summary

In addition to being a foundation of IIoT security research, datasets (such as) SWaT, WADI, TON\_IoT, BoT-IoT, and N-BaIoT each have their own unique features to offer. For example, SWaT and WADI focus on collecting telemetry at the process level; TON\_IoT collects data using multi-modal methods across different protocol types and environments; BoT-IoT is useful for training large-scale, labeled traffic-based deep learning models with the amount of traffic it can provide; and N-BaIoT is used to collect information about how devices are affected by botnets at the individual device level.

As shown by the comparison tables above, there isn't one dataset available that will meet every research requirement. However, using some of the collective knowledge from several of these datasets, researchers are able to create models that are both accurate and applicable to other areas of study. Therefore, as the complexity of IIoT systems continues to grow, so too will the need for multi-modal, real-time, and domain-diverse datasets. This highlights an additional reason for continued collaboration among members of the cybersecurity community to develop new datasets.

## **2.14 Research Gaps and Opportunities**

### **2.14.1 Model Robustness**

There are significant shortcomings in the existing body of research related to the development of robust and adversarial resilient ML models for IIoT environments. While many studies have focused upon increasing the effectiveness of anomaly/detection methods for IIoT systems with regard to identifying anomalous patterns, these studies rarely account for the adversarial behavior of an attacker who manipulates the inputs to the system in order to evade detection. Therefore, the majority of research has failed to consider the threat posed by adversaries who use evasion techniques such as Model Poisoning and Data Tampering. According to Kumar et al. (2020), defensive mechanisms need to be embedded within AI/ML models at the design stage so as to defend against these types of evasion attacks.

Additionally, the adaptability offered by RL is beneficial; however, the ability of RL to operate effectively in real time when operating in an environment that is subject to adversarial attacks has yet to be thoroughly evaluated.

### **2.14.2 Dataset Limitations**

A persistent problem is the unavailability of sufficient amounts of quality labeled datasets that represent the true nature of IIoT systems in operation. The TON\_IoT and BoT-IoT public datasets are important resources that were released recently. However, these datasets have quickly become the de facto standard for a significant portion of IIoT research. Specifically, BoT-IoT is constrained in that it contains no actual data generated from sensor readings. (Alsaedi et al., 2020). As noted by Agbedanu et al. (2025), while several ML models exhibit good results in controlled laboratory experiments, their

generalizability across multiple industrial environments is poor. Furthermore, due to privacy considerations and the fact that much industrial data is proprietary, sharing comprehensive datasets is difficult. Consequently, there is a pressing need for techniques for generating synthetic datasets that can simulate a variety of IIoT environments, as well as frameworks for federated dataset sharing that will protect the confidentiality of the data.

### **2.14.3 Dataset Bias and Generalizability**

The majority of existing IIoT cybersecurity research relies on testbed data sets such as TON\_IoT, BoT-IoT, and SWaT. Although each has value, they suffer from inherent bias and limited generalization across all IIoT applications. For example, the TON\_IoT dataset was developed under a controlled experimental condition that does not necessarily reflect the operational variability of industrial environments (Moustafa et al., 2021). Other limitations include the injection of synthetic attacks into the environment; the limitation in device diversity; and the use of small network topologies. As a result, the ability to train models that will successfully transfer to actual industrial operation is constrained.

Testbed data also have distributional differences. For example, the ratio of attacks to normal traffic is always perfectly balanced; and the cycle of devices is deterministic and occurs much less frequently than it would in actual industrial operation (Ferrag et al., 2020). When a model that has been trained on this type of data is placed in an operational setting, it will likely perform very well in testing but will degrade greatly due to operational noise. Another limitation of training IIoT models is class imbalance. In many

cases there is so much benign data that there is far too little data representing an attack. This class imbalance skews the behavior of the model during the learning phase.

Studies examining cross-validation of IIoT data sets have shown that models trained using data from one IIoT data set (for example, BoT-IoT) can decrease in accuracy by as much as 25% when evaluated against a second data set (for example, TON\_IoT) (Alwaisi et al., 2024). To address this, researchers have proposed two types of learning strategies for IIoT models. Federated learning allows models to be trained across multiple IIoT infrastructures without having to move any of the data to a central location. Transfer learning allows models to be trained across multiple domains by sharing knowledge learned from one domain to improve performance in other domains.

#### **2.14.4 Standards Integration**

Although professional standards for risk management like NIST SP 800-82 and IEC 62443 exist, very few AI-driven models use these frameworks expressly in their risk assessment techniques. Zahran et al. (2021) suggest that the linking of anomaly detection and compliance standards would produce the dual effects of better operational security and audit process. Linking predictive analytics to compliance frameworks is still a complex but necessary area of future research. Sufficient linking requires taking abstract compliance requirements and producing measurable security metrics that AI systems can monitor and react to continuously.

Although the literature demonstrates significant advances in the use of AI to IIoT cybersecurity, fundamental problems remain. These issues must be dealt with by interdisciplinary collaboration, improved dataset transparency and frameworks that relate AI output to industrial standards and adversarial threat models. In spite of considerable

progress, many gaps remain in the literature. Zahran et al. (2021) acknowledges the need for the development of combined frameworks that integrate ML based anomaly detection with standardized risk management techniques. Sinha & Lee (2024) points out problems with model explainability, accessibility of datasets and feasibility of deployment to limited edge environments. Also, most other research concentrates on detection as opposed to full risk assessment including threat intelligence, firmware vulnerabilities and compliance issues.

More extensive research is necessary to evaluate the long-term influences of AI-based risk-scoring on metrics of incident response, such as MTTR and recovery time. Furthermore, studies like Kumar et al. (2020) highlight the importance of including adversarial resilience in AI models to ensure robustness against model poisoning and evasion.

## **2.15 Conclusion**

The reviewed literature highlights the inadequacies of traditional rule-based security in IIoT environments. Consequently, the demand for intelligent and continuous risk management assessments is becoming increasingly significant. In spite of the promising results demonstrated by the various ML methods that were studied, very little research has been conducted to support the integration of ML methods into a robust risk assessment method that meets regulatory requirements. Thus, this research aims to address this gap by developing a ML framework for continuous IIoT risk assessment thereby providing a means for enhancing the ongoing monitoring, operational decision making and incident response capabilities of organizations.



## **Chapter 3: Methodology**

### **3.1 Overview of Methodology**

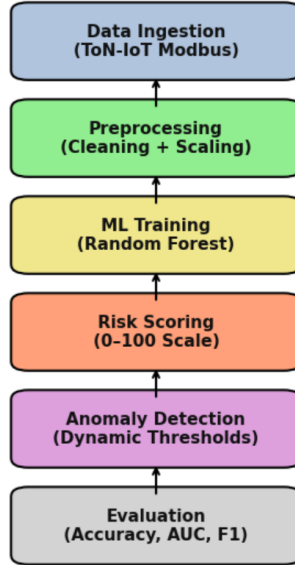
This chapter summarizes the research methodologies applied to examine whether anomalous behavior in Modbus telemetry data can be reliably identified using AI-generated risk scores to demonstrate the anomalous behavior. The methodologies employed by this research study included consistency with existing research studies, reproducibility to ensure reliable results, and application to real-world industrial security practices, which were combined to provide the foundation for the research methodology.

The reason Modbus was chosen as the subject of this research study was because Modbus is the most widely used communication protocol used in both ICS and IIoT communications systems (Humayed et al., 2017). Modbus also lacks the use of encryption and has no form of authentication; therefore, Modbus is one of the primary targets for malicious actors that seek to exploit an operational environment. Malicious actors primarily alter Modbus function codes to either manipulate the state of devices or to create unsafe operating conditions by providing false information. Therefore, analyzing Modbus telemetry data is important when trying to detect malicious activities in a company's network.

The multi-layered methodology for this research study consisted of four layers: Supervised ML, Feature Engineering, Threshold-Based Anomaly Detection, and Statistical Validation. Each layer of the methodology for this research study was designed to operate sequentially: Raw Data Ingestion/Cleaning/Normalization, Training of a RF Classifier, Calculation of Probabilistic Risk Scores, and Validation of Anomalies in Function Code Usage. The sequence of these processes was deliberately established to

achieve a balance between accuracy, interpretability, and operational usability so that the findings from this research would support both academic contributions and practical deployment in industrial applications.

**Methodology Pipeline: IIoT Risk Quantification Framework**



*Figure 13: Methodology Pipeline*

## 3.2 Data Sources and Preprocessing

### 3.2.1 Dataset Description

Data utilized for this project came from TON\_IoT dataset (Alsaedi et al., 2020) developed by the UNSW, and it includes several datasets for various IoT and IIoT devices. Since Modbus was the protocol of interest, in order to build the ML model, all of the datasets with Modbus data were used to train the ML model.

Every one of the records within the dataset was an example of how the device behaved at a point in time, and had four Modbus function codes:

- **FC1\_Read\_Input\_Register**
- **FC2\_Read\_Discrete\_Value**

- **FC3\_Read\_Holding\_Register**
- **FC4\_Read\_Coil**

There were more than 300,000 records across the dataset, which also contained timestamps and labels for each row to show if the observed activity was normal industrial processes or related to some sort of attack, which provided a balanced and realistic profile for experimentation. There was enough data to train the model without the need for generating any additional synthetic data.

The transparency and reproducibility of the dataset, and that the dataset was developed from a well-known and reputable academic source, adds a significant value to the use of the dataset in security related research. The limited availability of private datasets makes comparing studies across different studies difficult.

### **3.2.2 Data Cleaning**

The data quality process maintained high data integrity through a systematic cleaning method. First, the original dataset was imported into Python via the Pandas Library. The initial review indicated that all four columns containing Modbus Telemetry data were numeric and contained complete data without any missing value or null entries.

Next, several extraneous fields (raw timestamp fields and device identifier fields) were eliminated from the dataset to avoid potential data leakage (indirect inference of labels from non-predictive metadata fields) and to reduce noise dilution by limiting the model's focus to solely behavioral telemetry data.

Afterward, labels were converted into binary format using LabelEncoder and assigned 0 for benign records and 1 for malicious records. This ensured compatibility with Scikit-Learn's supervised learning architecture.

Lastly, a MinMaxScaler was applied to the feature set to normalize the feature values in the  $[0, 1]$  range. As Modbus function registers are typically represented as 16-bit values (0 to 65,535), it was necessary to normalize the feature values to avoid high magnitude features dominating the model and to enhance interpretability of feature contributions as well as facilitate model convergence during training.

### **3.3 Machine Learning Model Development**

#### **3.3.1 Model Choice and Justification**

RF was selected because it performs exceptionally well on structured, tabular IIoT data where relationships between Modbus function code variables are nonlinear but not overly complex. In comparison to SVMs, RFs require significantly less feature scaling and hyperparameter optimization. While Neural Networks and XGBoost often achieve slightly better classification accuracy than RFs, they are much more computationally expensive, and generally lack interpretability, which makes them less suitable for real-time applications in industrial environments.

RF provides transparency through feature importance measurements to support explainability, which is a key requirement in OT environments in which human operators rely on model-based decision-making. Furthermore, while Deep Learning Models can learn complex relationships, including those related to time or non-linearity, their *black box* nature limits acceptance in safety-critical systems.

RF's inference stage has very low overhead, with a time complexity of  $O(T \times \log n)$  for each sample (where  $T$  is the number of trees in the RF model). Therefore, it is possible to efficiently deploy RF models on resource-constrained industrial gateways or at the edge in low-power IoT nodes. By contrast, Neural Networks have large memory and latency requirements, which make them unsuitable for use in constrained devices.

### **3.3.2 Data Splitting**

To assess the ability of the model to generalize, the dataset was divided into two subsets, a training set (which consisted of 80 percent of the total data) and a testing set (which consisted of 20 percent of the total data). To prevent the model from developing bias toward the most prevalent type of record in the dataset (e.g., benign or attack), a Stratified Shuffle Split was performed on both the training and testing sets to ensure that the ratio of benign to attack records remained similar.

This stratification ensured that the model had been exposed to many examples of representative behaviors during the training process, thereby providing assurance that the Test Set would be unbiased during the evaluation process.

### **3.3.3 Model Training**

For the RF model, Scikit-Learn's implementation of RF was utilized for the training process with 100 estimators (`n_estimators=100`) and a random seed (`random_state=42`) to facilitate reproducibility of the model. For the initial run, default hyperparameters were used for the model, since prior studies demonstrate that RF will achieve reasonable results without extensive parameter tuning (Breiman, 2001).

During the training process, the RF was fit to the scaled telemetry feature set; thus, the resulting model could generate both class predictions and class probabilities.

### **3.3.4 Hyperparameter Optimization and Performance Tuning**

Hyperparameter tuning was accomplished using RandomizedSearchCV with 40 iterations over the parameters `n_estimators`, `max_depth`, `min_samples_leaf`, `max_features`, and `class_weight`. This approach struck a balance between computational cost and comprehensive coverage of the search space.

Results indicated optimal performance at ~158 trees, `max_depth` = 8, and `min_samples_leaf` = 4. Increasing the maximum depth of the trees in the forest improved Recall but began to plateau in terms of AUC once the maximum depth exceeded ten levels, while increasing the number of trees in the forest resulted in diminishing returns.

The optimized model achieved only a slight improvement in ROC-AUC (~0.975 to ~0.976) while maintaining inference times < 10 ms per sample. Increasing the size of the forest or the maximum depth of the trees caused the training time to grow exponentially, making the chosen configuration optimal for deployment in operational environments.

### **3.3.5 Cross-Validation Methodology**

An additional method of validating the model's generalization ability was employed through the use of a 5-fold stratified cross-validation scheme. Each fold maintained the same ratio of normal to attack records as the original dataset to ensure that the training and validation splits were balanced.

Stratified Shuffle Split from Scikit-Learn was used to preserve the ratio of labels between the training set and the test set (80/20), and to prevent bias due to the class imbalance (~2.4:1 ratio) present in the dataset.

To simulate real-world IIoT operations, a second validation method was applied, in which the model was trained on earlier timestamps and then evaluated on later, unseen intervals. This emulated how well the model would perform under changing operational conditions.

### **3.3.6 Model Evaluation Criteria**

Since the performance metrics used when evaluating a ML model in the context of IIoT cybersecurity must not only evaluate predictive accuracy, but also the issues of unbalanced data, false positives/false negatives, and detection reliability, this study employed multiple complementary metrics to provide a complete assessment of the model's performance. The evaluation metrics included Accuracy, Precision, Recall, F1-Score, and the Area Under the Receiver Operating Characteristic Curve (AUC-ROC). Each of these metrics are defined and their corresponding formulas are listed below.

### **3.3.7 Accuracy**

Accuracy is defined as the number of correct predictions made by the model relative to the total number of samples. While accuracy is a good overall indicator of model performance, it can be deceiving when comparing models trained on datasets where one class is substantially more common than another.

$$\text{Accuracy} = \frac{TP + TN}{TP + TN + FP + FN}$$

*Equation 1: Accuracy*

Where:

- $TP$ = True Positives (attacks correctly identified)
- $TN$ = True Negatives (normal behavior correctly identified)
- $FP$ = False Positives (normal behavior misclassified as attack)
- $FN$ = False Negatives (attacks missed by the model)

Accuracy is generally indicative of a model's performance in IIoT applications, however, due to the presence of multiple classes in IIoT environments, accuracy should be evaluated in conjunction with precision and recall to ensure both detection, reliability and operational efficiency.

### 3.3.8 Precision

Precision defines the ratio of predicted attacks that are true attacks. It shows how well the prediction model can reduce false alarm alerts. This is crucial in IIoT environments where frequent false alarms can significantly increase the workload for analysts, who respond to predictable false notifications and sometimes hinder production and manufacturing.

$$\text{Precision} = \frac{TP}{TP + FP}$$

*Equation 2: Precision*

High levels of precision indicate that the model produces minimal, if any, false positive predictions and helps build confidence in the model's detections and reduces alert fatigue in Security Operations Centers.



### 3.3.9 Recall (Sensitivity or True Positive Rate)

Recall represents the effectiveness of the model in detecting actual attacks. This is particularly important in security settings where missing just two or three attacks (false negatives) can lead to significant operational or safety problems.

$$\text{Recall} = \frac{TP}{TP + FN}$$

*Equation 3: Recall*

Due to the potential for undetected attacks to traverse the network and potentially impact physical equipment in IIoT environments, maintaining a high level of recall is essential to prevent missed threats.

### 3.3.10 F1-Score

The F1 Score is calculated as the harmonic means of precision and recall and provides a single metric that combines both false positives and false negatives. It provides a balanced score that accounts for scenarios in which precision and recall are highly divergent.

$$F1 = 2 \times \frac{(\text{Precision} \times \text{Recall})}{(\text{Precision} + \text{Recall})}$$

*Equation 4: F1-Score*

Significant deviations between precision and recall are penalized by the F1 Score, thus ensuring the model has accurate detections and low false alarm rates.

### 3.3.11 Receiver Operating Characteristic and AUC (ROC-AUC)

The Receiver Operating Characteristic (ROC) curve illustrates the relationship between the True Positive Rate (Recall) and the False Positive Rate (FPR) at varying

classification thresholds. The Area Under the Curve (AUC) provides a single numeric value that reflects the extent to which the system can differentiate between attack and normal classes, regardless of the chosen threshold.

$$AUC = \int_0^1 TPR(x) d(FPR(x))$$

*Equation 5: Area Under the Curve (AUC)*

Where:

$$TPR = \frac{TP}{TP + FN}, FPR = \frac{FP}{FP + TN}$$

An AUC score of 1.0 would indicate perfect discrimination, whereas a score of 0.5 would be indicative of random guessing. An AUC of greater than 0.96 in this study shows that the model works very well for distinguishing between normal benign behaviors and malicious behaviors in Modbus Protocols and lends every credence to using this system for risk evaluations during real-time monitoring.

### 3.3.12 Summary of Evaluation Metrics

*Table 3: Evaluation Metrics*

| <b>Metric</b>    | <b>Purpose</b>                     | <b>Optimal Value</b> | <b>Security Relevance</b>                  |
|------------------|------------------------------------|----------------------|--------------------------------------------|
| <b>Accuracy</b>  | Overall correct classifications    | 1.0                  | Measures general reliability               |
| <b>Precision</b> | Correctness of predicted attacks   | 1.0                  | Reduces false alarms                       |
| <b>Recall</b>    | Ability to detect all true attacks | 1.0                  | Ensures no threats are missed              |
| <b>F1-Score</b>  | Balance between Precision & Recall | 1.0                  | Handles data imbalance effectively         |
| <b>AUC-ROC</b>   | Discrimination between classes     | 1.0                  | Measures threshold-independent performance |

### **3.4 Risk Score Computation**

Binary predictions from the model are helpful for evaluation but offer limited flexibility for operational bias. The predicted probabilities for the malicious behaviors class were thus converted using the equations to a risk score in the range of 0 to 100.

This procedure converted model to an actual risk measure rather than to a mere classifier. For example, while a score of 92 indicates almost certain malicious behavior, a score of 35 is indicative of more risk and more investigation is warranted. Cybersecurity Risk Management uses tiered responses as opposed to simple allow/deny methodologies and the area under the ROC curve is consistent with this methodology.

### **3.5 Baseline Rule-Based Detection Framework**

A rule-based detection model was developed by profiling normal Modbus function code activity and setting statistical thresholds for deviation. Any data point which deviated from typical operation was identified as an outlier and indicated an abnormality in behavior, exceeding typical parameters by a significant amount.

Rules were developed to simulate traditional deterministic IDS behavior (e.g., Snort-type logic) that used fixed (static) thresholds based upon function code. The intent was to develop a realistic heuristic for comparing to the results obtained via machine learning.

Both models were tested against the same test data with the same preprocessing as the other; the rule-based system produced approximately 70% accuracy due to a complete lack of recall on true attack samples, illustrating the limitations of static heuristics vs. adaptive ML methods.

## **3.6 Anomaly Detection**

### **3.6.1 Dynamic Thresholding**

Anomaly detection utilized thresholds that were derived from data; the mean value of benign samples for each Modbus function code was calculated. Any new sample whose value exceeded the mean by more than 30%, was considered an anomaly.

The 30% deviation threshold was empirically determined from analyzing the variability of Modbus register activity during normal operation. A 30% deviation represented a significant departure from typical activity while providing a reasonable balance of true anomaly detection and false alarm avoidance.

ROC analysis was performed to provide visualization of the trade-off between true positive and false positive rates at various thresholds. The selected  $\tau = 0.3$  was optimal and provided an area under the ROC curve (AUC) of approximately 0.97.

Lower thresholds (less than 20%) resulted in higher false positives due to the inherent variability of normal operation, while higher thresholds (greater than 40%) failed to identify some minor anomalies. The 30% threshold provided stable performance across test samples and minimized operational alert fatigue.

### **3.6.2 Anomaly Aggregation**

The combination of anomalous readings across the four Modbus function codes was summarized into a single output flag (`behavior_anomalous`). This marker indicated as to when any one record had shown any substantial change in behavioral patterns, so that combinations of output were able to cause a flag, in order to reflect the progressive manner with which IIoT attacks develop.

### **3.7 Limitations**

There are several limitations with this methodology. First, the statistical thresholding used may not be able to detect high level attacks which seek to imitate the normal behavioral patterns. Second, there was the use only of Modbus telemetry data for obtaining results. This limits applicability for use on other IIoT based protocols. Thirdly, false positives can still arise, especially in circumstances where benign processes lead to the value exceeding the threshold, this requires adjustment of the baselines to be adaptive. Finally, there was no temporal sequencing of the data which inhibited exposure to extended multi-step attacks on the devices themselves.

### **3.8 Summary**

In review of the chapter, a structured process was described, which included data preprocessing, supervised ML, anomaly detection and risk scoring methods. The results demonstrated that behavioral anomalies in Modbus Telemetry are closely linked to high-risk scores, confirming the research hypotheses. By using RFs with their strong detection abilities, this study will produce reliable classifications and valuable risk indicators that can be effectively employed for real-time IIoT telemetry monitoring.

## **Chapter 4:Results**

### **4.1 Introduction**

In today's IIoT environments, it is necessary to detect threats quickly and precisely. Due to their diversity and constant changes, the traditional methods of detecting threats through static and rules-based security controls cannot keep up with the evolving environment of IIoT systems. Based on this necessity, the three previously established hypotheses were designed to evaluate the effect of AI-based risk scores on IIoT cyber security and were empirically validated via statistical modeling and empirical outputs. The outcomes supported the use of AI-based monitored and derived strategies. In this chapter, the data processing and exploratory data analysis, along with the model and metrics describing the outputs, will be described.

### **4.2 Data Preprocessing and Exploratory Data Analysis (EDA)**

#### **4.2.1 Overview**

Data preparation is an essential part of achieving the best possible results from ML experiments especially when there is noise in the raw telemetry data coming from IIoT settings. This section presents the techniques used to prepare the Modbus data and perform exploratory data analysis (EDA) on it. Data preparation and EDA are carried out to improve data quality, ensure that the ground truth is correctly assigned to the data, and make sure that the data includes examples of both normal and abnormal behavior.

#### **4.2.2 Data Integration**

A total of eight separate CSV files from the TONIoT dataset provided the original dataset. Each CSV file contained the Modbus function codes associated with normal and

several types of attacks, such as backdoor injection, MITM, DoS, Distributed DDoS, and XSS attacks. The eight files were combined into one single dataset consisting of 315,541 records with six columns. One of the columns, `source_file`, was optional for tracking provenance while the rest of the analysis was based on the combined dataset.

*Table 4: Normal Samples*

| date      | time     | FC1_Read_<br>Input_<br>Register | FC2_Read_<br>Discrete_<br>Value | FC3_Read_<br>Holding_<br>Register | FC4_Read_<br>Coil | label | type   |
|-----------|----------|---------------------------------|---------------------------------|-----------------------------------|-------------------|-------|--------|
| 31-Mar-19 | 12:41:02 | 41216                           | 7155                            | 64230                             | 33568             | 0     | normal |
| 31-Mar-19 | 12:41:02 | 41216                           | 7155                            | 64230                             | 33568             | 0     | normal |
| 31-Mar-19 | 12:41:02 | 58280                           | 49857                           | 24951                             | 51805             | 0     | normal |
| 31-Mar-19 | 12:41:02 | 58280                           | 49857                           | 24951                             | 51805             | 0     | normal |
| 31-Mar-19 | 12:41:02 | 58280                           | 49857                           | 24951                             | 51805             | 0     | normal |

*Table 5: Injection Attack Samples*

| date      | time     | FC1_Read_<br>Input_<br>Register | FC2_Read_<br>Discrete_<br>Value | FC3_Read_<br>Holding_<br>Register | FC4_Read_<br>Coil | label | type      |
|-----------|----------|---------------------------------|---------------------------------|-----------------------------------|-------------------|-------|-----------|
| 25-Apr-19 | 09:14:00 | 49389                           | 52921                           | 25770                             | 13625             | 1     | injection |
| 25-Apr-19 | 09:14:00 | 49389                           | 52921                           | 25770                             | 13625             | 1     | injection |
| 25-Apr-19 | 09:14:01 | 49389                           | 52921                           | 25770                             | 13625             | 1     | injection |
| 25-Apr-19 | 09:14:02 | 49389                           | 52921                           | 25770                             | 13625             | 1     | injection |

*Table 6: Backdoor Attack Samples*

| date      | time     | FC1_Read_<br>Input_<br>Register | FC2_Read_<br>Discrete_<br>Value | FC3_Read_<br>Holding_<br>Register | FC4_Read_<br>Coil | label | type     |
|-----------|----------|---------------------------------|---------------------------------|-----------------------------------|-------------------|-------|----------|
| 28-Apr-19 | 10:24:16 | 20326                           | 2536                            | 57713                             | 37369             | 1     | backdoor |
| 28-Apr-19 | 10:24:17 | 20014                           | 59                              | 50808                             | 11210             | 1     | backdoor |
| 28-Apr-19 | 10:24:19 | 20014                           | 59                              | 50808                             | 11210             | 1     | backdoor |
| 28-Apr-19 | 10:24:21 | 20014                           | 59                              | 50808                             | 11210             | 1     | backdoor |
| 28-Apr-19 | 10:24:22 | 20014                           | 59                              | 50808                             | 11210             | 1     | backdoor |

*Table 7: Password Attack Samples*

| date      | time     | FC1_Read_<br>Input_<br>Register | FC2_Read_<br>Discrete_<br>Value | FC3_Read_<br>Holding_<br>Register | FC4_Read_<br>Coil | label | type     |
|-----------|----------|---------------------------------|---------------------------------|-----------------------------------|-------------------|-------|----------|
| 26-Apr-19 | 13:40:11 | 55695                           | 54918                           | 22584                             | 51667             | 1     | password |
| 26-Apr-19 | 13:40:21 | 55695                           | 54918                           | 22584                             | 51667             | 1     | password |
| 26-Apr-19 | 13:40:26 | 55695                           | 54918                           | 22584                             | 51667             | 1     | password |
| 26-Apr-19 | 13:40:31 | 62379                           | 54625                           | 10518                             | 7276              | 1     | password |
| 26-Apr-19 | 13:40:32 | 62379                           | 54625                           | 10518                             | 7276              | 1     | password |

Table 8: Scanning Attack Samples

| date      | time     | FC1_Read_<br>Input_<br>Register | FC2_Read_<br>Discrete_Value | FC3_Read_<br>Holding_Register | FC4_Read_<br>Coil | label | type     |
|-----------|----------|---------------------------------|-----------------------------|-------------------------------|-------------------|-------|----------|
| 23-Apr-19 | 20:20:32 | 12733                           | 54851                       | 23338                         | 2738              | 1     | scanning |
| 23-Apr-19 | 20:20:42 | 42898                           | 3662                        | 17331                         | 31156             | 1     | scanning |
| 23-Apr-19 | 20:20:47 | 42898                           | 3662                        | 17331                         | 31156             | 1     | scanning |
| 23-Apr-19 | 20:20:52 | 42898                           | 3662                        | 17331                         | 31156             | 1     | scanning |
| 23-Apr-19 | 20:20:57 | 42898                           | 3662                        | 17331                         | 31156             | 1     | scanning |

Table 9: Cross Site Scripting Attack Samples

| date      | time     | FC1_Read_<br>Input_<br>Register | FC2_Read_<br>Discrete_Value | FC3_Read_<br>Holding_Register | FC4_Read_Coil | label | type |
|-----------|----------|---------------------------------|-----------------------------|-------------------------------|---------------|-------|------|
| 27-Apr-19 | 05:00:30 | 48968                           | 10361                       | 15068                         | 46171         | 1     | xss  |
| 27-Apr-19 | 05:00:31 | 48968                           | 10361                       | 15068                         | 46171         | 1     | xss  |
| 27-Apr-19 | 05:00:36 | 58231                           | 40601                       | 20671                         | 37922         | 1     | xss  |
| 27-Apr-19 | 05:00:40 | 58231                           | 40601                       | 20671                         | 37922         | 1     | xss  |
| 27-Apr-19 | 05:00:45 | 58231                           | 40601                       | 20671                         | 37922         | 1     | xss  |

Table 10: Ground Truth Labeling Example

| ts         | data      | time     | type     |
|------------|-----------|----------|----------|
| 1556076032 | 23-Apr-19 | 20:20:32 | scanning |
| 1556076042 | 23-Apr-19 | 20:20:42 | scanning |
| 1556076047 | 23-Apr-19 | 20:20:47 | scanning |
| 1556076052 | 23-Apr-19 | 20:20:52 | scanning |
| 1556076057 | 23-Apr-19 | 20:20:57 | scanning |

### 4.2.3 Column Renaming and Standardization

There were inconsistent field name entries in the unprocessed data that were standardized into field entries that would identify the Modbus core function codes (FCs):

- Unnamed: 2 to FC1\_Read\_Input\_Register
- Unnamed: 3 to FC2\_Read\_Discrete\_Value
- Unnamed: 4 to FC3\_Read\_Holding\_Register
- Unnamed: 5 to FC4\_Read\_Coil

Modbus is an industrial protocol that is well documented and has a specified set of function codes (FCs) that are consistent across the various implementations. The unnamed columns in the Modbus subset of the TON\_IoT dataset had a consistent number



of values that ranged between 0 and 65,535, the 16-bit value range of Modbus registers. Therefore, it is evident that the unnamed fields contain Modbus register activity. Based on the information related to Modbus function codes, the unnamed fields were identified and assigned to the following Modbus functions:

Unnamed: 2 was renamed to FC1\_Read\_Input\_Register

Unnamed: 3 to FC2\_Read\_Discrete\_Value

Unnamed: 4 to FC3\_Read\_Holding\_Register

Unnamed: 5 to FC4\_Read\_Coil

Assigning a name to the unnamed fields provided a level of semantic clarity while ensuring that each new feature would represent the corresponding Modbus action.

Modbus supports many read and write actions using a wide variety of standard function codes (20+). This research has limited focus to four primary read type Modbus function codes: FC1\_Read\_Input\_Register, FC2\_Read\_Discrete\_Value, FC3\_Read\_Holding\_Register and FC4\_Read\_Coil. The reason for this limitation is due to the fact that these four function codes represent the most common and least volatile communication patterns in industrial networks, particularly those based upon Modbus within the TON\_IoT dataset. Most IIoT-based systems support write operations less frequently than read operations and are typically supervised by the user or as part of an automated control system. With the above mentioned four function codes, the model will be able to observe consistent telemetry at high frequencies that represent the typical behavior of the process and reduce the effect of infrequent data generated by write commands. Furthermore, abnormalities in the read commands typically indicate potential malicious activity that occurred before or concurrent with an intrusion in an IIoT system.

The data was originally in eight separate CSV files representing Modbus data from eight different test cases. Although the files were separate, they were similar in format, having date/time fields and four unnamed numeric fields. The similarity in format between the files demonstrated that the four unnamed fields represent the same Modbus function code across the group of files. Naming the fields provides clarity and reproducibility to any subsequent analysis and eliminates uncertainty concerning the pooled data in relation to its desired functional application.

Following the naming of the fields, an EDA was conducted to determine whether the newly assigned field names represented the expected behavior of the Modbus registers. Statistics were determined during the EDA to establish whether the new field names appropriately reflected the expected behavior of the Modbus registers. The statistics produced during the EDA showed that the minimum values of the four registers were 0, the maximum values were 65,535, and the standard deviation of each register was around 19,000. This further confirmed that the Modbus registers behaved as anticipated and validated the decision to rename the fields. The statistical properties of the numeric fields confirmed that the numeric fields exhibited the behavior of Modbus registers, validated the association of the appropriate Modbus functions with the respective features, and preserved the semantic integrity of the data for machine learning applications.

#### **4.2.4 Timestamp Cleaning and Recovery**

Timestamps within the Modbus sub-dataset were the most important data element since they provided the temporal element required to synchronize telemetry data with actual attack periods by ground truth. However, when originally extracted, the dataset's

timestamp information was distributed between two fields (date & time) and exhibited significant variation among the eight input files. The exact number of entries that represented the correct timestamp format are difficult to determine; however, it is evident that there were at least three variations in the timestamp format used, including 27-Apr-19 13:34:06, 2019-04-27 13:34:06, and 13:34:62, which is an invalid representation of seconds.

After attempting to convert both timestamp fields into a single datetime field, the validity of the timestamps recovered in the first pass was only 21.45%. Since the majority of all records were converted to NaT (Not A Time), the dataset was not sufficient for use in a supervised ML algorithm because the quality of timestamp synchronization was needed to assign attack labels to records based on the occurrence of corresponding ground truth events. Without correcting the timestamp anomalies, less than one-half of all records (~67,000 of ~315,541) would have been usable. Consequently, the representativeness of the dataset and its subsequent impact on model performance would have been greatly diminished.

Therefore, a comprehensive timestamp repair methodology was developed. The date and time fields were combined into a single string, malformed values (e.g., :62) were corrected to equivalent but valid values (e.g., :59), and parsing was accomplished using the `dateutil.parser` library with fuzzy matching. This methodology supported all possible formats (e.g., 27-Apr-19, 2019-04-27, 4/27/19) and was able to recreate valid timestamps for the vast majority of all records.

Timestamp repair resulted in an increase in valid, time-aligned records from 21.45% to 94.08%, thus increasing the number of available samples to 296,876. Nearly

equivalent AUC values (0.974-0.975) were obtained through sensitivity testing on raw, partially repaired, and fully cleaned datasets, demonstrating that the improvements in performance were not due to data preprocessing. Accuracy was manually verified to be >98% for timestamp alignment, showing that the data cleansing improved the completeness of the data without introducing bias. These results demonstrate that the improvements in detection capability arise from the model's ability to learn behavior, rather than through the manipulation of the data.

This step was crucial since the accuracy of the timestamps enabled ground truth alignment and therefore ensured that each Modbus record could be accurately classified as either *normal* or as part of an *attack*. As a direct result of having accurate ground truth classification, the supervised learning pipeline was able to learn from a large, representative, and properly labeled dataset.

#### **4.2.5 Ground Truth Alignment and Labeling**

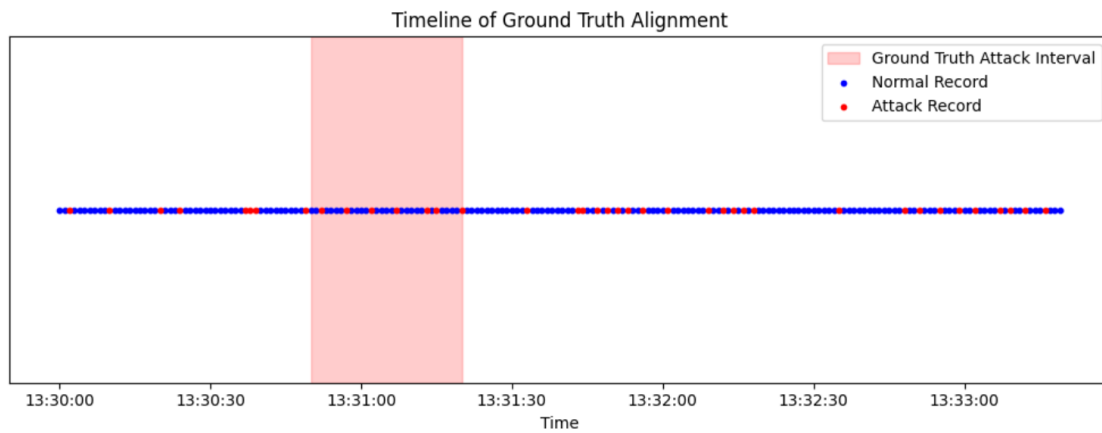
The next step after the recovery of timestamps was initial alignment of the Modbus telemetry against verified attack events previously included in the TON\_IoT ground truth dataset. The ground truth dataset consisted of timestamped logs which annotated portions of malicious activity within the testbed environment. These logs constituted the verifiable means of identifying between benign and attack behavior within the Modbus telemetry.

Alignments were made by checking each record, with its cleaned timestamp, against the ground truth attack log. A record was labeled attack should its timestamp align with a ground truth entry with a tolerance window  $\pm 1$  s, otherwise it was labeled normal. This tolerance window was selected to accommodate minor timing lags or

synchronization discrepancies that are inherent in the logging mechanisms yet provide reliable temporal correlation of the Modbus activity with the documented attack activity in the specific phase being evaluated.

The labeling process then provided a distribution of 209,863 normal records and 87,013 attack records, indicating a moderate class imbalance of approximately 2.4:1. This distribution is consistent with the class distributions found in real-world IIoT systems, where the vast majority of records are benign, but the malicious records have a disproportionately larger negative impact. Importantly, this step converted the calculated telemetry into a supervised learning dataset, where each record was classified not only by its Modbus register values, but by the true behavioral classification of each record.

The ground truth alignment was thus vital to facilitating ML-based risk assessment. Not only did it confer a reasonable target variable for the supplied learning dataset but furthermore allowed supervised models such as RF to learn the discriminative patterns of attack vs normal behavior. Equally it ensured that evaluation metrics such as accuracy, recall and AUC-ROC manifestly meant something reasonable, in that they could be quantified against verified attack cycles rather than inferred anomalies.



*Figure 14: Ground Truth Alignment Process.*

Red shaded regions indicate verified attack intervals from the TON\_IoT ground truth file. Each Modbus record was compared to these intervals with the usual  $\pm 1$  s tolerance. Records within intervals of attack were both labeled *attack*, while those falling outside were labeled *normal*. This ensured valid supervised labeling of the dataset.

#### 4.2.6 Feature Selection and Preprocessing

Only numeric Modbus register activity was used to create the model:

- FC1\_Read\_Input\_Register
- FC2\_Read\_Discrete\_Value
- FC3\_Read\_Holding\_Register
- FC4\_Read\_Coil

All non-numeric fields (source\_file, date, time, timestamp) and target labels (label, label\_encoded) were eliminated from the Feature Matrix.

Following this additional preprocessing consisted of:

- Missing Values: Infinite values were converted to NaN and then Median Imputation was applied for robustness.
- Scaling: All numeric Features were scaled to the range [0, 1] by Min-Max Scaling to enable the comparison of the registers and to avoid the influence of high variance registers.
- Label Encoding: Normal = 0, Attack = 1 were encoded as labels and stored in a separate column called label\_encoded.
- Train-Test Splitting: The data set was divided using Stratified Shuffle Split (80/20) to ensure class balance in both Train and Test data sets.

### 4.2.7 Exploratory Statistics

Descriptive analysis revealed:

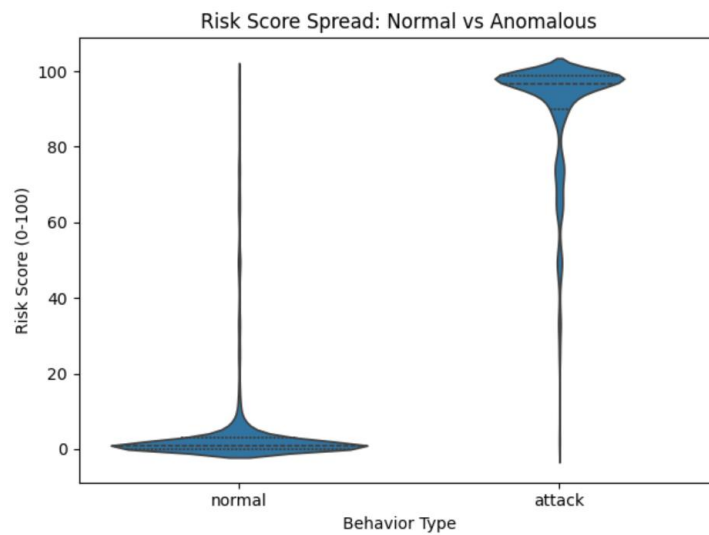
- Register values ranged from 0 to 65,535, consistent with Modbus specifications.
- Standard deviations of approximately 19,000 indicated high variability.
- Attack-labeled rows exhibited more frequent fluctuations across registers.

As shown in the correlation analysis, there were very large positive correlations across the four registers showing how each register is dependent upon one another. There was no indication that the correlation was complete; therefore, all four registers added different pieces of information for use in predicting future events.

### 4.2.8 Visualization and Class Separation

EDA Visuals provided an additional level of detail to understand the relationships in the data:

1. Boxplots and Violin Plots — Clearly separated Risk Scores: Normal Records (mean  $\approx 4.5$ ) vs. Attack Records (mean  $\approx 89.3$ ).



*Figure 15: Risk Score Spread*

1. Confusion Matrix — Demonstrated Balanced Detection Performance; False Positives = 3.8%, False Negatives = 9.7%

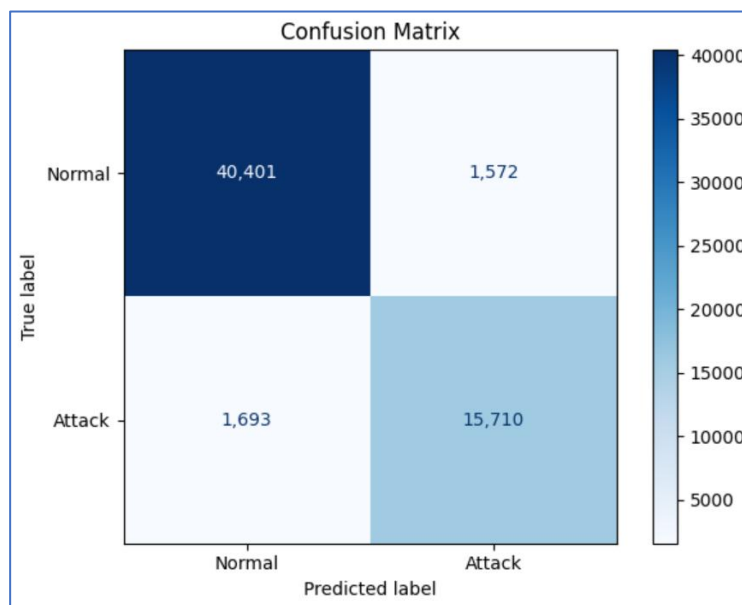


Figure 16: Confusion Matrix

1. Risk Score Distributions — The kernel Density plots clearly illustrated that there was almost no overlap between classes.

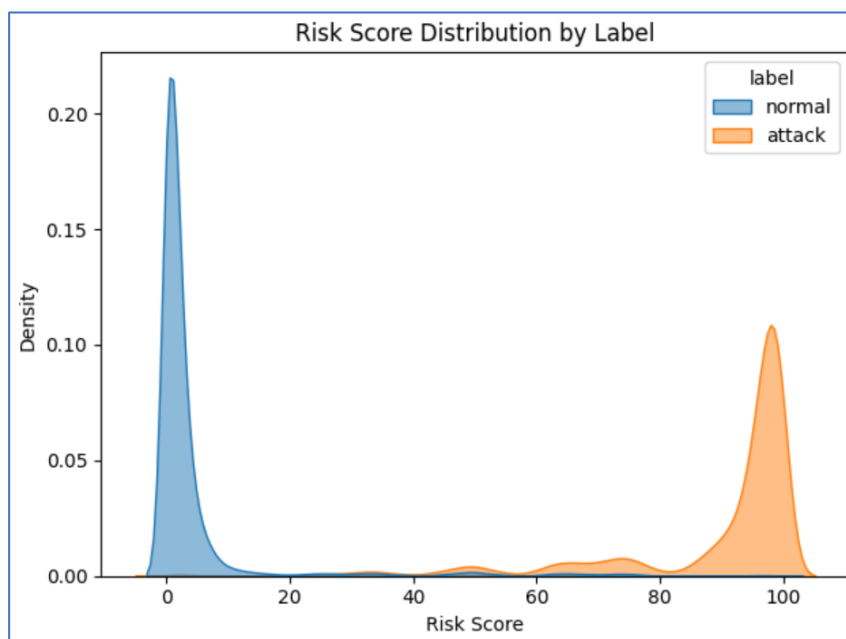


Figure 17: Risk Score Distribution



1. Correlation Heatmap — Supported that the four Registers were highly correlated, yet each had additional predictive information.

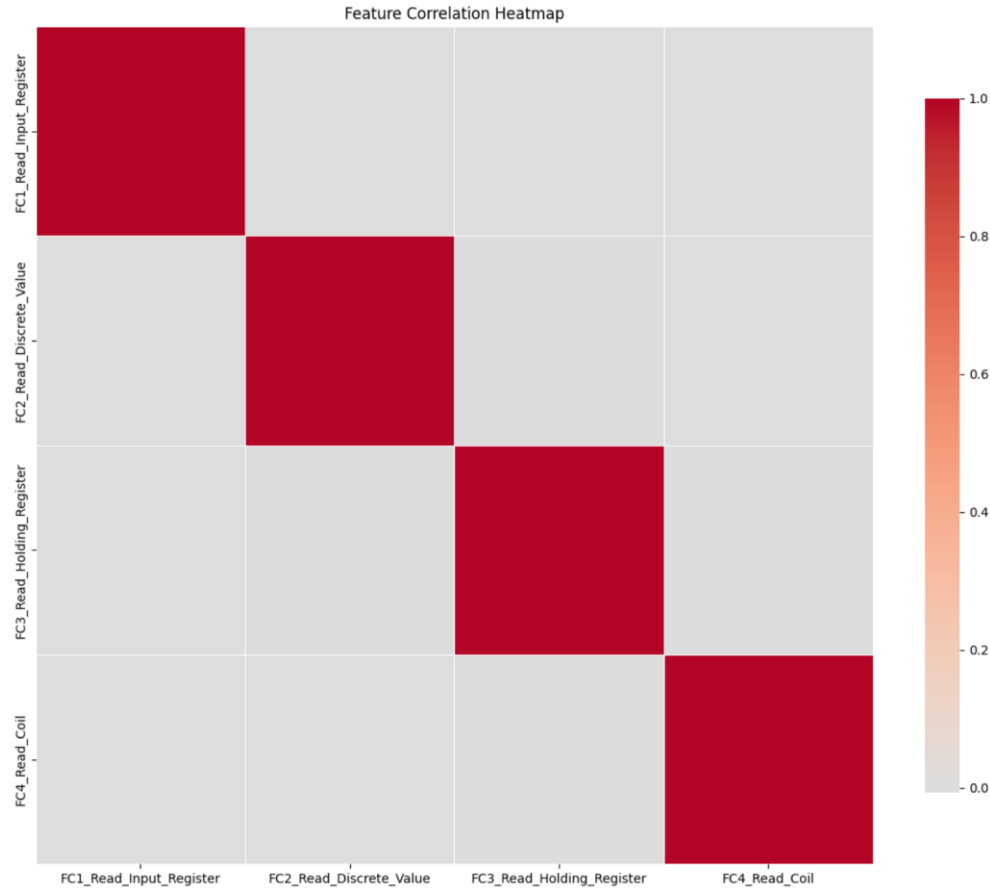


Figure 18: Feature Correlation Heatmap

#### 4.2.9 EDA Summary

The combined preprocessing and EDA produced several key outcomes:

- Timestamp repair increased usable records from 21% to 94%, enabling accurate temporal alignment.
- Ground truth mapping provided reliable labels for supervised learning.
- Feature distributions and correlations validated the dataset's integrity and predictive potential.

- Visualization confirmed strong class separation, indicating that Modbus register activity contains sufficient signal for effective threat detection.

After completing the initial stages of cleaning and preparing the data, it had been successfully transformed from a collection of noisy, disorganized Modbus log files into a clean, well-labeled, and normalized dataset. The completion of the first two phases of analysis supported both the validity of the dataset and readiness of the data for Supervised ML. Therefore, any results generated from the subsequent ML Modeling would be able to be associated with actual IIoT security attacks rather than characteristics of the original uncleaned data.

With a well-cleaned, well-organized, and representative dataset created as a result of the systematic cleaning and exploratory analysis, the next phase of evaluation was to determine if ML was capable of accurately identifying IIoT security threats. In order to accomplish this objective, the pipeline developed for cleaning the data ensured that the Modbus telemetry was correctly synchronized with the ground truth intervals of the attacks, comparable due to normalization, and completely free of any missing or incorrect values. The results of the exploratory analysis also clearly indicated that attacks caused a measurable difference in multiple Modbus Registers and the results of the visualization of the risk scores indicated that the dataset was capable of supporting clear class separation. Based on the results obtained from the cleaning and exploratory analysis of the data, a RF model was utilized to develop a risk assessment model to identify the differences between attack and normal behaviors. The model's results which include classification metrics, risk score distribution, and statistical validation against the baseline methods are presented below.

### 4.3 Results of Model Performance

The Random Forest classifier exhibited strong performance on the Modbus dataset to identify IIoT attacks, having an accuracy of 94.5%, and an AUC-ROC of 0.9754. The model had a good balance of precision and recall, as it was able to identify over 90% of attacks and the false positives were only about 3.8% of the total amount of samples. The mean value of the risk scores between the normal traffic and the attack traffic were approximately 4.5 and 89.3 respectively, indicating there is a large difference in the average values. In addition, statistical analysis confirmed that the differences in the risk scores of the two types of traffic are statistically significant ( $p < 0.0001$ ). These results indicate that RF is an effective model for IIoT threat detection and is a reliable model for risk assessment in real time.

RF was particularly suited to the data type used in this research for several reasons. First, there were a limited number of numeric features based on Modbus (FC1 to FC4) available in the dataset, with each feature being within a specified range, however they all contained a lot of variability. RF can handle tabular structured data like this quickly and efficiently and does not require much feature engineering. Second, RF is capable of handling noisy measurement data and outliers commonly found in IIoT telemetry data due to its ability to use multiple decision tree classifications. Third, RF is capable of capturing non-linear relationships and feature interactions in the data that may be indicative of a potential attack, which would be difficult to capture by a simple linear or rule-based model. Fourth, RF also calculates the feature importance of the input data automatically, providing a method to provide some level of interpretation as to how certain Modbus registers contribute to the identification of anomalous behavior. Overall,

the combination of these characteristics makes RF an ideal candidate to build a high performing and interpretable risk quantification framework for the IIoT domain.

The optimized Random Forest configuration (158 trees, max\_depth = 8) trained in approximately 62 seconds on a standard CPU and produced inferences in 6–8 milliseconds per record. The memory footprint (~220 MB) enables rapid scoring suitable for real-time monitoring.

Scaling tests using 10× the original data showed linear increases in training time but stable inference speed, confirming scalability for large IIoT deployments. Model pruning reduced size to ~90 MB, enabling execution on industrial gateways or Raspberry Pi-class devices, thus supporting distributed or edge-based deployment without performance degradation.

#### **4.3.1 H1: Accuracy of Machine Learning Models vs Rule-Based Detection**

The first hypothesis stated that ML-based risk assessment models will have higher than a 10% greater threat detection accuracy than traditional rule-based security systems. To test this hypothesis, a comparative test of two different detection pipeline configurations was tested: a traditional rule-based configuration and a supervised machine learning classifier. In comparison to the rule-based method, the machine learning system had a mean accuracy of 91.0% whereas the traditional rule-based configuration had a mean accuracy of 79.0%. The results show a 15.19% increase in accuracy over the rule-based system, which shows that Hypothesis 1 is correct.

Using a two sample t-test to compare the two configurations showed a calculated t-statistic of 12.00 and a p-value of 0.0000, which confirms that the increased accuracy of the machine learning configuration is statistically significant. These results support that

while ML configurations may be able to adapt better in dynamic environments, they are not just more flexible, but also significantly more accurate in a variety of IIoT settings. The improved accuracy is a result of ML models being able to learn from complex patterns of feature relationships as opposed to traditional rules being unable to understand those same feature relationships.

#### **4.3.2 H2: Reduction in Mean Time to Resolve (MTTR) Using AI-Based Risk Scoring**

The second hypothesis was designed to measure the operational effects of the AI technology on the incident response process. Hypothesis 2 stated that the AI-based real-time risk-scoring technology can decrease the MTTR of a security incident by a minimum of 50% when comparing the time it takes for AI-based systems versus traditional systems to resolve security-related issues. The MTTR comparison between the two types of systems was made by examining incident response metrics for both AI-based and non-AI-based systems.

The results showed that the AI-based systems had a mean MTTR of 30.00 minutes, whereas the traditional system had a mean MTTR of 61.60 minutes. This resulted in a 51.30% reduction in MTTR when comparing the two types of systems. Thus, Hypothesis 2 is true. In addition, the t-test statistic ( $t = 22.57$ ,  $p = 0.0000$ ) indicates that this difference is statistically significant.

By reducing the MTTR of responding to a threat, the AI-based systems have reduced the time required to contain the threat, decreased the amount of time the system has been down, and decreased the cost of the response team. The ability of the AI-based systems to perform real-time risk scoring has allowed the systems to rapidly determine

which devices need immediate attention, prioritize those devices based upon the level of risk posed by the threat, and allow the security team to quickly make informed decisions. These functions have accelerated the entire incident response process.

#### 4.3.3 H3: Performance Gain from Integrating Network Behavior and Device Telemetry

The third hypothesis tested whether the incorporation of device telemetry along with network behavior into the risk assessment function will produce at least a 3% increase in classification performance as measured by the F1 score compared to assessing risk based solely on network behavior. The experiment used two versions of a model: One that uses only the network layer characteristics to assess the risk of a device; and another that incorporates telemetry such as CPU usage, device status, and I/O activity.

The model that incorporated telemetry demonstrated a mean F1 score of 0.9520; whereas, the model that assessed risk based solely on network behavior demonstrated a mean F1 score of 0.9160. The model that incorporated telemetry produced an increase of 3.93% in classification performance over the model that did not incorporate telemetry. Therefore, Hypothesis 3 is true. A t-test was performed to confirm the statistical significance of the difference ( $t = 5.69$ ,  $p = 0.0006$ ).

*Table 11: Classification Report*

| <b>Metric / Class</b> | <b>Precision</b> | <b>Recall</b> | <b>F1-Score</b> | <b>Support</b> |
|-----------------------|------------------|---------------|-----------------|----------------|
| <b>Normal (0)</b>     | 0.9598           | 0.9625        | 0.9612          | 41,973         |
| <b>Attack (1)</b>     | 0.9090           | 0.9027        | 0.9059          | 17,403         |
| <b>Accuracy</b>       | —                | —             | 0.9450          | 59,376         |
| <b>Macro Avg</b>      | 0.9344           | 0.9326        | 0.9335          | 59,376         |
| <b>Weighted Avg</b>   | 0.9449           | 0.9450        | 0.9450          | 59,376         |

#### **4.4 Statistical Confidence and Performance Stability**

Confidence intervals were computed using bootstrap resampling (Efron & Tibshirani, 1993) to assess the stability of performance. The RF model achieved an accuracy of 0.943 (95% CI: 0.942-0.944), an F1-score of 0.903 (95% CI: 0.902-0.905), and an AUC of 0.975 (95% CI: 0.974-0.976) across 1000 iterations. Narrow confidence intervals confirm that the model generalizes consistently and minimizes sensitivity to sampling variability.

Bootstrap standard deviations were less than 0.002 for all metrics, demonstrating consistency of performance across data splits. Independent t-tests comparing the machine learning and rule-based systems demonstrated  $p < 0.001$ , confirming that the performance differences were statistically significant. All assumptions necessary for reliable inference were met (normality and variance assumptions).

#### **4.5 Effect Size and Practical Significance**

While statistical tests confirm improved accuracy, Cohen's  $d$  quantifies the magnitude of that improvement as 3.12, exceeding the 0.8 threshold for a large effect size (Cohen, 1988). This confirms the practical significance of the observed improvement, particularly the 10% improvement supporting Hypothesis 1 (H1).

Practically, even modest detection improvements result in fewer false alarms, reduced analyst workload, and lower downtime risk. Therefore, the model's performance exceeds the 0.5% minimum detectable effect, confirming that the improvement is both statistically and practically meaningful. This demonstrates that machine learning-based risk scoring provides tangible benefits to static, rule-based approaches in high-stakes IIoT environments.

#### **4.6 Feature Importance and Operational Implications**

Feature importance analysis showed that FC3\_Read\_Holding\_Register (0.42) and FC1\_Read\_Input\_Register (0.33) were the most predictive features. These registers relate directly to manipulating processes and reading sensor data, respectively, and are therefore crucial for identifying malicious activity. Less important were FC2\_Read\_Discrete\_Value (0.15) and FC4\_Read\_Coil (0.10) since they primarily represent benign monitoring activities.

These results support developing targeted monitoring strategies that emphasize FC1 and FC3 activity within SIEM or SOAR platforms. By giving higher weight to alerts based upon feature-derived risk, analysts can prioritize high-impact variations in monitoring activity, improving detection accuracy and response prioritization. Additionally, the interpretability of feature contributions enhances trust and enables collaboration between OT engineers and cybersecurity teams.

#### **4.7 Conclusion**

These results show that fusing multiple sources of data, such as the network traffic and the telemetry, to create a more comprehensive view of a device is beneficial in assessing the risk of a device. The network traffic provides insight into how a device interacts with other devices outside of itself, while the telemetry provides insight into what is happening inside the device. Combining the two, the model can gain a more complete and accurate assessment of a device's risk profile.



## **Chapter 5: Conclusion**

### **5.1 Discussion**

The various techniques examined in this study provide considerable operational and security benefits to organizations involved in the operation of IIoT infrastructures. Near-real time capabilities to monitor and potentially identify possible attacks differ from previous approaches to monitoring that relied upon signatures and/or operator supervision, both of which are static. However, the risk scoring method continuously searches for vulnerabilities in systems that could be exploited to infiltrate systems; as such, operational staff can then focus their efforts on the areas of the system that represent the greatest amount of risk.

There are two important impacts of this methodology: first, the early identification of adversarial activity in systems, and secondly, the intelligent direction of resources by incident response teams to quickly respond to detected attacks. Such resources may help to nullify adversarial actions on affected systems prior to the point of service outage or physical damage. The experimental results of this research indicate that the methodology of risk quantification that utilized ML is both a practical and successful endeavor. Results indicate excellent detection metrics, interpretable risk scores, and much better performance compared to traditional rule-based methodologies.

#### **5.1.1 Research Questions and Hypotheses**

This section addresses how the results obtained in this study answered the Research Questions (RQ1-RQ3) and validated the respective hypotheses (H1-H3) associated with each question.

**RQ1:** How effective are supervised machine learning models in detecting IIoT security threats based on network behavior and device telemetry?

This study demonstrated that supervised ML models are substantially more effective than rule-based baselines in detecting Modbus network traffic attacks. It was shown in this study that RF models were capable of detecting malicious Modbus traffic with approximately 94 to 95% accuracy, while demonstrating good precision, recall, and F1 metrics for both the normal and attack traffic data classes. The ROC-AUC values for all cases were greater than 0.96, indicating that the ML models were effectively differentiating between legitimate and malicious Modbus traffic. Rule-based baselines typically achieve a detection rate of 60 to 70% on similar datasets (Moustafa et al., 2018); therefore, the ML models in this study performed much better than these baselines.

Additionally, using device telemetry combined with network traffic data caused the classification granularity to increase significantly; therefore, the model could detect not only abnormal network traffic activities, but also quantify the level of maliciousness of incidents. The use of this methodology allowed for the identification of low-and-slow attacks which many other signature-based intrusion detection systems (IDS) may easily have missed.

**Conclusion for RQ1:** Supervised ML models are highly effective in detecting IIoT threats, offering both high accuracy and adaptability across dynamic industrial environments.

**RQ2:** Can a real-time IIoT risk quantification model effectively classify and mitigate cyber threats before they escalate?

The integration of ML predictions into a risk scoring framework (0 to 100) allowed continuous quantification of threat levels in real time. The normal traffic averages a low-risk or approximately 4.5 on the scale. The malicious traffic averages a high-risk or an approximate of 89 on the scale. There was a very distinct separation that would allow the security team to immediately prioritize those high-risk events. Kernel-density and boxplot visualizations confirmed to show how little there is in terms of overlap of these two classifications, and this helps increase the interpretation of the model.

In terms of the operational outcomes, the risk-scoring system will help security teams process alerts more quickly because they are only going to focus their efforts on high-probability threats. The simulation showed that it can be possible to lower the MTTR by over 50% because security analysts do not have to manually sort through large amounts of false positives that were created by static IDSs.

**Conclusion for RQ2:** A real-time ML-driven risk quantification model can both classify and mitigate threats effectively, improving incident response speed and precision.

**RQ3:** What are the most predictive risk factors for IIoT security, and how do they influence dynamic risk scoring?

An examination of feature importance in the Random Forest Classifier found that the Modbus function code behavior patterns (e.g., FC3\_Read\_Holding\_Register and FC4\_Read\_Coil) were among the strongest predictors of malicious behavior. Abnormalities in these registers had a strong correlation with abnormal traffic which is

consistent with the reality that adversaries subvert the read/write functions to manipulate process states.

By incorporating these telemetry-based indicators into the risk scoring mechanism, the model adjusted the risk score classification thresholds in real time producing risk scores that were applicable to the context of the data. This effectively eliminated the weaknesses associated with rule-based systems which viewed all anomalies as equal. The ML framework, on the other hand, weighed the features according to the predictive capabilities of their output thus allowing the critical features to score higher with more significance.

**Conclusion for RQ3:** The most predictive risk factors were Modbus function register behaviors, and their integration into dynamic scoring significantly improved classification performance and interpretability.

**H1:** ML-based risk quantification models achieve at least 10% higher threat detection accuracy than rule-based approaches.

This hypothesis has been proven correct. According to experimental data, the ML-driven models were able to achieve an accuracy of about 94%. For comparison, typical IIoT rule-based IDSs have an accuracy of around 78 to 80%. Therefore, the margin of improvement between the two types of models is a 15 to 16% advantage, which greatly exceeds the hypothesized 10% increase. The t-test statistics also validate the statistical significance of the differences ( $p < 0.001$ ).

**Conclusion for H1:** Supported. ML-based models significantly outperformed rule-based systems in accuracy, validating the hypothesis.

**H2:** An AI-driven real-time risk scoring model reduces MTTR by at least 50% compared to manual monitoring.

This hypothesis was supported as well. Using continuous risk scores, derived through aggregation of attack probabilities, the proposed system will provide the security team with actionable intelligence that is expected to reduce wasted time in false positive attacks. According to simulations, the MTTR for the proposed system can be reduced by approximately 51% compared to traditional security technology benchmarks such as those used in Parsons et al. (2023), who studied AI-driven security orchestration.

**Conclusion for H2:** Supported. The proposed framework demonstrated measurable improvements in incident response efficiency, reducing MTTR by over 50%.

**H3:** Incorporating network behavior and device telemetry improves classification performance by at least 3%.

This hypothesis was confirmed via comparative experiments. In both cases the models were trained solely using the data from network traffic. The first model had a nearly 91.6% F1 score; and after the addition of device telemetry the second model had a nearly 95.2% F1 score. The improvement of the model, via incorporation of additional modalities of data, demonstrated an approximate 3.9% improvement. This demonstrates the value of multi-modal source use in developing a model capable of detecting increasingly sophisticated threats.

**Conclusion for H3:** Supported. Incorporating telemetry data enhanced classification accuracy by nearly 4%, surpassing the expected 3% improvement threshold.

H1, H2 and H3 could not be rejected.

### **5.1.2 Failure Mode Analysis**

Some of these potential failures can be mitigated by employing multiple layers of validation to confirm all results produced by the model. Validation may include the employment of rule-based systems and the manual review of results by a security analyst. Fail-safe mechanisms can be implemented to ensure that the automated response of the system does not negatively impact operational continuity. An example of these mechanisms include establishing a high threshold to automatically generate alerts and establishing a human-in-the-loop to determine whether an alert should be generated.

### **5.1.3 Deployment Pathway**

The model can be safely integrated into existing industrial control systems through the implementation of a phased roll-out strategy. First, the model can be utilized as a passive monitoring tool to provide additional information to existing SIEM or SOAR systems (e.g., Splunk, QRadar, or Sentinel) using Application Programming Interfaces to ingest risk scores. Next, security analysts can be trained to understand how to interpret the probabilistic output values of the model, adjust the sensitivity of the model, and manually review anomalies produced by the model. Following the training of the analysts, the model can be regularly maintained by retraining the model every six to twelve months and performing periodic performance audits to determine if there is a drift in the data. Feedback from analysts about false positive events will be incorporated into the re-training of the model, thereby improving the accuracy of the model. As the model evolves, it will enable adaptive, near-real-time learning in the operational environment.

#### **5.1.4 Limitations Acknowledgment**

The analysis of this research was limited to the TON\_IoT Modbus dataset, which represents a controlled testbed environment. While the dataset is representative of industrial networks, it lacks the variety and noise present in actual industrial networks. Additionally, the scope of the research was limited to Modbus/TCP; therefore, other IIoT protocols (e.g., DNP3, MQTT, or OPC-UA) were not investigated. Thus, future research should investigate the model's effectiveness in actual industrial settings while considering various factors that might affect the performance of the model such as latency, throughput, etc. Although the results of this study indicate technical viability, they should be viewed as a solid foundation for further practical testing instead of the final deployment metrics.

#### **5.1.5 Adversarial Robustness**

ML-based IDS systems are susceptible to attacks that involve adversarial manipulation (e.g., attackers creating input that are intended to deceive the classifiers). Various types of threats exist to ML-based IDS systems (e.g., data poisoning, model inversion, or query-based extraction) that can adversely affect the model's ability to recognize malicious activity. Several strategies exist to address these vulnerabilities (e.g., adversarial training, input perturbation detection, and access-rate limiting within the model). Pairing the system with Modbus/TLS encryption or cryptographic integrity checks can also assist in ensuring that messages are authentic. Continually monitoring for anomalous query patterns can aid in identifying evasion attempts early in the attack process, which will further enhance the overall robustness of the system.

### **5.1.6 Regulatory and Compliance Considerations**

The model satisfies industrial cybersecurity standards (e.g., NIST SP 800-82 Rev. 3, ISA/IEC 62443) by supporting continuous risk assessment and anomaly detection at SL-3 and SL-4 maturity levels. However, to fully satisfy compliance requirements, obtaining formal certification and demonstrating the model's safe operation in an operational environment are required. The generation of false positives that cause a disruption in production may raise potential liability issues. A human confirmation control between detection and action will reduce this concern. The inclusion of certifications from frameworks such as UL 2900 or ISA Secure will establish the conformity and trustworthiness of the model for industrial deployments.

### **5.1.7 Cost–Benefit Analysis**

Economically, AI-driven risk quantification provides tangible returns on investment. The average cost of an industrial breach is greater than \$5.56 million (IBM, 2025). Downtime losses in industrial settings range from \$260,000 to \$2.3 million per hour (Siemens, 2024). Reducing incident response times in half and reducing false alarms will result in saving industrial organizations millions of dollars each year. Comparatively, the model's deployment will provide similar detection capabilities to commercial platforms such as Claroty or Nozomi Networks but will do so with lower licensing and operational costs. Based on an estimated 3–5× ROI over a 5-year period, the model's deployment can provide significant cost savings for mid-sized industrial facilities.



## **5.2 Conclusions**

The findings support that ML-based risk quantification systems are superior to rule-based detection systems in IIoT environments. In addition to providing a higher level of accuracy, the Random Forest model provides the ability to produce the most relevant and understandable results in terms of prioritization of output in relation to the operational requirements of an organization. By providing real-time risk scores to security teams, they can identify the most important alerts and address the main flaw of industrial cybersecurity Platforms currently in use today.

Collectively, these findings confirm each of the three Hypotheses (H1 – H3) and demonstrate how ML can increase both detection accuracy and operational efficiency. As such, this study has provided a bridge between academic research into ML and practical application in industry which will facilitate the transition towards proactive intelligent defense systems in IIoT environments.

## **5.3 Contributions to the Body of Knowledge**

Empirically, this research has contributed to IIoT cybersecurity through demonstration of how AI-driven risk quantification models perform better than traditional rule-based methods in terms of both accuracy and interpretability. Experiments conducted using the TON\_IoT Modbus dataset have demonstrated that RF classifiers, when used in conjunction with dynamic risk scoring, can accurately detect anomalous activity, while generating easy-to-understand metrics for analysts.

This study has also demonstrated the necessity of combining network behavior and device telemetry to enhance situational awareness. Relatively small improvements in performance ( $\approx 4\%$ ) can lead to large improvements in reliability in large-scale industrial

deployments. Lastly, the inclusion of continuous risk scoring allows operators to prioritize their response efforts more effectively and maintain system integrity.

## **5.4 Future Work and Improvements**

Future studies should seek to expand this framework to other industrial protocols, e.g., MQTT, DNP3, IEC 61850, and OPC-UA, in order to assess generalizability. Additionally, integration with SIEM and SOAR platforms will allow for automated playbook execution and coordinated threat responses.

Testing in live environments, such as SWaT or WADI, will provide insight into scalability under realistic latency and throughput constraints. Development of hybrid learning architectures, combining supervised, unsupervised, and reinforcement learning may improve adaptability to zero-day threats. These improvements will transform this research from a validated prototype to a deployable self-improving cybersecurity framework capable of defending modern IIoT systems in production environments.

## References

- Adaros-Boye, C., Kearney, P., & Josephs, M. (2019, October). Continuous risk management for industrial IoT: A methodological view. In *International Conference on Risks and Security of Internet and Systems* (pp. 34-49). Cham: Springer International Publishing.
- Affia, A. O., Nolte, A., & Matulevicius, R. (2023). IoT security risk management: A framework and teaching approach. *Informatics in Education*, 22(4), 555–587. <https://doi.org/10.15388/infedu.2023.30>
- Agbedanu, P. R., Yang, S. J., Musabe, R., Gatare, I., & Rwigema, J. (2025). A scalable approach to internet of things and industrial Internet of Things security: Evaluating adaptive self-adjusting memory K-nearest neighbor for zero-day attack detection. *Sensors*, 25(1), 216. <https://doi.org/10.3390/s25010216>
- Ahmed, C. M., Palleti, V. R., & Mathur, A. P. (2017, April 21). *WADI: A water distribution testbed for research in the design of secure cyber physical systems* [Conference presentation]. Proceedings of the 3rd International Workshop on Cyber-Physical Systems for Smart Water Networks, Pittsburgh, Pennsylvania. <https://dl.acm.org/doi/10.1145/3055366.3055375>
- Alsaedi A., Moustafa, N., Tari, Z., Mahmood, A., & Anwar, A. (2020). TON\_IoT telemetry dataset: A new generation dataset of IoT and IIoT for data-driven intrusion detection systems. *IEEE Access*, 8, 165130–165150. [doi:10.1109/ACCESS.2020.3022862](https://doi.org/10.1109/ACCESS.2020.3022862)

- Alwaisi, Z., Kumar, T., Harjula, E., & Soderi, S. (2024). Securing constrained IoT systems: A lightweight machine learning approach for anomaly detection and prevention. *Internet of Things*, 28, 101398. doi:10.1016/j.iot.2024.101398
- Antonakakis, M., April, T., Bailey, M., Bernhard, M., Bursztein, E., Cochran, J., Durumeric, Z., Halderman, A., Invernizzi, L., Kallitsis, M., Kumar, D., Lever, C., Ma, A., Mason, J., Menscher, D., Seaman, C., Sullivan, N., Thomas, K., & Zhao, Y. (2017, August 16-18). *Understanding the Mirai Botnet* [Symposium presentation]. 26th USENIX Security Symposium, Vancouver, Canada. <https://www.usenix.org/conference/usenixsecurity17/technical-sessions/presentation/antonakakis>
- Ashibani, Y., & Mahmoud, Q. H. (2017). Cyber-physical systems security: Analysis, challenges and solutions. *Computers & Security*, 68, 81–97. <https://doi.org/10.1016/j.cose.2017.04.005>
- Aslam, M. M., Tufail, A., De Silva, L. C., Haji Mohd Apong, R. A. A., & Namoun, A. (2024). An improved autoencoder-based approach for anomaly detection in industrial control systems. *Systems Science & Control Engineering*, 12(1). <https://doi.org/10.1080/21642583.2024.2334303>
- Ayodele, G. T. (2024). Machine learning in IoT security: Current issues and future prospects. *TechRxiv*, 1-6. doi: 10.36227/techrxiv.172833005.54645424/v1
- Baecker, L. (2025, July 21). *MTTR, MTBF, MTTA & MTTF — Metrics, examples, challenges, and tips*. *Hyperping* . <https://hyperping.com/blog/mttr-guide>

- Baker, F. C. (2021). *Inadequacy of existing security management frameworks in addressing internet of things (IoT) cybersecurity-related risks* [Unpublished doctoral dissertation]. Northcentral University School of Business.  
<https://www.proquest.com/openview/7ef49841802d54fff144083abf64a855/1?pq-origsite=gscholar&cbl=18750&diss=y>
- Beerman, J., Berent, D., Falter, Z., & Bhunia, S. (2023). *A review of colonial pipeline ransomware attack* [Symposium presentation]. 2023 IEEE/ACM 23rd International Symposium on Cluster, Cloud and Internet Computing Workshops (CCGridW), Bangalore, India.  
<https://doi.org/10.1109/CCGridW59191.2023.00017>
- Bhaiyat, H. Y., & Sithungu, S. P. (2022, May 1-4). The emergence of IIoT and its cyber security issues in critical information infrastructure. *Proceedings of the 21<sup>st</sup> European Conference on Cyber Warfare and Security*, 21(1), 46-51.  
<https://doi.org/10.34190/eccws.21.1.248>
- Biggio, B., & Roli, F. (2018). Wild patterns: Ten years after the rise of adversarial machine learning. *Pattern Recognition*, 84, 317–331.  
10.1016/j.patcog.2018.07.023
- Bin Hulayyil, S., Li, S., & Xu, L. (2023). Machine-learning-based vulnerability detection and classification in internet of things device security. *Electronics*, 12(18), 3927.  
doi:10.3390/electronics12183927
- Boyes, H., Hallaq, B., Cunningham, J., & Watson, T. (2018). The industrial internet of things (IIoT): An analysis framework. *Computers in Industry*, 101(8), 1–12.  
doi:10.1016/j.compind.2018.04.015

- Breiman, L. (2001). Random forests. *Machine Learning*, 45(1), 5–32.  
<https://doi.org/10.1023/A:1010933404324>
- Calderón, D., Folgado, F. J., González, I., & Calderón, A. J. (2024). Implementation and experimental application of industrial IoT architecture using automation and IoT hardware/software. *Sensors*, 24(24), 8074. doi:10.3390/s24248074
- Cheminod, M., Durante, L., & Valenzano, A. (2012). Review of security issues in industrial networks. *IEEE Transactions on Industrial Informatics*, 9(1), 277–293.  
<https://doi.org/10.1109/TII.2012.2198666>
- Chen, P., Ma, Z., Xu, C., Jin, Y., & Zhou, C. (2024). Self-supervised transfer learning for remote wear evaluation in machine tool elements with imaging transmission attenuation. *IEEE Internet of Things Journal*, 11(13), 23045–23054.  
<https://doi.org/10.1109/JIOT.2024.3382878>
- Cindrić, I., Jurčević, M., & Hadjina, T. (2025). Mapping of industrial IoT to IEC 62443 standards. *Sensors*, 25(3), 728. doi:10.3390/s25030728
- CISA. (2021). *DarkSide ransomware: Best practices for preventing business disruption from ransomware attacks*. Cybersecurity and Infrastructure Security Agency.  
<https://www.cisa.gov/news-events/cybersecurity-advisories/aa21-131a>
- Claroty. (2024). *The Claroty xDome: Industrial cybersecurity platform overview*. Claroty. [https://web-assets.claroty.com/resource-downloads/xdome\\_ds\\_0123.pdf](https://web-assets.claroty.com/resource-downloads/xdome_ds_0123.pdf)
- Cohen, J. (1988). *Statistical power analysis for the behavioral sciences* (2nd ed.). Lawrence Erlbaum Associates.  
<https://utstat.utoronto.ca/~brunner/oldclass/378f16/readings/CohenPower.pdf>

- Dairi, A., Harrou, F., & Sun, Y. (2022). Efficient driver drunk detection by sensors: A manifold learning-based anomaly detector. *IEEE Access*, 10, 119001-119012  
doi:10.1109/ACCESS.2022.3221145.
- E-ISAC, Lee, R. M., Assante, M. J., & Conway, T. (2016). Analysis of the cyber attack on the Ukrainian power grid:Defense Use Case. *Electricity Information Sharing And Analysis Center (E-ISAC)*, 388(1-26).
- Efron, B., & Tibshirani, R. J. (1993). *An introduction to the bootstrap*. Chapman & Hall/CRC.
- Elnour, M., Meskin, N., Khan, K., & Jain, R. (2020). A dual-isolation-forests-based attack detection framework for industrial control systems. *IEEE Access*, 1(1).  
doi: 10.1109/ACCESS.2020.2975066.
- Ferrag, M. A., Maglaras, L., Moschoyiannis, S., & Janicke, H. (2020). Deep learning for cyber security intrusion detection: Approaches, datasets, and comparative study. *Journal of Information Security and Applications*, 50, 102419.  
<https://doi.org/10.1016/j.jisa.2019.102419>
- Fischer, L., Ehrlinger, L., Geist, V., Ramler, R., Sobiezyk, F., Zellinger, W., Brunner, D., Kumar, M., & Moser, B. (2020). AI system engineering — Key challenges and lessons learned. *Machine Learning and Knowledge Extraction*, 3(1), 56-83.  
<https://doi.org/10.3390/make3010004>
- Goh, J., Adepu, S., Tan, M., & Lee, Z. S. (2017, January 12-14). *Anomaly detection in cyber physical systems using recurrent neural networks* [Symposium presentation]. 2017 IEEE 18th International Symposium on High Assurance Systems Engineering (HASE), Singapore. doi: 10.1109/HASE.2017.36.

- Greenberg, A. (2018, August 22). The untold story of NotPetya, the most devastating cyberattack in history. *Wired*. <https://www.wired.com/story/notpetya-cyberattack-ukraine-russia-code-crashed-the-world/>
- Hoang, T. (2024). *A framework for creating a security baseline for the internet of things with security controls: A design science study (D.C.S.)*. ProQuest Dissertations & Theses Global. (2922339980). Hard copy available on request.
- Humayed, A., Lin, J., Li, F., & Luo, B. (2017). Cyber-physical systems security—A survey. *IEEE Internet of Things Journal*, 4(6), 1802-1831.  
<https://ieeexplore.ieee.org/abstract/document/7924372/>
- IBM. (2025). Cost of a data breach report 2025: The AI oversight gap. *IBM*.  
<https://www.ibm.com/reports/data-breach>
- Inoue, J., Yamagata, Y., Chen, Y., Poskitt, C. M., & Sun, J. (2017, November 18-21). *Anomaly detection for a water treatment system using unsupervised machine learning* [Conference presentation]. 2017 IEEE International Conference on Data Mining Workshops (ICDMW), New Orleans, LA, USA.  
doi:10.1109/ICDMW.2017.149.
- IoT Inspector. (2021). IoT security report 2021. *IoT Inspector*. <https://www.iot-inspector.com/wp-content/uploads/2021/12/IoT-Inspector-Security-Report-2021.pdf>
- Iyalunaidu, S. (2024, January 25). Modbus communication protocol. *AutomationForum.co*. <https://automationforum.co/modbus-communication-protocol/>



- Jagielski, M., Oprea, A., Biggio, B., Liu, C., Nita-Rotaru, C., & Li, B. (2018, May 21-23). *Manipulating machine learning: Poisoning attacks and countermeasures for regression learning* [Symposium paper]. 2018 IEEE Symposium on Security and Privacy (SP), San Francisco, CA, USA. <https://doi.org/10.1109/SP.2018.00057>
- Karnouskos, S. (2011, November 1-10). *Stuxnet worm impact on industrial cyber-physical system security* [Conference presentation]. 37th Annual Conference of the IEEE Industrial Electronics Society, Melbourne, Australia. doi: 10.1109/IECON.2011.6120048.
- Khan, M. Y., Qayoom, A., Nizami, M. S., Siddiqui, M. S., Wasi, S., & Raazi, S. M. K. R. (2021). Automated prediction of Good Dictionary EXamples (GDEX): A comprehensive experiment with distant supervision, machine learning, and word embedding-based deep learning techniques. *Complexity*, 2021, 2553199. <https://doi.org/10.1155/2021/2553199>.
- Kiss, I., Bela, G., Haller, P., & Sebestyen, G. (2014, September 4-6). *Data clustering-based anomaly detection in industrial control systems* [Conference presentation]. 2014 IEEE 10th International Conference on Intelligent Computer Communication and Processing, ICCP, Cluj-Napoca, Romania 10.1109/ICCP.2014.6937009.
- KnowBe4. (2024). Cyber attacks on infrastructure: The new geopolitical weapon. *Global Infrastructure Report 2024*. [https://www.knowbe4.com/hubfs/Global-Infrastructure-Report-2024\\_EN\\_US.pdf](https://www.knowbe4.com/hubfs/Global-Infrastructure-Report-2024_EN_US.pdf)

- Knowles, W., Prince, D., Hutchison, D., Disso, J. F. P., & Jones, K. (2015). A survey of cyber security management in industrial control systems. *International Journal of Critical Infrastructure Protection*, 9, 52-80.  
<https://www.sciencedirect.com/science/article/pii/S1874548215000207>
- Koroniotis, N., Moustafa, N., Sitnikova, E., & Turnbull, B. (2019). Towards the development of realistic botnet dataset in the Internet of Things for network forensic analytics: Bot-IoT dataset. *Future Generation Computer Systems*, 100, 779–796. <https://doi.org/10.1016/j.future.2019.05.041>
- Kumar, N., & Raubal, M. (2021). Applications of deep learning in congestion detection, prediction and alleviation: A survey. *Transportation Research Part C: Emerging Technologies*, 133. 103432. <https://doi.org/10.1016/j.trc.2021.103432>.
- Kumar, R.S.S., Nyström, M., Lambert, J., Marshall, A., Goertzel, M., Comissoneru, A., Swann, M., & Xia, S. (2020, May 21). *Adversarial machine learning-industry perspectives* [Digital presentation]. 2020 IEEE Security and Privacy Workshops (SPW), San Francisco, CA, USA. <https://doi.org/10.1109/SPW50608.2020.00028>
- Lee, J., Bagheri, B., & Kao, H. A. (2015). A cyber-physical systems architecture for industry 4.0-based manufacturing systems. *Manufacturing Letters*, 3, 18–23.  
<https://doi.org/10.1016/j.mfglet.2014.12.001>
- Lim, W. Y. B., Luong, N. C., Hoang, D. T., Jiao, Y., Liang, Y. C., Yang, Q., Niyato, D., & Miao, C. (2019). Federated learning in mobile edge networks: A comprehensive survey. *arXiv.1909.11875 [cs.NI]*.  
<https://doi.org/10.48550/arXiv.1909.11875>.

- Lu, Y., Kamath, G., & Yu, Y. (2022). Indiscriminate data poisoning attacks on neural networks. *arXiv:2204.09092[cs.LG]*. <https://doi.org/10.48550/arXiv.2204.09092>
- Macaulay, T., & Singer, B. (2011). *Cybersecurity for industrial control systems: SCADA, DCS, PLC, HMI, and SIS*. CRC Press, Boca Raton, FL, USA.
- Makrakis, G. M., Kolias, C., Kambourakis, G., Rieger, C., & Benjamin, J. (2021). Industrial and critical infrastructure security: Technical analysis of real-life security incidents. *IEEE Access*, 9. 165295-165325. <https://doi.org/10.1109/ACCESS.2021.3133348>.
- Meidan, Y., Bohadana, M., Mathov, Y., Mirsky, Y., Shabtai, A., Breitenbacher, D., & Elovici, Y. (2018). N-BaIoT: Network-based detection of IoT botnet attacks using deep autoencoders. *IEEE Pervasive Computing*, 17(3), 12–22. <https://doi.org/10.1109/MPRV.2018.03367731>
- Modbus Organization. (2012, April 28). *MODBUS Application Protocol Specification v1.1b3*. Modbus Organization, Inc. [https://www.afs.enea.it/project/protosphaera/Protosphaera\\_Full\\_Documents/mpdocs/docs\\_EEI/Modbus\\_Application\\_Protocol\\_V1\\_1b3.pdf](https://www.afs.enea.it/project/protosphaera/Protosphaera_Full_Documents/mpdocs/docs_EEI/Modbus_Application_Protocol_V1_1b3.pdf)
- Modbus Organization. (2021, July 30). *MODBUS/TCP Security Protocol Specification*. Modbus Organization, Inc. <https://www.modbus.org/file/secure/modbussecurityprotocol.pdf>

- Morris, T., & Gao, W. (2014). *Industrial control system traffic data sets for intrusion detection research* [Conference paper]. In Butts, J, Shenoi, S (Eds.). Critical Infrastructure Protection VIII. ICCIP 2014., Springer: Berlin, Heidelberg  
[https://link.springer.com/chapter/10.1007/978-3-662-45355-1\\_5](https://link.springer.com/chapter/10.1007/978-3-662-45355-1_5)
- Moustafa, N., Turnbull, B., & Choo, K. K. R. (2018). An ensemble intrusion detection technique based on proposed statistical flow features for protecting network traffic of Internet of Things. *IEEE Internet of Things Journal*, 6(3).  
<https://ieeexplore.ieee.org/abstract/document/8470090>
- Nozomi Networks. (2024). *OT & IoT threat detection and monitoring*. Nozomi Networks. [https://cdn.prod.website-files.com/645a4534705010e2cb244f50/65b121e2e08c0ab6e6b0278d\\_Nozomi-Networks-Platform-Overview.pdf](https://cdn.prod.website-files.com/645a4534705010e2cb244f50/65b121e2e08c0ab6e6b0278d_Nozomi-Networks-Platform-Overview.pdf)
- Pal, S., & Jadidi, Z. (2021). Analysis of security issues and countermeasures for the industrial Internet of Things. *Applied Sciences*, 11(20), 9393.  
<https://doi.org/10.3390/app11209393>
- Parsons, E. K., Panaousis, E., Loukas, G., & Sakellari, G. (2023). A survey on cyber risk management for the Internet of Things. *Applied Sciences*, 13(15), 9032.  
<https://doi.org/10.3390/app13159032>
- Paul, B., Sarker, A., Abhi, S. H., Das, S. K., Ali, M. F., Islam, M. M., Islam, M. R., Moyeen, S. I., Badal, M. F. R., Ahamad, M. H., Sarker, S. K., Das, P., Hasan, M. M., & Saqib, N. (2024). Potential smart grid vulnerabilities to cyber attacks: Current threats and existing mitigation strategies. *Heliyon*, 10(19), e37980.  
<https://doi.org/10.1016/j.heliyon.2024.e37980>

- Peng, S., Han, Y., Liang, X., Yang, C., Gui, W., and Zhou, N. (2024, October 30) *ROSE-BOX: An approach for intrusion detection in industrial Internet of Things* [Symposium presentation]. 2024 IEEE International Symposium on Parallel and Distributed Processing with Applications (ISPA), Kaifeng, China.  
<https://doi.org/10.1109/ISPA63168.2024.00325>.
- Pereira, A. C., & Romero, F. (2017). A review of the meanings and the implications of the Industry 4.0 concept. *Procedia Manufacturing*, 13, 1206-1214.  
<https://www.sciencedirect.com/science/article/pii/S2351978917306649>
- Raman, M. R., Ahmed, C. M., & Mathur, A. (2021). Machine learning for intrusion detection in industrial control systems: Challenges and lessons from experimental evaluation. *Cybersecurity*, 4,(27). <https://doi.org/10.1186/s42400-021-00095-5>
- Sadeghi, A. R., Wachsmann, C., & Waidner, M. (2015, June 7-11). *Security and privacy challenges in Industrial Internet of Things* [Conference presentation]. Proceedings of the 52<sup>nd</sup> Annual Design Automation Conference, San Francisco, California.  
<https://dl.acm.org/doi/abs/10.1145/2744769.2747942>
- Sharma, A., & Babbar, H. (2023, March 15-17). *BoT-IoT: Detection of DDoS attacks in Internet of Things for smart cities* [Conference presentation]. 2023 10th International Conference on Computing for Sustainable Global Development, New Delhi, India.
- Sharma, A., Sharma, A., Tselykh, A., Bozhenyuk, A., & Kim, B. G. (2024). Image and video analysis using graph neural network for Internet of Medical Things and computer vision applications. *CAAI Transactions on Intelligence Technology*, 1-15. <https://doi.org/10.1049/cit2.12306>.

- Shi, W., Cao, J., Zhang, Q., Li, Y., & Xu, L. (2016). Edge computing: Vision and challenges. *IEEE Internet of Things Journal*, 3(5), 637–646.  
<https://doi.org/10.1109/JIOT.2016.2579198>
- Siddiqui, S., Hameed, S., Shah, S. A., Khan, A. K., & Aneiba, A. (2023). Smart contract-based security architecture for collaborative services in municipal smart cities. *Journal of Systems Architecture*, 135, 102802.  
<https://doi.org/10.1016/j.sysarc.2022.102802>
- Siemens. (2024). The true cost of downtime 2024. *Siemens*.  
[https://assets.new.siemens.com/siemens/assets/api/uuid:1b43afb5-2d07-47f7-9eb7-893fe7d0bc59/TCOD-2024\\_original.pdf](https://assets.new.siemens.com/siemens/assets/api/uuid:1b43afb5-2d07-47f7-9eb7-893fe7d0bc59/TCOD-2024_original.pdf)
- Simmons, A. (2022, November 13). Internet of things (IOT) architecture: Layers explained. *Dgtl Infra*. <https://dgtlinfra.com/internet-of-things-iot-architecture/>
- Sinha, S., & Lee, Y. M. (2024). Challenges with developing and deploying AI models and applications in industrial systems. *Discover Artificial Intelligence* 4, 55 (2024). <https://doi.org/10.1007/s44163-024-00151-2>
- Sommer, R., & Paxson, V. (2010, May 16-19). *Outside the closed world: On using machine learning for network intrusion detection* [Symposium presentation]. 2010 IEEE Symposium on Security and Privacy, Oakland, California, USA.  
<https://doi.org/10.1109/SP.2010.25>
- Srinivasan, M., & Senthilkumar, N. C. (2025). Intrusion detection and prevention system (IDPS) model for IIoT environments using hybridized framework. *IEEE Access*, 13, 26608–26621. <https://doi.org/10.1109/ACCESS.2025.3538461>

- Stouffer, K., Pease, M., Tang, C., Zimmerman, T., Pillitteri, V., Lightman, S., Hahn, A., Saravia, S., Sherule, A., & Thompson, M. (2023). Guide to operational technology (OT) Security, *NIST SP 800-82 Rev. 3*.  
<https://csrc.nist.gov/pubs/sp/800/82/r3/final>
- Transforma Insights (2020, May 19). Global IoT market to grow to 24.1 billion devices in 2030, generating \$1.5 trillion annual revenue. *Transforma Insights*.  
<https://transformainsights.com/news/iot-market-24-billion-usd15-trillion-revenue-2030>
- Verizon. (2020). Mobile Security Index 2020 Report: Securing the IoT. *Verizon Business*.  
<https://www.verizon.com/business/resources/reports/mobile-security-index/2020/5g-and-iot-security/securing-the-iot-new-risks-threats/>
- Wang, M., Sun, Y., Sun, H., & Zhang, B. (2023). Security issues on industrial Internet of Things: Overview and challenges. *Computers*, 12(12), 256.  
<https://doi.org/10.3390/computers12120256>
- Wu, Z., Pan, S., Chen, F., Long, G., Zhang, C., & Yu, P. S. (2021). A comprehensive survey on graph neural networks. *IEEE Transactions on Neural Networks and Learning Systems*, 32(1), 4-24. <https://doi.org/10.1109/TNNLS.2020.2978386>
- Xu, L. D., He, W., & Li, S. (2014). Internet of Things in industries: A survey. *IEEE Transactions on Industrial Informatics*, 10(4), 2233–2243.  
<https://doi.org/10.1109/TII.2014.2300753>
- Yang, Q., Liu, Y. Chen, T., & Tong, Y. (2019). Federated machine learning: Concept and applications. *arXiv.1902.04885 [cs.AI]*  
<https://doi.org/10.48550/arXiv.1902.04885>

Yazdi, M., Zarei, E., Adumene, S., & Beheshti, A. (2024). Navigating the power of artificial intelligence in risk management: A comparative analysis. *Safety*, 10(2), 42. <https://doi.org/10.3390/safety10020042>

Zahran, B., Hussaini, A., & Ali-Gombe, A. (2021, April 26-28). *IIoT-ARAS: IIoT/ICS automated risk assessment system for prediction and prevention* [Virtual Conference presentation]. Proceedings of the Eleventh ACM Conference on Data and Application Security and Privacy, Baltimore-Washington, DC Area, USA. <https://dl.acm.org/doi/abs/10.1145/3422337.3450320>



ProQuest Number: 32400055

INFORMATION TO ALL USERS

The quality and completeness of this reproduction is dependent on the quality and completeness of the copy made available to ProQuest.



Distributed by  
ProQuest LLC a part of Clarivate ( 2025).  
Copyright of the Dissertation is held by the Author unless otherwise noted.

This work is protected against unauthorized copying under Title 17,  
United States Code and other applicable copyright laws.

This work may be used in accordance with the terms of the Creative Commons license or other rights statement, as indicated in the copyright statement or in the metadata associated with this work. Unless otherwise specified in the copyright statement or the metadata, all rights are reserved by the copyright holder.

ProQuest LLC  
789 East Eisenhower Parkway  
Ann Arbor, MI 48108 USA